TRƯỜNG ĐẠI HỌC SƯ PHẠM KỸ THUẬT TP.HCM

KHOA CÔNG NGHỆ THÔNG TIN

VŨ ĐÌNH KHANG : 22162015

TRẦN THẾ TRUNG : 22162051

Đề Tài : **HỆ THỐNG PHÁT HIỆN VÀ PHẢN HỒI XÂM NHẬP SỬ DỤNG MÃ NGUỒN MỞ**

TIỂU LUẬN CHUYÊN NGÀNH KHOA CNTT

GIÁO VIÊN HƯỚNG DẪN

ThS. NGUYỄN THỊ THANH VÂN

Tp. Hồ Chí Minh, tháng 12 năm 2025

ĐH SƯ PHẠM KỸ THUẬT TP.HCM	**XÃ HỘI CHỦ NGHĨA VIỆT NAM**
KHOA CNTT	**Độc lập – Tự do – Hạnh Phúc**
*******	*******

PHIẾU NHẬN XÉT CỦA GIÁO VIÊN HƯỚNG DẪN

Họ và tên Sinh viên 1: Vũ Đình Khang MSSV 1: 22162015
Họ và tên Sinh viên 2: Trần Thế Trung MSSV 2: 22162051
Ngành: An toàn Thông tin
Tên đề tài: HỆ THỐNG PHÁT HIỆN VÀ PHẢN HỒI XÂM NHẬP SỬ DỤNG MÃ NGUỒN MỞ
Họ và tên Giáo viên hướng dẫn:

NHẬN XÉT

1. Về nội dung đề tài & khối lượng thực hiện:

2. Ưu điểm:

3. Khuyết điểm

4. Đề nghị cho bảo vệ hay không?
5. Đánh giá loại:
6. Điểm:

Tp. *Hồ Chí Minh, ngày tháng năm 2025*

Giáo viên hướng dẫn

(Ký & ghi rõ họ tên)

ĐH SƯ PHẠM KỸ THUẬT TP.HCM	**XÃ HỘI CHỦ NGHĨA VIỆT NAM**
KHOA CNTT	**Độc lập – Tự do – Hạnh Phúc**
*******	*******

PHIẾU NHẬN XÉT CỦA GIÁO VIÊN PHẢN BIỆN

Họ và tên Sinh viên 1: Vũ Đình Khang MSSV 1: 22162015
Họ và tên Sinh viên 2: Trần Thế Trung MSSV 2: 22162051
Ngành: Công nghệ Thông tin
Tên đề tài: HỆ THỐNG PHÁT HIỆN VÀ PHẢN HỒI XÂM NHẬP SỬ DỤNG MÃ NGUỒN MỞ
Họ và tên Giáo viên phản biện:

NHẬN XÉT

1. Về nội dung đề tài & khối lượng thực hiện:

2. Ưu điểm:

3. Khuyết điểm

4. Đề nghị cho bảo vệ hay không?
5. Đánh giá loại:
6. Điểm:

Tp. *Hồ Chí Minh, ngày tháng năm 2025*

Giáo viên phản biện

(Ký & ghi rõ họ tên)

LỜI CẢM ƠN

Trong quá trình học tập tại Trường Đại học Sư Phạm Kỹ Thuật TP. Hồ Chí Minh, chúng em đã nhận được sự giảng dạy tận tình của quý Thầy (Cô) về kiến thức chuyên môn cũng như những hiểu biết bổ ích về lĩnh vực an toàn thông tin và công nghệ thông tin. Những kiến thức mà quý Thầy (Cô) đã truyền đạt là nền tảng quan trọng giúp chúng em hoàn thành tốt tiểu luận trong thời gian quy định.

Chúng em xin chân thành cảm ơn quý Thầy (Cô) đã hướng dẫn, giảng dạy và định hướng cho chúng em trong suốt quá trình học tập, tạo điều kiện thuận lợi để em có thể thực hiện đề tài "Hệ thống phát hiện và phản hồi xâm nhập sử dụng mã nguồn mở".

Trong suốt thời gian thực hiện đề tài và hoàn thành báo cáo, chúng em đã nhận được sự hỗ trợ quý báu từ cô ThS. Nguyễn Thị Thanh Vân, các Thầy (Cô) trong khoa Công nghệ Thông tin, cùng sự động viên, chia sẻ và giúp đỡ nhiệt tình của các anh chị và các bạn học cùng khóa. Với lòng kính trọng và biết ơn sâu sắc, chúng em xin gửi lời cảm ơn chân thành đến tất cả.

Bên cạnh đó, chúng em xin gửi lời tri ân đến gia đình và bạn bè đã luôn động viên, ủng hộ và tạo điều kiện thuận lợi để chúng em yên tâm học tập và hoàn thành tốt tiểu luận này.

Kính chúc quý Thầy (Cô) luôn mạnh khỏe, thành công và tiếp tục truyền cảm hứng cho nhiều thế hệ sinh viên trong tương lai.

Chúng em xin chân thành cảm ơn!

TÓM TẮT

Trong bối cảnh các cuộc tấn công mạng ngày càng tinh vi và nguy hiểm, việc chỉ dừng lại ở khả năng phát hiện xâm nhập (IDS) không còn đủ để bảo vệ hệ thống mạng một cách hiệu quả. Do đó, nhu cầu xây dựng các giải pháp chủ động có khả năng ngăn chặn và phản hồi tự động (IPS/IRS) ngày càng trở nên cấp thiết.

Tiểu luận này trình bày quá trình nghiên cứu, thiết kế và triển khai một hệ thống phát hiện và phản hồi xâm nhập dựa trên mã nguồn mở, kết hợp các công nghệ Suricata (IDS/IPS), ELK Stack (phân tích log) và mô-đun Mini-SOAR (Python Script) để tự động hóa quá trình ngăn chặn tấn công.

Hệ thống được triển khai theo mô hình Gateway trên môi trường ảo hóa (VirtualBox/VMware), bao gồm ba thành phần chính: máy tấn công (Kali Linux), máy phòng thủ (Ubuntu Server chạy Suricata, Filebeat, Elasticsearch, Kibana và mô-đun phản hồi tự động), và máy nạn nhân (DVWA Web Server). Suricata đảm nhiệm vai trò thu thập và phân tích lưu lượng gói tin theo thời gian thực, trong khi ELK Stack giúp trực quan hóa và giám sát toàn bộ hoạt động an ninh. Mini-SOAR đóng vai trò ra quyết định và tương tác trực tiếp với tường lửa (Nftables/Iptables) để chặn IP khi phát hiện tấn công nguy hiểm.

Các kịch bản thử nghiệm bao gồm nhiều dạng tấn công phổ biến như SQL Injection, Cross-Site Scripting, Path Traversal, File Upload, Network Scanning và DoS. Kết quả thực nghiệm cho thấy hệ thống không chỉ phát hiện chính xác các mẫu tấn công mà còn thực hiện hành động ngăn chặn kịp thời, đồng thời gửi cảnh báo về Telegram/Email, đáp ứng tốt yêu cầu của một hệ thống an ninh mạng hiện đại.

Tiểu luận góp phần làm rõ khả năng ứng dụng của các giải pháp mã nguồn mở trong xây dựng hệ thống phòng thủ an ninh mạng chi phí thấp nhưng hiệu quả, đồng thời là nền tảng để phát triển các hệ thống SOAR quy mô lớn trong tương lai.

MỤC LỤC

DANH MỤC VIẾT TẮT 1

DANH MỤC HÌNH ẢNH 3

PHẦN MỞ ĐẦU 6

1. Lý do chọn đề tài 6

2. Mục tiêu đề tài 6

3. Đối tượng và phạm vi nghiên cứu 6

4. Phương pháp nghiên cứu 7

5. Nội dung đề tài. 8

NỘI DUNG 9

Chương 1: Tổng quan về Hệ thống phát hiện và phản hồi xâm nhập (IDS/IPS) 9

1.1.Hệ thống phát hiện xâm nhập – IDS 9

1.1.1.Khái niệm 9

1.1.2.Chức năng 9

1.1.3.Phân loại 10

1.1.4.Cơ chế hoạt động 11

1.2.Hệ thống ngăn chặn xâm nhập IPS 12

1.2.1.Khái niệm 12

1.2.2.Chức năng 13

1.2.3.Phân loại 14

1.2.4.Cơ chế hoạt động 15

1.3. Hệ thống phản hồi xâm nhập (IRS) 15

1.3.1Khái niệm 16

1.3.2.Các mô hình phản hồi 16

1.3.3.Các kỹ thuật phản hồi phổ biến 17

Chương 2: Công nghệ IDS/IPS (Suricata) và phân tích (ELK Stack)..... 19
2.1.Suricata..... 19
2.1.1. Giới thiệu về Suricata..... 19
2.1.2.Kiến trúc của Suricata 20
2.1.3.Các chế độ hoạt động 21
2.1.4.Cấu trúc luật 22
2.1.5. Bộ luật Emerging Threats (ET Open) 23
2.1.6. Phương pháp viết luật tùy chỉnh (Custom Rules) 24
2.1.7. Cơ chế xuất log (EVE-JSON) 26
2.2.Hệ thống phân tích log (ELK Stack)..... 27
2.2.1.Elasticsearch..... 27
2.2.2.Filebeat..... 28
2.2.3.Kibana 29
2.3. Mô-đun phản hồi tự động..... 29
2.3.1. Luồng thực thi tổng thể của thuật toán 29
2.3.2. Cơ chế thu thập và xử lý sự kiện..... 35
2.3.3. Cơ chế ra quyết định và luật phản hồi 38
2.3.4. Tương tác với tường lửa..... 41
2.3.5. Quản lý trạng thái và vòng đời lệnh cấm 43
2.3.6. Hệ thống cảnh báo và API quản trị 46
Chương 3: Triển khai và thử nghiệm..... 49
3.1. Kiến trúc tổng thể của hệ thống 49
3.2.Mô tả thực nghiệm 54
3.2.1. Nhóm tấn công Ứng dụng Web (Web Application Attacks)..... 54
3.2.2. Nhóm tấn công Hạ tầng Mạng (Network Infrastructure Attacks) 54

3.2.3. Nhóm tấn công Tự động và Dò mật khẩu (Automation & Brute Force) 55
3.2.4. Nhóm ngăn chặn lộ lọt dữ liệu (Data Loss Prevention - DLP) 55
3.3.Cài đặt và triển khai hệ thống 55
3.3.1 Cài đặt và Cấu hình Suricata 55
3.3.2 Triển khai ELK Stack (Log Management) 59
3.3.3 Cài đặt Filebeat (Log Shipper) 61
3.3.4 Triển khai Mini-SOAR (Active Response Script) 62
3.4.Triển khai các kịch bản thử nghiệm 65
3.4.1. Kịch bản 1: Ngăn chặn tấn công SQL Injection (SQLi) 65
3.4.2. Kịch bản 2: Ngăn chặn tấn công Cross-Site Scripting (XSS) 67
3.4.3. Kịch bản 3: Ngăn chặn tấn công Path Traversal (LFI) 69
3.4.4. Kịch bản 4: Ngăn chặn tải lên mã độc (Malicious File Upload) 72
3.4.5. Kịch bản 5: Ngăn chặn tấn công từ chối dịch vụ (DoS - SYN Flood) .. 74
3.4.6. Kịch bản 6: Ngăn chặn dò quét mạng (Network Scanning) 76
3.4.7. Kịch bản 7: Ngăn chặn tấn công dò quét và Brute Force Web 78
3.4.8. Kịch bản 8: Ngăn chặn tấn công Shellshock (Remote Code Execution) 81
3.5. Kết quả giám sát và trực quan hóa trên ELK Stack 83
3.5.1. Tra cứu log chi tiết (Discover) 83
3.5.2. Dashboard tổng quan (Visualization) 84
KẾT LUẬN 87
TÀI LIỆU THAM KHẢO 89

DANH MỤC VIẾT TẮT

Viết tắt	Tên đầy đủ
AIDS	Anomaly-based Intrusion Detection System
DDoS	Distributed Denial of Service
DoS	Denial of Service
ELK	Elasticsearch, Logstash, Kibana
ET Open	Emerging Threats Open
EVE	Extensible Event Format
HIDS	Host-based Intrusion Detection System
HIPS	Host-based Intrusion Prevention System
IDS	Intrusion Detection System
IPS	Intrusion Prevention System
IRS	Intrusion Response System
JSON	JavaScript Object Notation
MPM	Multi-Pattern Matcher
NIDS	Network-based Intrusion Detection System
NIPS	Network-based Intrusion Prevention System

NRT	Near Real-Time
NSM	Network Security Monitoring
OISF	Open Information Security Foundation
SID	Signature ID
SIEM	Security Information and Event Management
SOAR	Security Orchestration, Automation and Response
SQLi	SQL Injection
TAP	Test Access Point
TTL	Time-to-Live
WAL	Write-Ahead Logging
XSS	Cross-Site Scripting

DANH MỤC HÌNH ẢNH

Hình 1.1: So sánh triển khai IDS và IPS 13

Hình 1.2: Quy trính xử lý phản hồi sự cố tự động 16

Hình 2.1: Quy trình hoạt động của ELK Stack kết hợp Suricata 27

Hình 2.2: Lưu đồ khởi động code phản hồi tự động mini-SOAR.py 30

Hình 2.3: Lưu đồ hoạt động tổng thể của mini-SOAR.py 31

Hình 2.4: Lưu đồ thuật toán đọc log và xử lý xoay vòng 32

Hình 2.5: Lưu đồ quy trình lọc sự kiện và khử trùng lặp 33

Hình 2.6: Lưu đồ logic ra quyết định phản hồi 34

Hình 2.7: Lưu đồ luồng tự động gỡ bỏ lệnh cấm 35

Hình 2.8: Lưu đồ thu thập và lọc sự kiện 36

Hình 2.9: Lưu đồ quy trình ra quyết định và ánh xạ luật phản hồi 39

Hình 2.10: Lưu đồ logic tương tác và lựa chọn nền tảng tường lửa 42

Hình 2.11: Lưu đồ cơ chế quản lý trạng thái và luồng gỡ bỏ tự động 45

Hình 2.12: Lưu đồ luồng cảnh báo đa kênh 47

Hình 2.13: Lưu đồ luồng API quản trị 47

Hình 3.1: Sơ đồ mạng 49

Hình 3.2: Kiến trúc tổng thể của hệ thống 51

Hình 3.3: Khởi chạy Suricata 59

Hình 3.4: Khởi chạy Elasticsearch thành công 60

Hình 3.5:Khởi chạy Kibana thành công 61

Hình 3.6:Trang web không phản hồi sau khi kẻ tấn công submit lệnh tấn công 66

Hình 3.7: Log Suricata báo drop gói tin với rule SQL Injection 67

Hình 3.8: Log ban IP và gửi thông tin về email của script theo Rule SQL Injection 67

Hình 3.9: Thông báo blocked IP do Rule SQL Injection được gửi về Email 67

Hình 3.10: Trang web không phản hồi sau khi kẻ tấn công submit lệnh tấn công.... 68

Hình 3.11: Log Suricata báo drop gói tin với rule XSS 69

Hình 3.12: Log ban IP và gửi thông tin về email của script theo Rule XSS 69

Hình 3.13: Thông báo blocked IP do Rule XSS được gửi về Email 69

Hình 3.14: Phía tấn công không nhận được phản hồi..... 71

Hình 3.15: Log Suricata báo drop gói tin với rule LFI..... 71

Hình 3.16: Log ban IP và gửi thông tin về email của script theo Rule LFI 71

Hình 3.17: Thông báo blocked IP do Rule LFI được gửi về Email..... 71

Hình 3.18: Trang web không phản hồi sau khi kẻ tấn công submit lệnh tấn công.... 73

Hình 3.19: Log Suricata báo drop gói tin với rule nội dung chứa mã độc 73

Hình 3.20: Log ban IP và gửi thông tin về email của script theo Rule nội dung chứa mã độc 73

Hình 3.21: Thông báo blocked IP do Rule nội dung chứa mã độc được gửi về Email 74

Hình 3.22: Phía tấn công thất bại khi các gói tin đã bị chặn 75

Hình 3.23: Log Suricata báo drop gói tin với rule Dos 76

Hình 3.24:Log ban IP và gửi thông tin về email của script theo Rule Dos 76

Hình 3.25: Thông báo blocked IP do Rule Dos được gửi về Email 76

Hình 3.26: Phía tấn công không nhận được phản hồi..... 78

Hình 3.27: Log Suricata báo drop gói tin với rule Port Scanning 78

Hình 3.28: Log ban IP và gửi thông tin về email của script theo Rule Port Scanning 78

Hình 3.29: Thông báo blocked IP do Rule Port Scanning được gửi về Email..... 78

Hình 3.30: Phía tấn công không dò quét được do bị chặn..... 80

Hình 3.31: Log Suricata báo drop gói tin với rule Brute Force..... 81

Hình 3.32: Log ban IP và gửi thông tin về email của script theo Rule Brute Force . 81

Hình 3.33: Thông báo blocked IP do Rule Brute Force được gửi về Email 81

Hình 3.34: Phía tấn công không nhận được phản hồi 82

Hình 3.35: Log Suricata báo drop gói tin với rule liên quan tới lỗ hổng Bash Shellshock (CVE-2014-6271) 83

Hình 3.36: Log ban IP và gửi thông tin về email của script theo Rule liên quan tới lỗ hổng Bash Shellshock (CVE-2014-6271) 83

Hình 3.37: Thông báo blocked IP do Rule liên quan tới lỗ hổng Bash Shellshock (CVE-2014-6271) được gửi về Email 83

Hình 3.38: Trang Discover được filter theo alert 84

Hình 3.39: Dashboard theo Event Overview 85

Hình 3.40: Dashboard theo Alert Overview 85

Hình 3.41: Thông tin của alert 86

PHẦN MỞ ĐẦU

1. Lý do chọn đề tài

Sự bùng nổ của chuyển đổi số kéo theo các cuộc tấn công mạng ngày càng tinh vi, khiến các biện pháp phòng thủ truyền thống như tường lửa trở nên khó kiểm soát toàn bộ. Trong khi các giải pháp thương mại thường đắt đỏ và khó tùy biến, công nghệ mã nguồn mở nổi lên như một lựa chọn tối ưu, đặc biệt là Suricata với kiến trúc đa luồng hiệu năng cao thay thế cho các thế hệ IDS cũ.

Tuy nhiên, để bảo vệ hệ thống hiệu quả, chỉ phát hiện xâm nhập là chưa đủ mà cần phải có cơ chế phản hồi (Response) tức thời nhằm giảm thiểu thiệt hại. Xuất phát từ thực tế đó, đề tài "Hệ thống phát hiện và phản hồi xâm nhập sử dụng mã nguồn mở" được lựa chọn nghiên cứu. Mục tiêu là xây dựng giải pháp an ninh khép kín, chi phí thấp nhưng đảm bảo khả năng giám sát sâu và tự động ngăn chặn tấn công, phù hợp với nhu cầu thực tiễn của nhiều tổ chức hiện nay.

2. Mục tiêu đề tài

Mục tiêu chủ đạo của đề tài là nghiên cứu, thiết kế và triển khai một hệ thống an ninh mạng khép kín có khả năng phát hiện sớm và phản hồi tự động trước các nguy cơ xâm nhập, hoàn toàn dựa trên nền tảng các công cụ mã nguồn mở. Hệ thống hướng đến việc tích hợp engine Suricata để nhận diện chính xác các dạng tấn công mạng phổ biến như dò quét cổng, từ chối dịch vụ (DoS) hay các khai thác lỗ hổng ứng dụng web. Song song với năng lực phát hiện, đề tài tập trung giải quyết bài toán phản hồi tức thời thông qua việc xây dựng cơ chế phân tích dữ liệu tập trung và tự động kích hoạt các kịch bản ngay khi phát hiện dấu hiệu bất thường, từ đó giúp giảm thiểu độ trễ xử lý và nâng cao khả năng tự vệ chủ động cho hệ thống mạng.

3. Đối tượng và phạm vi nghiên cứu

Đối tượng nghiên cứu trọng tâm của đề tài là các giải pháp và công nghệ mã nguồn mở phục vụ cho việc giám sát an ninh mạng. Cụ thể, đề tài đi sâu phân tích kiến trúc, cơ chế hoạt động đa luồng và quy trình xử lý gói tin của công cụ Suricata IDS/IPS, cùng với đó là việc nghiên cứu bộ luật (ruleset) để nhận diện các dấu hiệu xâm nhập. Bên cạnh đó, đề tài cũng nghiên cứu các kỹ thuật tấn công mạng phổ biến hiện nay để làm cơ sở xây dựng kịch bản thử nghiệm, đồng thời tìm hiểu cách thức vận hành của

ELK Stack trong việc thu thập, chuẩn hóa log và cơ chế tương tác với tường lửa (như Iptables/Netfilter) để thực hiện hành động phản hồi tự động.

Về phạm vi nghiên cứu, đề tài được giới hạn trong việc thiết kế và triển khai hệ thống trên môi trường mạng giả lập (Lab) quy mô nhỏ, mô phỏng mô hình mạng doanh nghiệp cơ bản. Hệ thống sẽ tập trung vào việc phát hiện và ngăn chặn các dạng tấn công cụ thể ở tầng mạng (Network Layer) và tầng ứng dụng (Application Layer) như: quét cổng, tấn công từ chối dịch vụ (DoS/DDoS), và các lỗ hổng web (SQL Injection, XSS). Đề tài không đi sâu vào việc giải mã lưu lượng được mã hóa phức tạp hay các phương thức tấn công phi kỹ thuật (Social Engineering), mà tập trung tối ưu hóa hiệu năng phát hiện và tốc độ phản hồi của hệ thống trong môi trường thử nghiệm đã thiết lập.

4. Phương pháp nghiên cứu.

Để giải quyết các mục tiêu đã đề ra, đề tài áp dụng phương pháp nghiên cứu lý thuyết làm nền tảng ban đầu. Quá trình này bao gồm việc thu thập, tổng hợp và phân tích các tài liệu chuyên ngành về an toàn thông tin, kiến trúc của các hệ thống IDS/IPS. Cụ thể, đề tài tập trung nghiên cứu sâu về cơ chế hoạt động của Suricata, cách thức xây dựng bộ luật phát hiện xâm nhập (Signature-based), cũng như kiến trúc xử lý dữ liệu lớn của ELK Stack để đảm bảo việc thiết kế hệ thống tuân thủ các nguyên tắc kỹ thuật chuẩn mực.

Dựa trên cơ sở lý thuyết, phương pháp nghiên cứu thực nghiệm được sử dụng làm phương pháp chủ đạo để triển khai hệ thống. Nhóm tiến hành xây dựng một môi trường mạng giả lập (Lab) sử dụng công nghệ ảo hóa, mô phỏng lại mô hình mạng cơ bản. Tại đây, việc cài đặt, cấu hình và tích hợp các công cụ mã nguồn mở (Suricata, Elasticsearch, Logstash, Kibana) được thực hiện để tạo thành một quy trình từ lúc thu thập gói tin, phân tích log cho đến khi kích hoạt script phản hồi tự động.

Cuối cùng, phương pháp giả lập tấn công và đánh giá định lượng được áp dụng để kiểm chứng hiệu quả của hệ thống. Đề tài sử dụng các công cụ kiểm thử an ninh mạng (Penetration Testing tools) để thực hiện các kịch bản tấn công mẫu như dò quét mạng, khai thác lỗ hổng web hay tấn công từ chối dịch vụ vào hệ thống đã xây dựng. Kết quả thực nghiệm sẽ được đo lường dựa trên các chỉ số cụ thể như độ chính xác trong

việc phát hiện, tỷ lệ cảnh báo sai (false positive) và thời gian trễ (latency) từ khi cuộc tấn công bắt đầu cho đến khi hệ thống thực hiện hành động ngăn chặn thành công.

5. Nội dung đề tài.

Nội dung đồ án được cấu trúc thành ba chương chính.

-Chương 1 hệ thống hóa cơ sở lý thuyết về IDS/IPS và các mô hình phản hồi xâm nhập tự động.

-Chương 2 đi sâu phân tích công nghệ lõi, bao gồm kiến trúc Suricata, hệ thống phân tích log ELK Stack và thiết kế mô-đun phản hồi bằng script.

-Chương 3 trình bày quá trình triển khai thực nghiệm trên môi trường giả lập, kiểm chứng hiệu quả hệ thống qua các kịch bản tấn công thực tế và đánh giá các chỉ số hiệu năng cụ thể.

NỘI DUNG

CHƯƠNG 1: TỔNG QUAN VỀ HỆ THỐNG PHÁT HIỆN VÀ PHẢN HỒI XÂM NHẬP (IDS/IPS)

1.1.Hệ thống phát hiện xâm nhập – IDS

1.1.1.Khái niệm

Hệ thống phát hiện xâm nhập (Intrusion Detection System - IDS) được định nghĩa là một giải pháp an ninh mạng, có thể tồn tại dưới dạng thiết bị phần cứng chuyên dụng hoặc phần mềm cài đặt trên máy chủ. Nhiệm vụ cốt lõi của IDS là tự động giám sát lưu lượng mạng (network traffic) hoặc các hoạt động trên hệ thống máy tính nhằm phát hiện các hành vi xâm nhập trái phép, các hoạt động độc hại (như phát tán mã độc, tấn công từ chối dịch vụ) hoặc các vi phạm chính sách bảo mật mà tổ chức đã thiết lập.

Khác với tường lửa (Firewall) truyền thống – vốn đóng vai trò như một "người gác cổng" chỉ cho phép hoặc chặn lưu lượng dựa trên địa chỉ IP và cổng tại lớp biên – IDS hoạt động ở mức độ sâu hơn. Nó thực hiện phân tích sâu gói tin (Deep Packet Inspection) hoặc theo dõi các hành vi bất thường bên trong hệ thống để tìm kiếm các dấu hiệu tấn công mà tường lửa có thể bỏ qua. Khi phát hiện một sự kiện đáng ngờ, IDS sẽ ghi lại nhật ký (log) chi tiết và gửi cảnh báo (alert) tức thời đến quản trị viên hoặc Hệ thống quản lý thông tin và sự kiện an ninh (SIEM).

Có thể hình dung vai trò của IDS tương tự như một "hệ thống báo động" hoặc "camera giám sát" trong mô hình an ninh vật lý. IDS tập trung vào khả năng "nhìn thấy" (visibility) và phát hiện. Mặc dù ở cấu hình cơ bản, IDS hoạt động thụ động và không trực tiếp ngăn chặn tấn công (khác với IPS), nhưng nó cung cấp những thông tin tình báo quan trọng, giúp quản trị viên nắm bắt được tình hình an ninh mạng theo thời gian thực và đưa ra các quyết định phản hồi chính xác.

1.1.2.Chức năng

Chức năng nền tảng và quan trọng nhất của hệ thống IDS là giám sát và thu thập dữ liệu (Monitoring). Hệ thống hoạt động liên tục 24/7 để lắng nghe mọi lưu lượng đi

qua các điểm kiểm soát trên mạng hoặc giám sát các sự kiện trên máy chủ (như truy cập tệp tin, thay đổi registry). Tại bước này, IDS đóng vai trò như một bộ cảm biến thụ động, sao chép các luồng dữ liệu để xử lý mà không làm ảnh hưởng đến hiệu năng hay tính toàn vẹn của đường truyền mạng chính.

Dựa trên dữ liệu thu thập được, IDS thực hiện chức năng phân tích và phát hiện (Analysis & Detection). Hệ thống sử dụng các thuật toán chuyên sâu để mổ xẻ cấu trúc gói tin (Deep Packet Inspection), giải mã các giao thức mạng và so sánh chúng với cơ sở dữ liệu các mẫu tấn công đã biết (Signatures) hoặc mô hình hành vi chuẩn (Baseline). Chức năng này cho phép IDS nhận diện chính xác các dấu hiệu xâm nhập đa dạng, từ các cuộc thăm dò mạng đơn giản như quét cổng (Port Scanning) đến các cuộc tấn công phức tạp ở tầng ứng dụng như SQL Injection hay phát tán mã độc.

Cuối cùng, IDS thực hiện chức năng cảnh báo và ghi nhật ký (Alerting & Logging). Ngay khi phát hiện sự cố, hệ thống sẽ tạo ra các cảnh báo tức thời gửi đến người quản trị qua nhiều kênh (console, email, SMS) hoặc đẩy dữ liệu về hệ thống quản lý tập trung (SIEM). Đồng thời, IDS lưu trữ lại toàn bộ thông tin chi tiết về sự kiện (thời gian, địa chỉ nguồn/đích, loại tấn công, nội dung gói tin) vào nhật ký hệ thống. Chức năng lưu trữ này đặc biệt quan trọng, phục vụ cho công tác điều tra số (Digital Forensics) sau sự cố và giúp tổ chức đáp ứng các tiêu chuẩn tuân thủ bảo mật.

1.1.3.Phân loại

Dựa trên phạm vi giám sát và nguồn dữ liệu, hệ thống IDS được chia thành hai loại chính là Network-based IDS (NIDS) và Host-based IDS (HIDS). NIDS được triển khai tại các điểm nút chiến lược trong mạng (như bộ định tuyến hoặc cổng Mirror của Switch) để giám sát lưu lượng đi qua toàn bộ phân đoạn mạng (subnet). Ưu điểm của NIDS là khả năng bao quát rộng, không ảnh hưởng đến hiệu năng của các máy chủ và khó bị kẻ tấn công vô hiệu hóa. Ngược lại, HIDS là các phần mềm đại lý (agent) được cài đặt trực tiếp trên từng máy chủ hoặc máy trạm cụ thể. HIDS tập trung giám sát các hoạt động nội bộ như nhật ký hệ điều hành, tính toàn vẹn của tệp tin hệ thống và các truy cập bộ nhớ, cho phép phát hiện các cuộc tấn công leo thang đặc quyền mà NIDS khó nhận thấy.

Xét theo phương pháp phát hiện, IDS được phân loại thành Signature-based (SIDS) và Anomaly-based (AIDS). Signature-based IDS hoạt động dựa trên việc so sánh nội dung gói tin với một cơ sở dữ liệu chứa các mẫu chữ ký tấn công đã biết (tương tự như phần mềm diệt virus). Phương pháp này có độ chính xác rất cao và tốc độ xử lý nhanh đối với các mối đe dọa đã được công bố, nhưng lại hoàn toàn "mù" trước các cuộc tấn công mới chưa từng xuất hiện (Zero-day attacks).

Để khắc phục nhược điểm trên, Anomaly-based IDS sử dụng các thuật toán thống kê hoặc học máy (Machine Learning) để xây dựng một mô hình hành vi "bình thường" (baseline) của hệ thống mạng. Bất kỳ hoạt động nào sai lệch đáng kể so với mô hình chuẩn này (ví dụ: lưu lượng tăng đột biến vào ban đêm) sẽ bị coi là bất thường và kích hoạt cảnh báo. Mặc dù có khả năng phát hiện các tấn công chưa biết (Zero-day), phương pháp này thường có tỷ lệ cảnh báo sai (false positive) cao do khó phân biệt giữa hành vi bất thường vô hại và tấn công thực sự.

1.1.4.Cơ chế hoạt động

Cơ chế hoạt động của IDS là một quy trình khép kín bắt đầu từ thu thập và tiền xử lý dữ liệu. Ở giai đoạn đầu vào, các cảm biến (sensor) của IDS được đặt ở chế độ "hỗn tạp" (promiscuous mode) để bắt giữ toàn bộ các gói tin đi qua card mạng, thay vì chỉ nhận các gói tin gửi đích danh cho nó. Dữ liệu thô sau khi thu thập sẽ đi qua bộ giải mã và tiền xử lý nhằm tái lập lại các dòng (stream) TCP, ghép nối các gói tin bị phân mảnh và chuẩn hóa các giao thức (ví dụ: giải mã các chuỗi URL encoded). Bước này đóng vai trò quan trọng để đảm bảo dữ liệu đầu vào sạch và nhất quán trước khi đưa vào bộ máy phân tích.

Tiếp theo là giai đoạn phân tích và phát hiện (Detection Engine), được coi là "trí tuệ" của hệ thống. Tại đây, dữ liệu đã chuẩn hóa được đối sánh với cơ sở dữ liệu luật (Rules/Signatures) hoặc mô hình hành vi đã thiết lập. Bộ máy phân tích sẽ kiểm tra từng trường thông tin trong gói tin (như Header, Payload) để tìm kiếm các khớp nối với mẫu tấn công. Ví dụ, nếu một gói tin chứa chuỗi ký tự đặc trưng của mã độc WannaCry hoặc có hành vi quét cổng dồn dập trong thời gian ngắn, bộ máy sẽ đánh dấu đây là một sự kiện đáng ngờ.

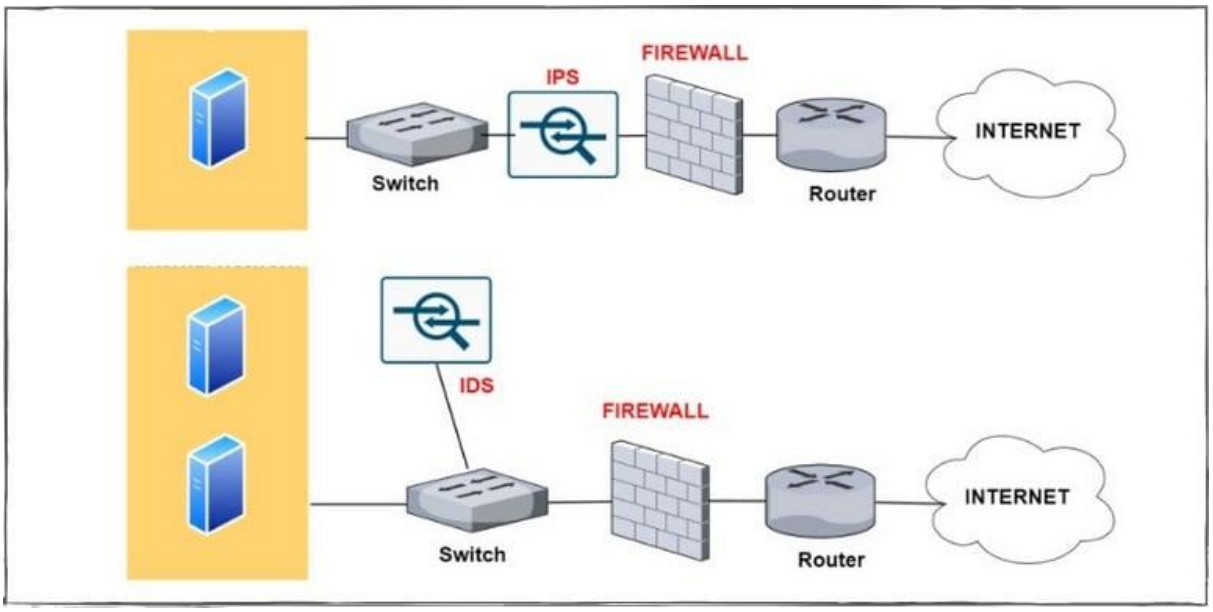
Giai đoạn cuối cùng là báo cáo và phản hồi. Khi một sự kiện xâm nhập được xác định, IDS sẽ kích hoạt cơ chế đầu ra (Output module). Hệ thống sẽ ghi lại chi tiết sự kiện vào tệp log (bao gồm thời gian, địa chỉ IP nguồn/đích, loại luật bị vi phạm) và gửi cảnh báo thời gian thực đến quản trị viên hoặc hệ thống SIEM. Tùy thuộc vào cấu hình, nếu IDS được tích hợp cơ chế ngăn chặn (IPS), nó có thể chủ động gửi lệnh để ngắt kết nối hoặc cập nhật quy tắc cho tường lửa nhằm chặn đứng cuộc tấn công ngay lập tức.

1.2.Hệ thống ngăn chặn xâm nhập IPS

1.2.1.Khái niệm

Hệ thống ngăn chặn xâm nhập (Intrusion Prevention System - IPS) là một giải pháp an ninh mạng chủ động, được xem là bước tiến hóa kế tiếp của IDS. Nếu như IDS đóng vai trò như một "camera giám sát" chỉ quan sát và báo động, thì IPS hoạt động như một "nhân viên an ninh" có quyền lực thực thi, đứng chắn ngay tại cổng để kiểm soát ra vào. Về bản chất, IPS là một thiết bị hoặc phần mềm an ninh mạng có khả năng giám sát lưu lượng mạng hoặc hoạt động hệ thống nhằm phát hiện các hành vi độc hại, nhưng điểm khác biệt cốt lõi là nó có khả năng tự động thực hiện các hành động ngăn chặn ngay lập tức để chặn đứng cuộc tấn công trước khi nó gây hại cho mục tiêu.

Để thực hiện được khả năng ngăn chặn này, IPS được triển khai theo mô hình "Inline" (nằm trực tiếp trên đường truyền). Điều này có nghĩa là toàn bộ lưu lượng mạng giữa vùng không an toàn (Internet) và vùng an toàn (Mạng nội bộ) bắt buộc phải đi xuyên qua thiết bị IPS. Khác với IDS thường nhận bản sao của gói tin qua cổng Mirror (SPAN port), IPS hoạt động như một nút chặn trung gian (bottleneck); nó chặn giữ gói tin lại để phân tích, nếu gói tin sạch thì mới cho đi qua, còn nếu phát hiện mã độc hoặc dấu hiệu tấn công, IPS sẽ lập tức hủy bỏ (drop) gói tin đó. Sự khác biệt cơ bản về vị trí triển khai giữa IDS (giám sát thụ động) và IPS (giám sát chủ động trên đường truyền Inline) được minh họa cụ thể trong Hình [X]



Hình 1.1: So sánh triển khai IDS và IPS

Chính vì đặc điểm hoạt động trực tiếp trên luồng dữ liệu, IPS cung cấp khả năng bảo vệ theo thời gian thực (Real-time protection). Nó không chỉ cảnh báo quản trị viên về sự cố đang diễn ra mà còn chủ động loại bỏ các mối đe dọa như sâu máy tính (worms), tấn công từ chối dịch vụ (DoS) hay các nỗ lực khai thác lỗ hổng phần mềm ngay tại thời điểm chúng phát sinh, giúp giảm thiểu tối đa độ trễ trong quy trình phản ứng sự cố.

1.2.2.Chức năng

Chức năng quan trọng nhất phân biệt IPS với các hệ thống giám sát khác là khả năng ngăn chặn chủ động (Active Prevention). Do được đặt trực tiếp trên đường truyền (Inline), IPS có quyền kiểm soát dòng chảy dữ liệu. Khi phát hiện một gói tin hoặc luồng dữ liệu vi phạm chính sách bảo mật, IPS có thể lập tức thực thi các hành động như hủy bỏ gói tin (Drop packet) để nó không thể đến được đích, hoặc gửi tín hiệu ngắt kết nối TCP (TCP Reset) để chấm dứt phiên làm việc giữa kẻ tấn công và nạn nhân. Cơ chế này diễn ra hoàn toàn tự động và gần như tức thời, giúp vô hiệu hóa mối đe dọa trước khi chúng kịp gây hại cho hệ thống.

Bên cạnh việc chặn tấn công, IPS còn thực hiện chức năng "Vá lỗ hổng ảo" (Virtual Patching). Trong thực tế quản trị mạng, khi một lỗ hổng bảo mật mới (vulnerability) được công bố, các quản trị viên thường mất một khoảng thời gian đáng kể để kiểm tra và cập nhật bản vá lỗi cho hệ thống máy chủ. Trong khoảng "thời gian

chết" này, hệ thống rất dễ bị tấn công. IPS giải quyết vấn đề này bằng cách áp dụng các luật (rules) đặc biệt để nhận diện và chặn các nỗ lực khai thác lỗ hổng đó ngay tại lớp mạng. Điều này tạo ra một lớp bảo vệ tạm thời, giúp bảo vệ các hệ thống chưa được cập nhật (unpatched systems) khỏi bị khai thác mà không cần phải can thiệp trực tiếp vào mã nguồn hay cấu hình máy chủ.

Ngoài ra, IPS còn có chức năng chuẩn hóa lưu lượng (Traffic Normalization). Kẻ tấn công thường sử dụng các kỹ thuật trốn tránh (evasion techniques) như phân mảnh gói tin (fragmentation), gửi chồng chéo dữ liệu hoặc sử dụng các biến thể giao thức lạ để đánh lừa tường lửa và IDS. IPS có khả năng tái lập và sắp xếp lại các gói tin theo đúng trình tự, loại bỏ các dữ liệu thừa hoặc sai lệch quy chuẩn trước khi chuyển tiếp chúng vào mạng nội bộ. Chức năng này không chỉ giúp phát hiện tấn công chính xác hơn mà còn giúp lọc sạch lưu lượng rác, tối ưu hóa hiệu năng cho các thiết bị phía sau.

1.2.3.Phân loại

Tương tự như hệ thống phát hiện xâm nhập, IPS cũng được phân loại dựa trên phạm vi bảo vệ và vị trí triển khai, với hai loại hình phổ biến nhất là Network-based IPS (NIPS) và Host-based IPS (HIPS).

Hệ thống ngăn chặn xâm nhập dựa trên mạng (Network-based IPS - NIPS) thường là các thiết bị phần cứng chuyên dụng hoặc các máy chủ ảo hóa được đặt tại các vị trí chiến lược trong hạ tầng mạng, điển hình là ngay sau tường lửa biên hoặc tại các điểm giao tiếp giữa các vùng mạng khác nhau (như giữa mạng nội bộ và vùng DMZ). NIPS hoạt động ở chế độ "Inline" (trực tuyến), nghĩa là nó nằm chắn ngang đường truyền vật lý, buộc toàn bộ lưu lượng mạng của phân đoạn đó phải đi qua nó để kiểm tra. Ưu điểm lớn nhất của NIPS là khả năng bảo vệ diện rộng cho hàng loạt thiết bị phía sau chỉ với một điểm kiểm soát duy nhất, giúp đơn giản hóa việc quản lý và cập nhật các luật bảo mật cho toàn bộ hệ thống mạng.

Hệ thống ngăn chặn xâm nhập dựa trên máy chủ (Host-based IPS - HIPS) là các phần mềm hoặc tác nhân (agent) được cài đặt trực tiếp trên từng máy chủ hoặc thiết bị đầu cuối cụ thể (như Database Server, Web Server). Thay vì giám sát lưu lượng mạng tổng thể, HIPS tập trung bảo vệ hệ điều hành và các ứng dụng đang chạy trên chính

thiết bị đó. HIPS hoạt động bằng cách giám sát các lời gọi hệ thống (system calls), sự thay đổi của các tệp tin quan trọng và các kết nối mạng đi vào/ra khỏi card mạng của máy chủ. Lợi thế đặc biệt của HIPS so với NIPS là khả năng phân tích được dữ liệu đã được giải mã (trong trường hợp lưu lượng HTTPS/TLS), đồng thời có thể ngăn chặn các cuộc tấn công nội bộ hoặc các hành vi leo thang đặc quyền mà các thiết bị mạng ở lớp biên không thể nhìn thấy.

1.2.4.Cơ chế hoạt động

Cơ chế hoạt động của hệ thống IPS được xây dựng dựa trên nguyên tắc xử lý "Inline" (nằm trực tiếp trên đường truyền). Khác với cơ chế lắng nghe thụ động (Promiscuous mode) của IDS vốn chỉ sao chép gói tin để phân tích song song, IPS hoạt động như một cầu nối (bridge) hoặc bộ định tuyến (router) ảo nằm chắn giữa luồng dữ liệu. Khi một gói tin đi từ mạng ngoài vào hệ thống nội bộ, nó bắt buộc phải đi qua giao diện mạng của IPS. Tại đây, IPS sẽ tạm giữ gói tin trong bộ đệm (buffer) và không chuyển tiếp nó đến đích ngay lập tức mà giữ lại để thực hiện quy trình kiểm tra an ninh.

Quá trình phân tích diễn ra trong thời gian thực cực ngắn để đảm bảo không gây độ trễ (latency) đáng kể cho mạng. IPS sử dụng các bộ máy phân tích (inspection engine) để giải mã các lớp giao thức, tái lập các luồng dữ liệu bị phân mảnh và đối sánh nội dung gói tin với cơ sở dữ liệu luật (signatures) hoặc các hồ sơ hành vi bất thường. Do đứng ở vị trí nút thắt cổ chai, các giải pháp IPS hiện đại (như Suricata) thường áp dụng công nghệ xử lý đa luồng (multi-threading) và tăng tốc phần cứng để đảm bảo tốc độ xử lý (throughput) theo kịp băng thông mạng.

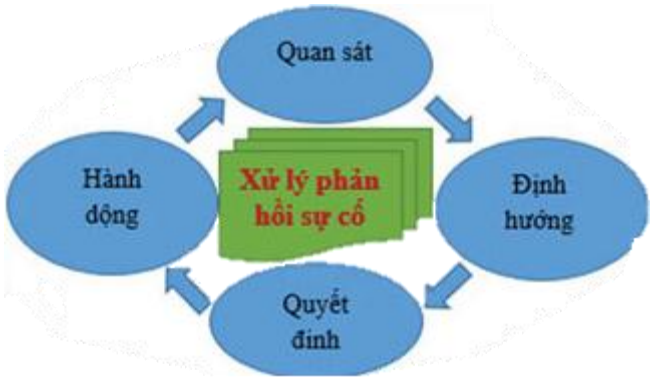
Kết thúc quá trình phân tích, IPS sẽ đưa ra quyết định xử lý dựa trên kết quả đối sánh. Nếu gói tin hợp lệ và không vi phạm chính sách, IPS sẽ giải phóng nó khỏi bộ đệm và chuyển tiếp (forward) đến đích. Ngược lại, nếu phát hiện dấu hiệu tấn công, IPS sẽ kích hoạt cơ chế ngăn chặn tức thời với các hành động cụ thể như: âm thầm hủy bỏ gói tin (Drop) khiến kẻ tấn công bị "treo" kết nối, hoặc gửi tín hiệu ngắt kết nối (TCP Reset) về phía nguồn tấn công. Song song với hành động chặn, IPS cũng ghi lại nhật ký sự kiện (log) để phục vụ công tác điều tra sau này.

1.3. Hệ thống phản hồi xâm nhập (IRS)

1.3.1Khái niệm

Hệ thống phản hồi xâm nhập (Intrusion Response System - IRS) được định nghĩa là một tập hợp các quy trình, công cụ và chính sách được thiết kế để tự động hoặc bán tự động thực hiện các biện pháp đối phó ngay sau khi một cuộc xâm nhập hoặc tấn công mạng bị phát hiện. Nếu như IDS đóng vai trò là "cảm biến" để nhận diện mối đe dọa, thì IRS đóng vai trò là "bộ phận thực thi" nhằm xử lý hậu quả. Nhiệm vụ cốt lõi của IRS là tiếp nhận các cảnh báo từ hệ thống phát hiện, phân tích mức độ nghiêm trọng và kích hoạt các hành động kỹ thuật cụ thể để ngăn chặn cuộc tấn công lan rộng, giảm thiểu thiệt hại và đưa hệ thống trở lại trạng thái an toàn.

Trong kiến trúc an ninh mạng hiện đại, IRS là thành phần quan trọng để khép kín vòng tròn bảo mật (Security Loop). Trước đây, việc phản hồi thường phụ thuộc hoàn toàn vào con người (quản trị viên nhận email cảnh báo rồi đăng nhập vào tường lửa để chặn thủ công). Tuy nhiên, với tốc độ tấn công ngày càng nhanh của các mã độc và botnet, phản hồi thủ công thường tạo ra độ trễ quá lớn (latency), tạo cơ hội cho kẻ tấn công hoàn thành mục đích. Do đó, IRS hiện đại tập trung vào tính tự động hóa, chuyển đổi từ mô hình phản ứng thụ động sang mô hình phòng thủ chủ động, nơi các kịch bản ngăn chặn được lập trình sẵn để thực thi ngay lập tức khi điều kiện kích hoạt được thỏa mãn.



Hình 1.2: Quy trính xử lý phản hồi sự cố tự động

1.3.2.Các mô hình phản hồi

Dựa trên khả năng kiểm tra của người dùng trong quá trình xử lý quy trình, các hệ thống phản hồi xâm nhập được phân chia thành ba mô hình chính: thủ công, bán tự

động và tự động hoàn toàn. Việc lựa chọn mô hình nào phụ thuộc vào tốc độ phản hồi nhanh chóng và có nguy cơ ảnh hưởng đến tính năng sẵn sàng của dịch vụ.

Mô hình phản hồi thủ công là phương pháp truyền thống tốt nhất, trong đó hệ thống an ninh chỉ đóng vai trò phát hiện và gửi cảnh báo. Quản trị viên sau khi nhận được thông báo sẽ phải trực tiếp phân tích nhật ký, xác thực độ chính xác của sự kiện và tự động thực hiện các thao tác kỹ thuật (như đăng nhập vào Bộ định tuyến/Tường lửa để bổ sung luật chặn). Ưu điểm của mô hình này là mức độ an toàn cao, tránh hệ thống tự động chặn lỗi hợp lệ người dùng (False Positive) do có trình duyệt của người dùng. Tuy nhiên, nhược điểm chí mạng là độ trễ lớn. Trong bối cảnh cuộc tấn công hiện đại diễn ra với tốc độ cao, khoảng thời gian chờ xử lý là quá đủ để tấn công hoàn thành việc đánh cắp dữ liệu hoặc gây tổn hại cho hệ thống.

Mô hình phản hồi bán tự động đóng vai trò trung gian, kết nối giữa tốc độ của máy và phán đoán của con người. Trong mô hình này, khi phát hiện xâm nhập, hệ thống sẽ tự động đề xuất phương pháp xử lý (ví dụ: chuẩn bị sẵn một tập lệnh chặn IP) và gửi yêu cầu xác thực nhận đến quản trị viên. Người quản trị chỉ cần thực hiện một thao tác đơn giản (như nhấn nút "Chấp nhận") để hệ thống thực thi lệnh. Mô hình này giúp giảm bớt gánh nặng kỹ thuật và thời gian vận hành cho nhân sự, nhưng vẫn tồn tại ở mức độ phụ thuộc vào thời gian phản hồi và khả năng xử lý thông tin của con người.

Mô hình phản hồi tự động là cấp độ cao nhất và cũng là mục tiêu hướng tới của đề tài. Hệ thống được ủy quyền để tự động thực thi các biện pháp ngăn chặn ngay lập tức khi phát hiện dấu hiệu tấn công mà không cần đến can can của con người. Cơ chế này loại bỏ hoàn toàn "thời gian chết" giữa hiện tại và phản hồi, đảm bảo an ninh 24/7. Tuy nhiên, quy trình lớn nhất của mô hình này là nguy cơ chặn triệt để (False Positive). Nếu luật phát hiện không chính xác, hệ thống có thể tự động chặn các truy cập hợp lệ, gây gián đoạn hoạt động kinh doanh (DoS chính mình). Do đó, mô hình này Yêu cầu luật phát hiện (quy tắc phát hiện) phải có độ chính xác cực cao và thường được áp dụng kết hợp với cơ chế Whitelist (danh sách tin cậy).

1.3.3.Các kỹ thuật phản hồi phổ biến

Các kỹ thuật phản hồi trong an ninh mạng thường được phân chia thành hai nhóm chính: phản hồi thụ động (Passive Response) và phản hồi chủ động (Active Response). Kỹ thuật phản hồi thụ động tập trung vào việc thông báo và lưu trữ. Phổ biến nhất là cơ chế Gửi cảnh báo (Alerting/Notification). Khi phát hiện sự cố, hệ thống sẽ tự động gửi thông báo chi tiết đến quản trị viên qua email, tin nhắn (SMS/Telegram) hoặc đẩy dữ liệu về giao diện giám sát trung tâm (Dashboard). Song song với đó là kỹ thuật Ghi nhật ký (Logging), đảm bảo mọi dấu vết của cuộc tấn công được lưu trữ an toàn để phục vụ công tác điều tra số (Forensics) sau này. Nhóm kỹ thuật này không tác động trực tiếp lên kẻ tấn công nên tuyệt đối an toàn cho hệ thống vận hành, nhưng không thể ngăn chặn thiệt hại tức thời.

Kỹ thuật phản hồi chủ động can thiệp trực tiếp vào luồng dữ liệu để ngăn chặn cuộc tấn công. Phương pháp phổ biến và hiệu quả nhất ở cấp độ mạng là Chặn địa chỉ IP (IP Blocking/Shunning). Hệ thống phản hồi sẽ tương tác với tường lửa (Firewall) hoặc Router để thêm địa chỉ IP của kẻ tấn công vào danh sách đen (Blacklist). Tùy thuộc vào chính sách, việc chặn này có thể là vĩnh viễn hoặc tạm thời trong một khoảng thời gian nhất định (ví dụ: 30 phút) để làm nản lòng kẻ tấn công. Đây là kỹ thuật trọng tâm mà đề tài hướng tới triển khai, sử dụng script để cập nhật luật cho Iptables/Netfilter.

Một kỹ thuật chủ động khác mang tính kỹ thuật sâu hơn là Ngắt kết nối (Session Sniping/TCP Reset). Thay vì chặn toàn bộ IP, hệ thống gửi các gói tin TCP với cờ RST (Reset) giả mạo đến cả máy nạn nhân và máy tấn công, buộc hai bên phải đóng kết nối ngay lập tức. Kỹ thuật này hiệu quả để ngắt các phiên làm việc độc hại cụ thể mà không chặn hoàn toàn truy cập của người dùng. Ngoài ra, đối với các hệ thống phòng thủ chiều sâu, kỹ thuật Cô lập (Quarantine/Isolation) cũng được áp dụng. Khi một máy tính trong mạng nội bộ bị phát hiện nhiễm mã độc, hệ thống sẽ tự động chuyển cổng switch của máy đó sang một VLAN cách ly (Quarantine VLAN), ngăn không cho mã độc lây lan sang các máy khác (Lateral Movement) trong khi vẫn cho phép quản trị viên truy cập để khắc phục sự cố.

CHƯƠNG 2: CÔNG NGHỆ IDS/IPS (SURICATA) VÀ PHÂN TÍCH (ELK STACK)

2.1.Suricata

2.1.1. Giới thiệu về Suricata

Suricata là một công cụ mã nguồn mở thế hệ mới hoạt động với vai trò là Hệ thống phát hiện xâm nhập (IDS), Hệ thống ngăn chặn xâm nhập (IPS) và Giám sát an ninh mạng (Network Security Monitoring - NSM). Công cụ này được phát triển và duy trì bởi tổ chức phi lợi nhuận Open Information Security Foundation (OISF), với sự đóng góp từ cộng đồng bảo mật toàn cầu và các tập đoàn công nghệ lớn. Ra đời nhằm khắc phục những hạn chế về hiệu năng của các hệ thống IDS truyền thống, Suricata nhanh chóng trở thành tiêu chuẩn công nghiệp nhờ khả năng xử lý lưu lượng mạng tốc độ cao và tính năng phân tích sâu toàn diện.

Điểm đột phá lớn nhất về mặt công nghệ của Suricata so với các đối thủ (điển hình là phiên bản Snort cũ) nằm ở kiến trúc đa luồng (Multi-threading). Trong khi các IDS truyền thống thường hoạt động đơn luồng (single-threaded) – nghĩa là chỉ sử dụng được một nhân CPU để xử lý tất cả các gói tin, dễ gây ra hiện tượng thắt cổ chai khi lưu lượng mạng tăng cao – thì Suricata được thiết kế để tận dụng tối đa sức mạnh của các vi xử lý đa nhân hiện đại. Nó có thể chia nhỏ luồng dữ liệu và phân phối tải xử lý đồng thời trên nhiều nhân CPU, giúp tăng băng thông xử lý (throughput) và giảm thiểu rủi ro rớt gói tin (packet loss) trong môi trường mạng doanh nghiệp tải trọng lớn.

Bên cạnh hiệu năng, Suricata còn sở hữu khả năng nhận diện giao thức thông minh. Thay vì chỉ dựa vào số hiệu cổng (port) để xác định giao thức (ví dụ: mặc định cổng 80 là HTTP), Suricata tự động phân tích luồng dữ liệu để nhận diện chính xác giao thức thực sự đang chạy, bất kể nó sử dụng cổng nào. Điều này giúp phát hiện các phần mềm độc hại cố tình ẩn mình dưới các cổng không tiêu chuẩn để trốn tránh sự kiểm soát. Ngoài ra, Suricata hỗ trợ xuất nhật ký dưới định dạng chuẩn EVE JSON, cho phép dễ dàng tích hợp và phân tích với các hệ thống Big Data như ELK Stack hay Splunk, tạo điều kiện thuận lợi cho việc xây dựng các Dashboard giám sát trực quan.

2.1.2.Kiến trúc của Suricata

Kiến trúc của Suricata được thiết kế dựa trên mô hình đa luồng (Multi-threading) và mô-đun hóa (Modular). Khác với kiến trúc đơn luồng truyền thống xử lý tuần tự từng gói tin, Suricata chia nhỏ quy trình xử lý thành các tác vụ độc lập và phân phối chúng cho nhiều luồng (threads) chạy song song trên các nhân CPU khác nhau. Cốt lõi của kiến trúc này là sự phối hợp giữa các mô-đun chức năng chính: mô-đun thu thập gói tin (Packet Acquisition), mô-đun giải mã và xử lý luồng (Decode & Stream), mô-đun phát hiện (Detection) và mô-đun đầu ra (Output). Các luồng này giao tiếp với nhau thông qua các hàng đợi (queues) đệm dữ liệu hiệu năng cao, đảm bảo tốc độ xử lý được duy trì ổn định ngay cả khi lưu lượng mạng tăng đột biến.

Quy trình xử lý một gói tin trong kiến trúc Suricata diễn ra theo trình tự nghiêm ngặt. Đầu tiên, Mô-đun Thu thập tiếp nhận các gói tin thô từ giao diện mạng (sử dụng các công nghệ như AF_PACKET, PF_RING hoặc NFQUEUE). Sau đó, gói tin được chuyển sang Mô-đun Giải mã, nơi các header của giao thức (Ethernet, IP, TCP/UDP) được phân tích để xác định cấu trúc. Điểm đặc biệt trong kiến trúc Suricata là khả năng tái lập luồng (Stream Reassembly) mạnh mẽ tại giai đoạn này; nó ghép nối các gói tin TCP bị phân mảnh thành một luồng dữ liệu hoàn chỉnh, giúp bộ máy phát hiện nhìn thấy toàn bộ nội dung (payload) thay vì các mảnh rời rạc, ngăn chặn kẻ tấn công sử dụng kỹ thuật phân mảnh để qua mặt IDS.

Sau khi dữ liệu đã được chuẩn hóa, nó đi vào Mô-đun Phát hiện - trái tim của hệ thống. Tại đây, engine sẽ đối sánh dữ liệu với hàng nghìn luật (signatures) đã được nạp vào bộ nhớ. Kiến trúc của Suricata hỗ trợ grouping (nhóm luật) theo giao thức và cổng, giúp giảm thiểu số lượng phép so sánh không cần thiết để tối ưu hiệu năng. Cuối cùng, kết quả phân tích được chuyển đến Mô-đun Đầu ra để ghi log, tạo cảnh báo (alert) hoặc thực hiện hành động rớt gói (drop) nếu đang chạy ở chế độ IPS.

Về cách thức tổ chức luồng, Suricata cung cấp các chế độ vận hành (Runmodes) linh hoạt, trong đó phổ biến nhất là chế độ Workers. Trong chế độ này, mỗi luồng (thread) sẽ đảm nhận trọn vẹn quy trình xử lý một gói tin từ đầu đến cuối (từ thu thập đến ghi log). Điều này tận dụng tối đa kiến trúc đa nhân của CPU hiện đại và hạn chế độ trễ do việc chuyển đổi ngữ cảnh (context switching) hoặc khóa dữ liệu (locking) giữa

các luồng, giúp Suricata đạt được hiệu suất vượt trội trong các môi trường mạng tốc độ cao.

2.1.3.Các chế độ hoạt động

Suricata được thiết kế với tính linh hoạt cao, cho phép triển khai ở nhiều vị trí khác nhau trong hạ tầng mạng tùy thuộc vào mục tiêu bảo mật. Về cơ bản, có hai phương thức tiếp nhận gói tin chính là Chế độ thụ động (Passive/IDS Mode) và Chế độ chủ động (Active/IPS Mode).

Trong Chế độ thụ động (IDS Mode), Suricata hoạt động như một hệ thống giám sát thuần túy. Nó tiếp nhận bản sao của lưu lượng mạng thông qua cổng Mirror (SPAN Port) trên Switch hoặc thiết bị TAP mạng chuyên dụng. Trên môi trường Linux, Suricata thường sử dụng thư viện AF_PACKET (hoặc Pcap cũ hơn) để thu thập gói tin từ giao diện mạng với hiệu năng cao. Ưu điểm của chế độ này là "vô hình" đối với kẻ tấn công và không gây ảnh hưởng đến hiệu suất đường truyền mạng (zero latency impact), tuy nhiên nó không thể chặn trực tiếp các gói tin độc hại mà chỉ có thể gửi cảnh báo.

Trong Chế độ chủ động (IPS Mode), Suricata được cấu hình để hoạt động trực tiếp trên đường truyền (Inline). Đối với hệ điều hành Linux, chế độ này thường được triển khai thông qua cơ chế NFQUEUE (Netfilter Queue) tích hợp với Iptables. Khi đó, Iptables sẽ giữ các gói tin lại và đẩy chúng vào hàng đợi (queue) để Suricata thẩm định; Suricata sau khi phân tích sẽ trả về phán quyết (verdict) là cho phép (NF_ACCEPT) hay hủy bỏ (NF_DROP). Ngoài ra, Suricata cũng hỗ trợ chế độ AF_PACKET IPS (còn gọi là Bridge mode), cho phép nó hoạt động như một cầu nối lớp 2 trong suốt, mang lại hiệu năng xử lý gói tin cao hơn so với NFQUEUE nhờ giảm bớt các thao tác sao chép dữ liệu giữa kernel và userspace.

Bên cạnh chế độ tiếp nhận gói tin, Suricata còn quản lý cách thức xử lý dữ liệu bên trong CPU thông qua các Runmodes. Quan trọng nhất là chế độ Workers. Trong mô hình Workers, mỗi luồng xử lý (thread) sẽ đảm nhiệm trọn vẹn vòng đời của một gói tin: từ lúc thu thập, giải mã, phát hiện đến khi xuất log. Điều này giúp tối ưu hóa bộ nhớ đệm CPU (CPU Cache) và loại bỏ các nút thắt cổ chai khi truyền dữ liệu giữa các

luồng, biến Suricata thành giải pháp lý tưởng cho các hệ thống phần cứng đa nhân hiện đại.

2.1.4.Cấu trúc luật

Luật (Rule) hay chữ ký (Signature) là thành phần cốt lõi quyết định khả năng phát hiện của Suricata. Một luật định nghĩa các điều kiện cụ thể mà nếu lưu lượng mạng thỏa mãn, hệ thống sẽ kích hoạt một hành động tương ứng. Cú pháp của luật Suricata tuân theo một định dạng chuẩn mực, được chia thành hai phần chính: Tiêu đề luật (Rule Header) và Tùy chọn luật (Rule Options). Cấu trúc tổng quát được thể hiện như sau:

{Action} {Protocol} {Source_IP} {Source_Port} {Direction} {Dest_IP} {Dest_Port} (Rule_Options)

Phần tiêu đề luật (Rule Header) bao gồm các thông tin định tuyến cơ bản để xác định luồng dữ liệu nào sẽ được kiểm tra. Nó bắt đầu bằng Action (Hành động), quy định Suricata sẽ làm gì khi khớp luật. Các hành động phổ biến bao gồm: alert (gửi cảnh báo), drop (chặn gói tin - chỉ hoạt động ở chế độ IPS), pass (bỏ qua, không kiểm tra tiếp) và reject (chặn và gửi phản hồi RST/ICMP Unreachable). Tiếp theo là Protocol (Giao thức), xác định loại giao thức cần kiểm tra (như tcp, udp, icmp hoặc các giao thức tầng ứng dụng như http, dns). Các trường còn lại xác định địa chỉ IP và Cổng của nguồn (Source) và đích (Dest), được ngăn cách bởi toán tử hướng (Direction), thường là -> (một chiều) hoặc <> (hai chiều). Suricata hỗ trợ sử dụng các biến định sẵn (như $HOME_NET, $EXTERNAL_NET) để đơn giản hóa việc quản lý địa chỉ IP.

Phần tùy chọn luật (Rule Options) là phần quan trọng nhất, được bao bọc trong dấu ngoặc đơn (...), chứa các từ khóa (keywords) quy định logic phát hiện chi tiết và các thông tin mô tả (metadata). Các tùy chọn này được chia cách nhau bằng dấu chấm phẩy ; và thường bao gồm các nhóm chính:

Nhóm Meta-settings: Cung cấp thông tin về luật, như msg (nội dung cảnh báo hiển thị), sid (Signature ID - mã định danh duy nhất của luật), rev (phiên bản luật) và classtype (phân loại mức độ nghiêm trọng).

Nhóm Payload keywords: Chứa các điều kiện để tìm kiếm nội dung trong gói tin. Quan trọng nhất là từ khóa content (tìm chuỗi ký tự hoặc mã Hex cụ thể), pcre (sử dụng biểu thức chính quy để tìm kiếm phức tạp), depth/offset (giới hạn vùng tìm kiếm).

Nhóm Flow keywords: Xác định trạng thái của kết nối, ví dụ flow: established, to_server (chỉ kiểm tra các kết nối đã thiết lập và hướng về phía máy chủ).

Ví dụ minh họa:

Một luật phát hiện hành vi truy cập trang quản trị web có thể được viết như sau:

alert http $EXTERNAL_NET any -> $HOME_NET 80 (msg:"ET EXPLOIT Access Admin Page"; flow:established,to_server; content:"/admin.php"; http_uri; sid:1000001; rev:1;)

Trong ví dụ này, Suricata sẽ gửi cảnh báo (alert) nếu phát hiện giao thức http từ mạng bên ngoài ($EXTERNAL_NET) gửi đến mạng nội bộ ($HOME_NET) cổng 80. Điều kiện khớp luật là trong đường dẫn URL (http_uri) có chứa chuỗi "/admin.php".

2.1.5. Bộ luật Emerging Threats (ET Open)

Trong hệ sinh thái các giải pháp phát hiện xâm nhập mã nguồn mở, bộ luật Emerging Threats Open (ET Open) được xem là tiêu chuẩn cơ sở và được sử dụng rộng rãi nhất hiện nay. Đây là tập hợp các luật (signatures) phát hiện xâm nhập được cung cấp miễn phí bởi Proofpoint, với sự đóng góp tích cực từ cộng đồng an ninh mạng toàn cầu. Đối với đề tài này, ET Open đóng vai trò là "nguồn trí tuệ" chính, cung cấp cơ sở dữ liệu mẫu nhận diện cho Suricata engine để phát hiện các mối đe dọa mạng.

Điểm mạnh cốt lõi của ET Open nằm ở tính cập nhật và độ bao phủ rộng. Khác với các bộ luật tĩnh, ET Open được cập nhật hàng ngày dựa trên dữ liệu thu thập từ các hệ thống giám sát (telemetry) và các nghiên cứu về mã độc mới nhất. Bộ luật này bao gồm hơn 30.000 chữ ký, bao quát đa dạng các loại hình tấn công từ các hành vi quét mạng cơ bản, các nỗ lực khai thác lỗ hổng ứng dụng (Exploit Kit), cho đến các hoạt động giao tiếp của mã độc với máy chủ điều khiển (C&C Server) và các dấu hiệu của

phần mềm tống tiền (Ransomware). Điều này đảm bảo hệ thống có khả năng nhận diện được các cuộc tấn công mới nổi ngay khi chúng vừa xuất hiện trên không gian mạng.

Về mặt kỹ thuật, ET Open cung cấp phiên bản được tối ưu hóa riêng cho Suricata. Trong khi các luật cũ của Snort thường chỉ dựa vào các tiêu chí đơn giản, phiên bản ET Open cho Suricata tận dụng triệt để các từ khóa nâng cao (keywords) mà chỉ engine này mới hỗ trợ, ví dụ như http.user_agent, tls.sni hay file_data. Việc này cho phép viết các luật có độ chính xác cao hơn, giảm thiểu tỷ lệ cảnh báo sai (False Positive) và cải thiện hiệu năng xử lý gói tin. Ví dụ, thay vì quét toàn bộ gói tin để tìm mã độc, luật Suricata có thể chỉ định chỉ quét trong phần thân (body) của phản hồi HTTP, giúp tiết kiệm tài nguyên CPU đáng kể.

Trong quá trình triển khai thực tế, bộ luật ET Open được quản lý và tự động hóa thông qua công cụ suricata-update. Các luật được phân chia thành các tệp danh mục cụ thể (như emerging-web_server.rules, emerging-sql.rules, emerging-dos.rules), cho phép quản trị viên linh hoạt bật/tắt từng nhóm luật tùy theo môi trường mạng thực tế mà không cần tải toàn bộ cơ sở dữ liệu khổng lồ. Sự kết hợp giữa khả năng xử lý đa luồng của Suricata và cơ sở dữ liệu phong phú của ET Open tạo nên một lớp phòng thủ vững chắc, đáp ứng tốt các yêu cầu về phát hiện xâm nhập trong phạm vi nghiên cứu của đề tài.

2.1.6. Phương pháp viết luật tùy chỉnh (Custom Rules)

Mặc dù các bộ luật có sẵn như ET Open cung cấp khả năng bảo vệ diện rộng, nhưng trong thực tế triển khai tại doanh nghiệp, việc viết các luật tùy chỉnh (Custom Rules) là yêu cầu bắt buộc để giải quyết các bài toán đặc thù. Đó có thể là nhu cầu giám sát các ứng dụng nội bộ, phát hiện các hành vi vi phạm chính sách công ty (như truy cập mạng xã hội trong giờ làm việc), hoặc quan trọng hơn là tạo ra các bản vá ảo (Virtual Patch) để ngăn chặn một cuộc tấn công Zero-day khi chưa có luật chính thức từ cộng đồng.

Quy trình xây dựng một luật tùy chỉnh hiệu quả thường tuân theo quy trình khép kín: Thu thập mẫu (Capture) – Phân tích (Analyze) – Viết luật (Create) – Kiểm thử (Test).

Đầu tiên, để viết luật cho một dạng tấn công cụ thể, cần phải có mẫu lưu lượng mạng (PCAP) của cuộc tấn công đó. Công cụ phân tích gói tin như Wireshark được sử dụng để "mổ xẻ" cấu trúc gói tin, từ đó tìm ra các đặc điểm nhận dạng duy nhất (invariant patterns) – là những chuỗi dữ liệu không thay đổi trong các lần tấn công khác nhau. Một chữ ký tốt (signature) phải đảm bảo tính đặc trưng cao để tránh khớp với lưu lượng sạch (False Positive), nhưng cũng đủ tổng quát để không bị kẻ tấn công qua mặt bằng những thay đổi nhỏ (Evasion).

Khi chuyển từ phân tích sang viết cú pháp Suricata, có ba nguyên tắc kỹ thuật quan trọng cần tuân thủ để đảm bảo hiệu năng:

Sử dụng Content Modifiers (Bộ định lượng nội dung): Thay vì yêu cầu Suricata tìm kiếm một chuỗi ký tự trong toàn bộ gói tin (rất tốn tài nguyên CPU), ta cần chỉ định vị trí cụ thể để tìm kiếm.

Ví dụ: Nếu muốn chặn một User-Agent độc hại, thay vì dùng content:"EvilAgent", ta nên dùng content:"EvilAgent"; http_user_agent;. Việc gắn từ khóa đệm (buffer keyword) như http_user_agent, http_uri, hay http_client_body giúp Suricata thu hẹp phạm vi tìm kiếm, tăng tốc độ xử lý đáng kể.

Sử dụng các từ khóa depth, offset hoặc distance để giới hạn vùng tìm kiếm chính xác đến từng byte.

Quản lý định danh (SID Management): Mỗi luật trong Suricata bắt buộc phải có một mã định danh duy nhất (Signature ID - SID). Theo quy ước quốc tế, các luật tùy chỉnh do người dùng tự viết nên sử dụng dải SID khởi đầu từ 1.000.000 trở đi. Điều này nhằm tránh xung đột với các luật có sẵn của hệ thống (thường có SID < 1 triệu) hoặc các bộ luật ET Open (thường có SID dải 20 triệu).

Ví dụ: sid:1000005; rev:1;

Tối ưu hóa đối sánh: Sử dụng từ khóa fast_pattern cho chuỗi ký tự dài nhất hoặc đặc trưng nhất trong luật. Điều này giúp bộ máy Multi-Pattern Matcher (MPM) của Suricata nhanh chóng loại bỏ các gói tin không khớp ngay từ bước đầu, trước khi thực hiện các kiểm tra phức tạp hơn.

Ví dụ thực tế: Giả sử cần viết một luật để phát hiện và cảnh báo khi có máy trạm nội bộ cố gắng truy cập vào một trang web quản trị giả mạo có đường dẫn chứa chuỗi "/admin_login.php" thông qua giao thức HTTP không an toàn. Luật tùy chỉnh sẽ được viết trong tệp local.rules như sau:

```
alert http $HOME_NET any -> $EXTERNAL_NET 80 (msg:"LOCAL SUSPICIOUS Access to Admin Login Page"; flow:established,to_server; content:"POST"; http_method; content:"/admin_login.php"; http_uri; fast_pattern; classtype:policy-violation; sid:1000001; rev:1;)
```

Sau khi viết xong, luật cần được kiểm thử bằng cách sử dụng công cụ phát lại gói tin (như tcpreplay) để đẩy file PCAP mẫu qua Suricata, nhằm xác minh xem cảnh báo có được kích hoạt đúng như mong đợi hay không trước khi áp dụng vào hệ thống thực tế (Production).

2.1.7. Cơ chế xuất log (EVE-JSON)

Trong kiến trúc của Suricata, EVE (Extensible Event Format) không chỉ đơn thuần là một tính năng xuất nhật ký mà được xem là cuộc cách mạng trong cách thức lưu trữ và chia sẻ dữ liệu an ninh mạng. Đây là định dạng đầu ra mặc định và hiện đại nhất của Suricata, thay thế hoàn toàn cho các định dạng nhị phân cũ (như Unified2 của Snort) vốn đòi hỏi các công cụ chuyên biệt để giải mã.

Về mặt kỹ thuật, EVE sử dụng chuẩn JSON (JavaScript Object Notation) để cấu trúc dữ liệu. Mỗi sự kiện xảy ra trên mạng – từ một cảnh báo tấn công (alert), một bản ghi truy vấn DNS, một giao dịch HTTP hay trạng thái bắt tay TLS – đều được Suricata đóng gói thành một đối tượng JSON (JSON object) độc lập và ghi vào một tệp duy nhất thường có tên là eve.json. Việc sử dụng JSON mang lại lợi thế to lớn về khả năng tương thích: nó là định dạng văn bản thuần túy (human-readable) giúp con người có thể đọc hiểu nhanh chóng khi cần debug, đồng thời là định dạng máy đọc (machine-readable) tiêu chuẩn mà hầu hết các ngôn ngữ lập trình và hệ thống cơ sở dữ liệu hiện đại đều hỗ trợ mặc định.

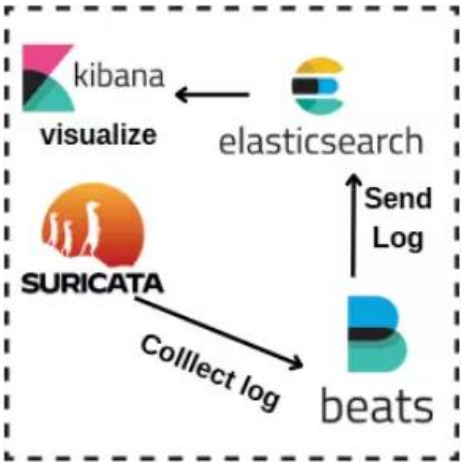
Điểm ưu việt nhất của EVE-JSON so với các cơ chế log truyền thống là khả năng cung cấp ngữ cảnh phong phú (Rich Context). Thay vì phân tán thông tin: file alert chỉ

chứa cảnh báo, file http.log chỉ chứa thông tin web riêng lẻ, EVE liên kết chúng lại với nhau. Khi một cảnh báo được kích hoạt, bản ghi JSON của nó không chỉ chứa thông tin cơ bản (IP nguồn/đích, tên luật) mà còn có thể đính kèm các metadata của giao thức liên quan (như URL đã truy cập, User-Agent, hoặc tên miền DNS). Điều này giúp các chuyên gia phân tích có cái nhìn toàn cảnh về sự cố mà không cần phải vất vả đối chiếu thủ công giữa nhiều tệp log khác nhau.

Trong khuôn khổ của đồ án này, EVE-JSON đóng vai trò là "mắt xích" quan trọng nhất để kết nối Suricata với hệ thống phân tích ELK Stack. Do dữ liệu đã được cấu trúc sẵn dưới dạng key-value, các công cụ thu thập log như Logstash hoặc Filebeat có thể "tiêu thụ" (ingest) dữ liệu từ eve.json và đẩy trực tiếp vào Elasticsearch mà không cần tốn tài nguyên để viết các biểu thức chính quy (Regex) phức tạp để tách dòng như khi xử lý Syslog. Điều này đảm bảo tính toàn vẹn của dữ liệu và tối ưu hóa hiệu năng cho luồng xử lý thời gian thực (Real-time processing).

2.2.Hệ thống phân tích log (ELK Stack)

Kiến trúc luồng dữ liệu log trong hệ thống được thiết kế theo mô hình pipeline, bắt đầu từ Suricata (EVE JSON) được Filebeat thu thập và đẩy về Elasticsearch để lập chỉ mục, cuối cùng hiển thị trên Kibana như minh họa tại Hình [X].



Hình 2.1: Quy trình hoạt động của ELK Stack kết hợp Suricata

2.2.1.Elasticsearch

Trong kiến trúc của bộ công cụ ELK Stack, Elasticsearch đóng vai trò trung tâm là "trái tim" lưu trữ và truy vấn dữ liệu. Đây là một công cụ tìm kiếm và phân tích phân

tán (distributed search and analytics engine) mã nguồn mở, được phát triển dựa trên nền tảng thư viện Apache Lucene mạnh mẽ. Khác với các cơ sở dữ liệu quan hệ (RDBMS) truyền thống như MySQL hay PostgreSQL lưu trữ dữ liệu dưới dạng bảng và hàng cố định, Elasticsearch là một cơ sở dữ liệu NoSQL hướng văn bản (document-oriented). Nó lưu trữ dữ liệu dưới dạng các tài liệu JSON (JSON Documents), điều này làm cho nó trở thành mảnh ghép hoàn hảo để xử lý định dạng log eve.json đầu ra của Suricata mà không cần quá trình chuyển đổi cấu trúc phức tạp.

Sức mạnh vượt trội của Elasticsearch nằm ở cơ chế Chỉ mục ngược (Inverted Index). Thay vì quét toàn bộ cơ sở dữ liệu để tìm một chuỗi ký tự (giống như lệnh LIKE trong SQL vốn rất chậm chạp), Elasticsearch liệt kê tất cả các từ khóa duy nhất xuất hiện trong các văn bản và ánh xạ chúng đến vị trí lưu trữ tương ứng. Cơ chế này hoạt động tương tự như phần mục lục tra cứu ở cuối một cuốn sách, cho phép hệ thống thực hiện các truy vấn tìm kiếm toàn văn (full-text search) trên hàng triệu bản ghi log với tốc độ phản hồi gần như thời gian thực (Near Real-Time - NRT). Đây là yếu tố sống còn đối với một hệ thống giám sát an ninh, nơi độ trễ trong việc truy xuất dữ liệu tấn công phải được tính bằng mili-giây.

Trong phạm vi thực nghiệm của đồ án, Elasticsearch sẽ tiếp nhận dữ liệu đã được chuẩn hóa từ Filebeat. Nó cung cấp các giao tiếp thông qua chuẩn RESTful API, cho phép công cụ trực quan hóa Kibana.

2.2.2.Filebeat

Trong kiến trúc ELK truyền thống, Logstash thường tiêu tốn nhiều tài nguyên hệ thống (do chạy trên Java), gây ảnh hưởng đến hiệu năng xử lý của Suricata Engine. Do đó, em lựa chọn Filebeat – một bộ vận chuyển log hạng nhẹ viết bằng ngôn ngữ Go – làm giải pháp thay thế để tối ưu hóa tài nguyên phần cứng cho lớp thu thập dữ liệu đầu cuối.

Nhiệm vụ cốt lõi của Filebeat là theo dõi tệp eve.json theo thời gian thực và đẩy dữ liệu về Elasticsearch. Ưu điểm kỹ thuật lớn nhất được áp dụng trong đề tài là tính năng Suricata Module tích hợp sẵn. Module này chứa các kịch bản phân tích (ingest

pipelines) giúp tự động nhận diện cấu trúc log, chuẩn hóa và làm giàu dữ liệu (như dịch mã phản hồi HTTP) mà không cần cấu hình bộ lọc thủ công phức tạp như Logstash.

Bên cạnh đó, Filebeat đảm bảo tính toàn vẹn dữ liệu (Data Integrity) thông qua cơ chế Backpressure. Khi hệ thống đích bị quá tải, Filebeat tự động giảm tốc độ đọc và ghi nhớ vị trí dòng cuối cùng đã gửi qua tệp registry. Cơ chế này đảm bảo quá trình truyền tải được tiếp tục chính xác ngay khi kết nối ổn định trở lại, ngăn chặn tuyệt đối tình trạng thất lạc các cảnh báo an ninh quan trọng.

2.2.3.Kibana

Trong hệ thống này, Kibana đóng vai trò là giao diện quản trị trung tâm, cho phép tương tác trực quan với dữ liệu log EVE-JSON của Suricata được lưu trữ trong Elasticsearch. Mục tiêu chính của việc sử dụng Kibana là xây dựng các Security Dashboards để giám sát các hành vi xâm nhập và cảnh báo từ Suricata theo thời gian thực.

Thay vì phải xử lý thủ công hàng nghìn dòng log thô, Kibana chuyển đổi chúng thành các thông tin tình báo dạng hình ảnh, như: biểu đồ phân phối các loại tấn công (dựa trên alert.signature), thống kê các địa chỉ IP nguồn/đích có hành vi đáng ngờ và bản đồ địa lý (GeoIP) của kẻ tấn công. Đồng thời, công cụ này hỗ trợ ngôn ngữ truy vấn KQL để thực hiện kỹ thuật "Drill-down" (truy vết sâu), giúp quản trị viên nhanh chóng lọc ra các sự kiện liên quan đến một cảnh báo cụ thể để điều tra và ra quyết định phản hồi chính xác.

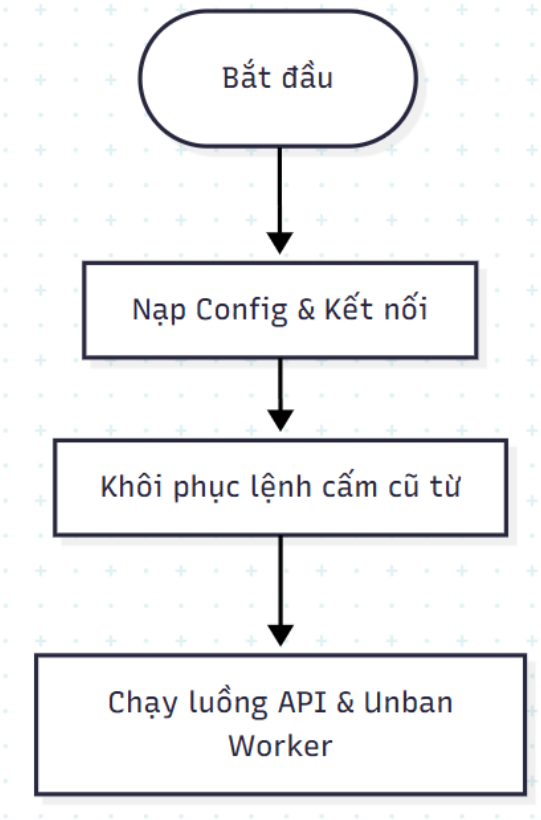
2.3. Mô-đun phản hồi tự động

2.3.1. Luồng thực thi tổng thể của thuật toán

Để đảm bảo khả năng xử lý thời gian thực và tính toàn vẹn của dữ liệu, mô-đun Mini-SOAR được thiết kế hoạt động theo mô hình đa luồng (multi-threading) với cơ chế hướng sự kiện (event-driven). Toàn bộ chu trình vòng đời của một sự kiện an ninh được chia thành ba giai đoạn xử lý chính: Khởi tạo, Vòng lặp xử lý sự kiện và Quy trình hậu kiểm.

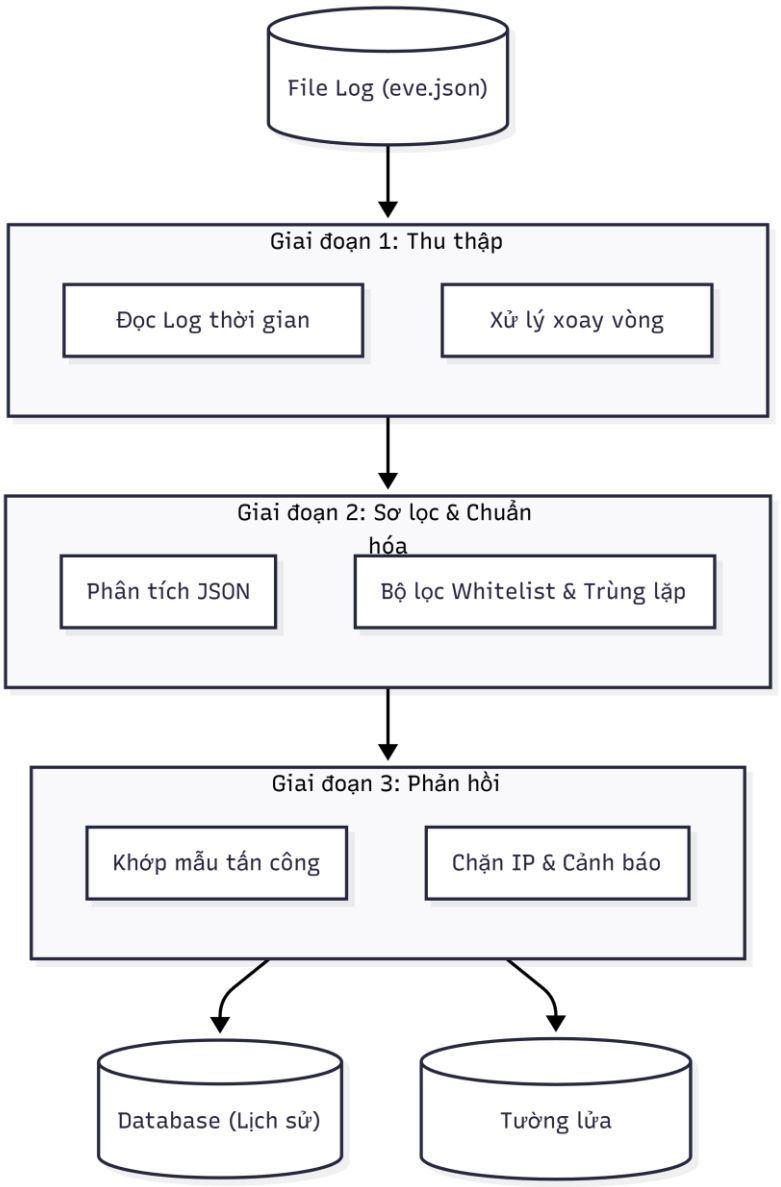
Giai đoạn Khởi tạo (Initialization Phase) Ngay khi dịch vụ được kích hoạt, hệ thống thực hiện các tác vụ chuẩn bị môi trường trước khi bắt đầu lắng nghe sự kiện:

- Nạp cấu hình: Đọc các tham số từ tệp config.yaml bao gồm đường dẫn log, thông tin kết nối cơ sở dữ liệu và danh sách whitelist.
- Kiểm tra môi trường: Xác thực quyền truy cập vào trình điều khiển tường lửa (ưu tiên NFTables, dự phòng IPtables) và khởi tạo cấu trúc bảng trong SQLite.
- Khôi phục trạng thái (State Restoration): Đây là bước quan trọng đảm bảo tính bền vững (Persistence). Hệ thống truy vấn cơ sở dữ liệu để tìm các lệnh cấm (Ban) chưa hết hạn và tái lập chúng trên tường lửa . Điều này ngăn chặn kẻ tấn công lợi dụng việc khởi động lại máy chủ để thoát khỏi "danh sách đen".
- Khởi chạy luồng phụ: Hệ thống tách luồng xử lý chính và khởi tạo thêm các luồng chạy nền (Background Workers) cho API quản trị và tác vụ dọn dẹp tự động.



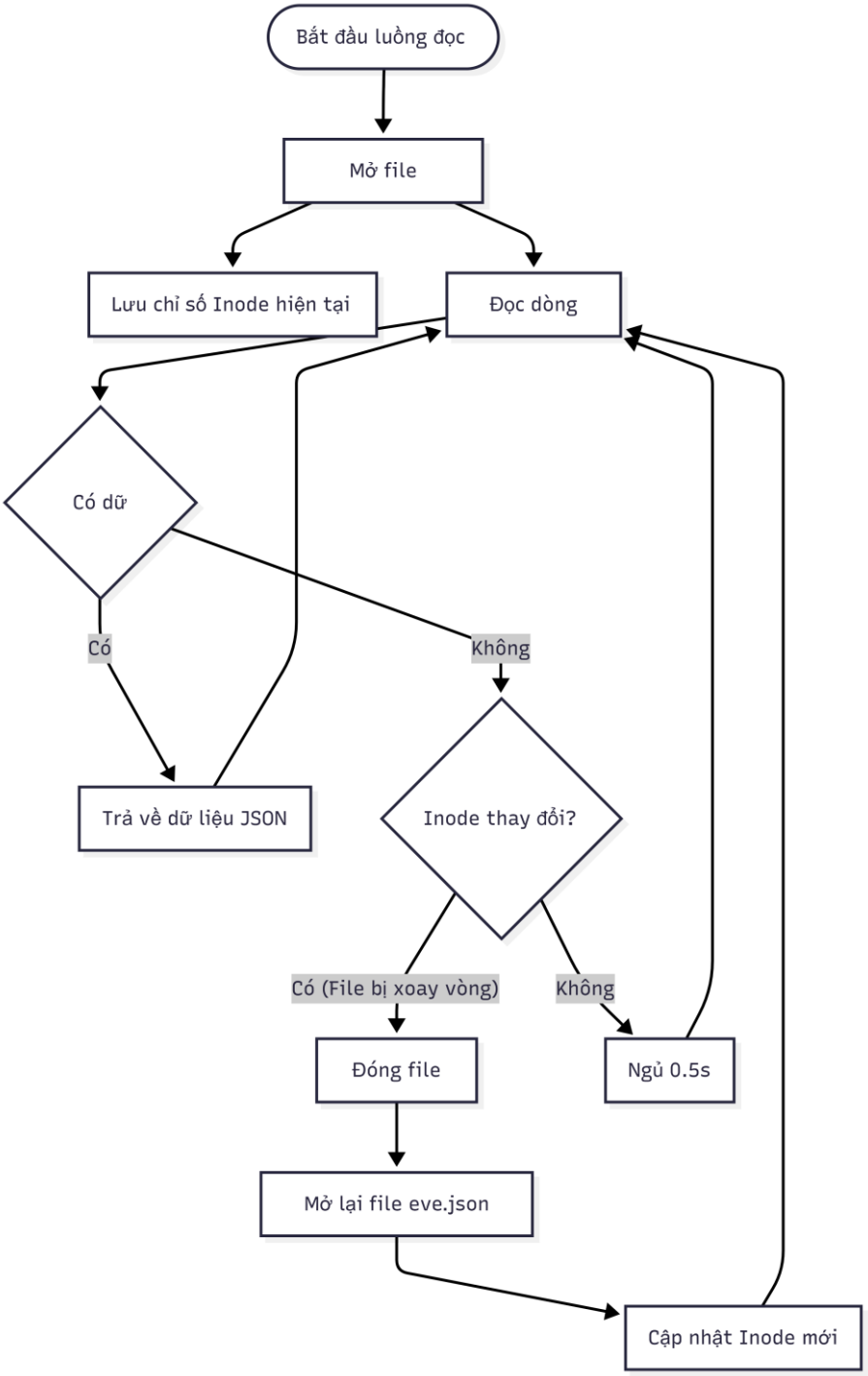
Hình 2.2: Lưu đồ khởi động code phản hồi tự động mini-SOAR.py

Vòng lặp xử lý sự kiện (Main Event Loop) Đây là luồng xử lý chính (Main Thread), chịu trách nhiệm giám sát và phản ứng với các cuộc tấn công theo thời gian thực:



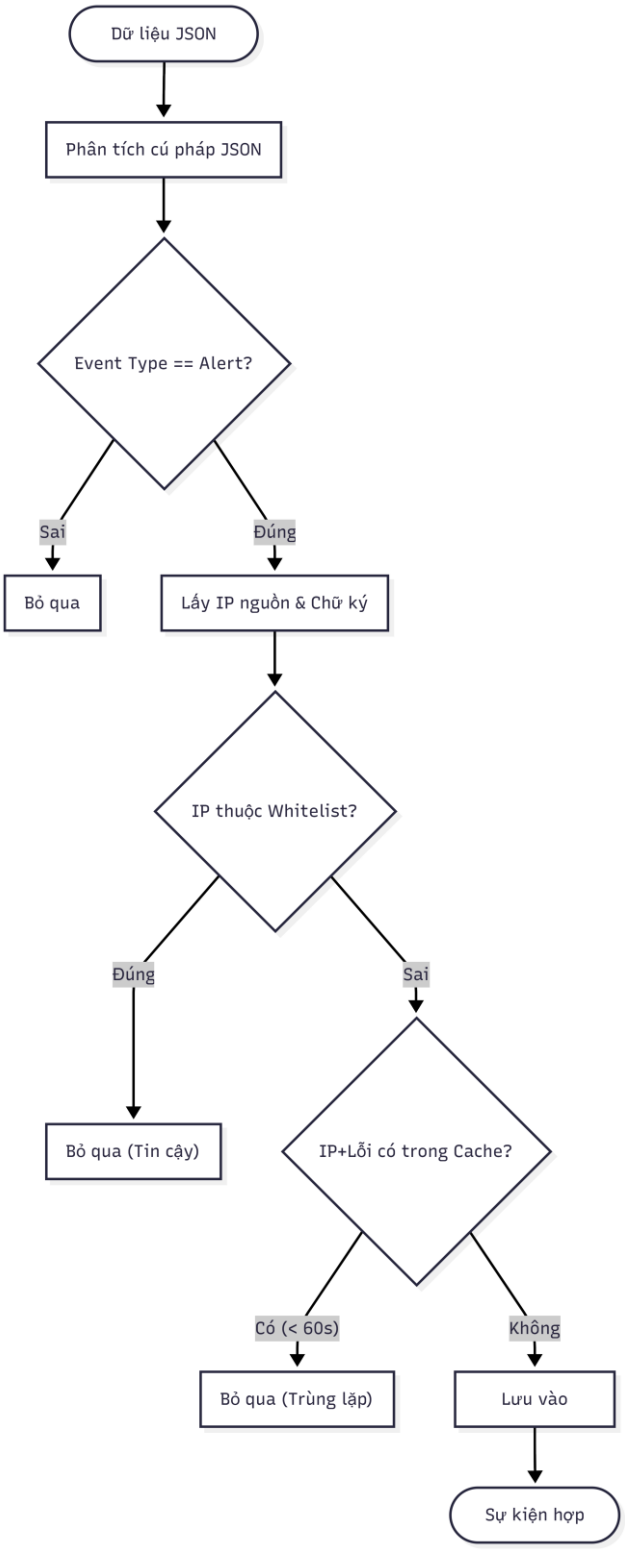
Hình 2.3: Lưu đồ hoạt động tổng thể của mini-SOAR.py

- Thu thập (Ingestion): Sử dụng cơ chế Log Tailing để đọc liên tục dữ liệu mới được ghi vào cuối tệp eve.json . Hệ thống tích hợp thuật toán giám sát inode để tự động xử lý trường hợp tệp log bị xoay vòng (log rotation) mà không làm gián đoạn luồng dữ liệu .



Hình 2.4: Lưu đồ thuật toán đọc log và xử lý xoay vòng

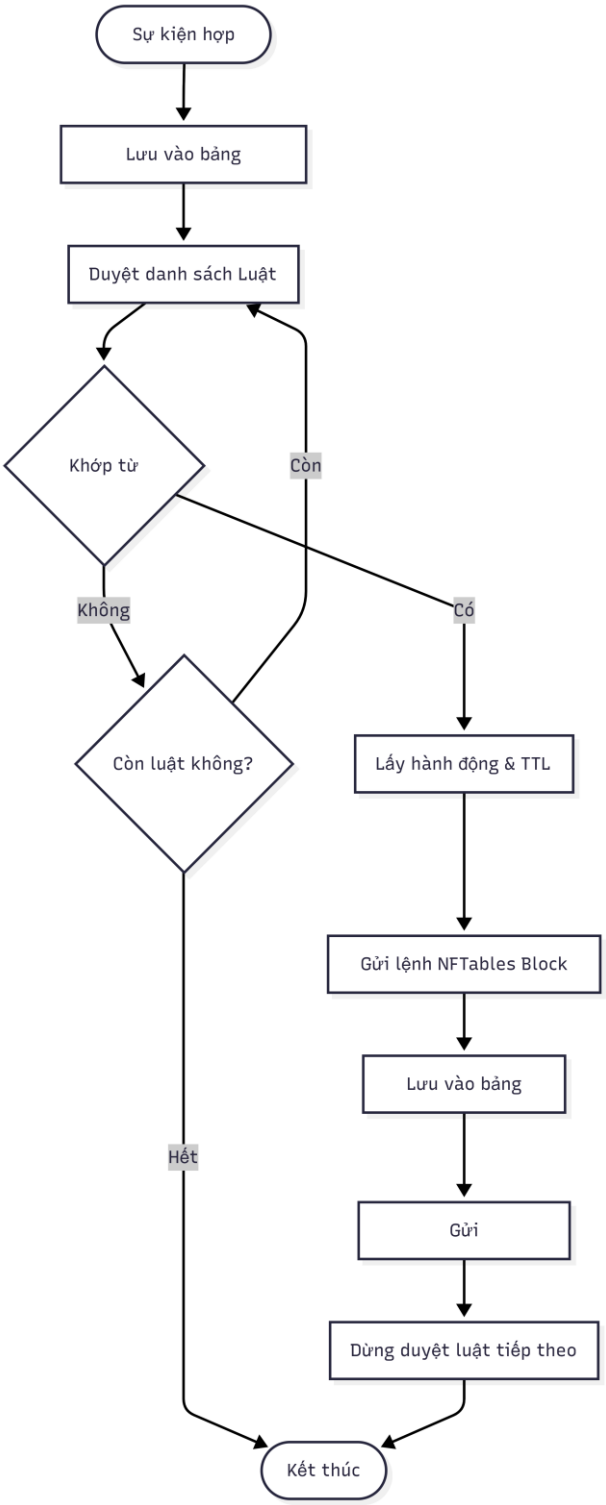
- Sơ lọc: Chuỗi JSON thô được phân tích cú pháp (Parsing) và đưa qua bộ lọc:
  - Loại bỏ các sự kiện không phải cảnh báo (event_type != alert).
  - Đối chiếu địa chỉ IP nguồn với danh sách tin cậy (Whitelist) .
  - Kiểm tra bộ nhớ đệm để loại bỏ các cảnh báo trùng lặp trong khoảng thời gian ngắn (mặc định 60 giây), giúp giảm tải tài nguyên xử lý .



Hình 2.5: Lưu đồ quy trình lọc sự kiện và khử trùng lặp

- Ra quyết định: Nếu sự kiện vượt qua bộ lọc, nó được lưu vào bảng incidents để làm bằng chứng. Hệ thống đối sánh chữ ký cảnh báo (alert signature) với tập luật phản hồi đã định nghĩa.

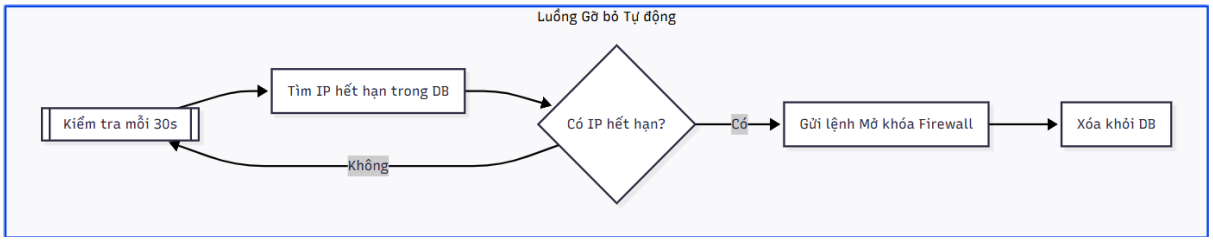
- Thực thi: Khi tìm thấy luật khớp (ví dụ: phát hiện SQL Injection), hệ thống gọi trình điều khiển tường lửa để chặn IP nguồn, ghi nhận hành động vào bảng bans và kích hoạt mô-đun thông báo (Notifier) để gửi cảnh báo tức thời qua Telegram/Email .



Hình 2.6: Lưu đồ logic ra quyết định phản hồi

Quy trình hậu kiểm và dọn dẹp (Maintenance Worker) Để tối ưu hóa tài nguyên mạng và tránh việc chặn vĩnh viễn không cần thiết, một luồng riêng biệt (Unban Worker) hoạt động song song với chu kỳ định kỳ (mặc định 30 giây) :

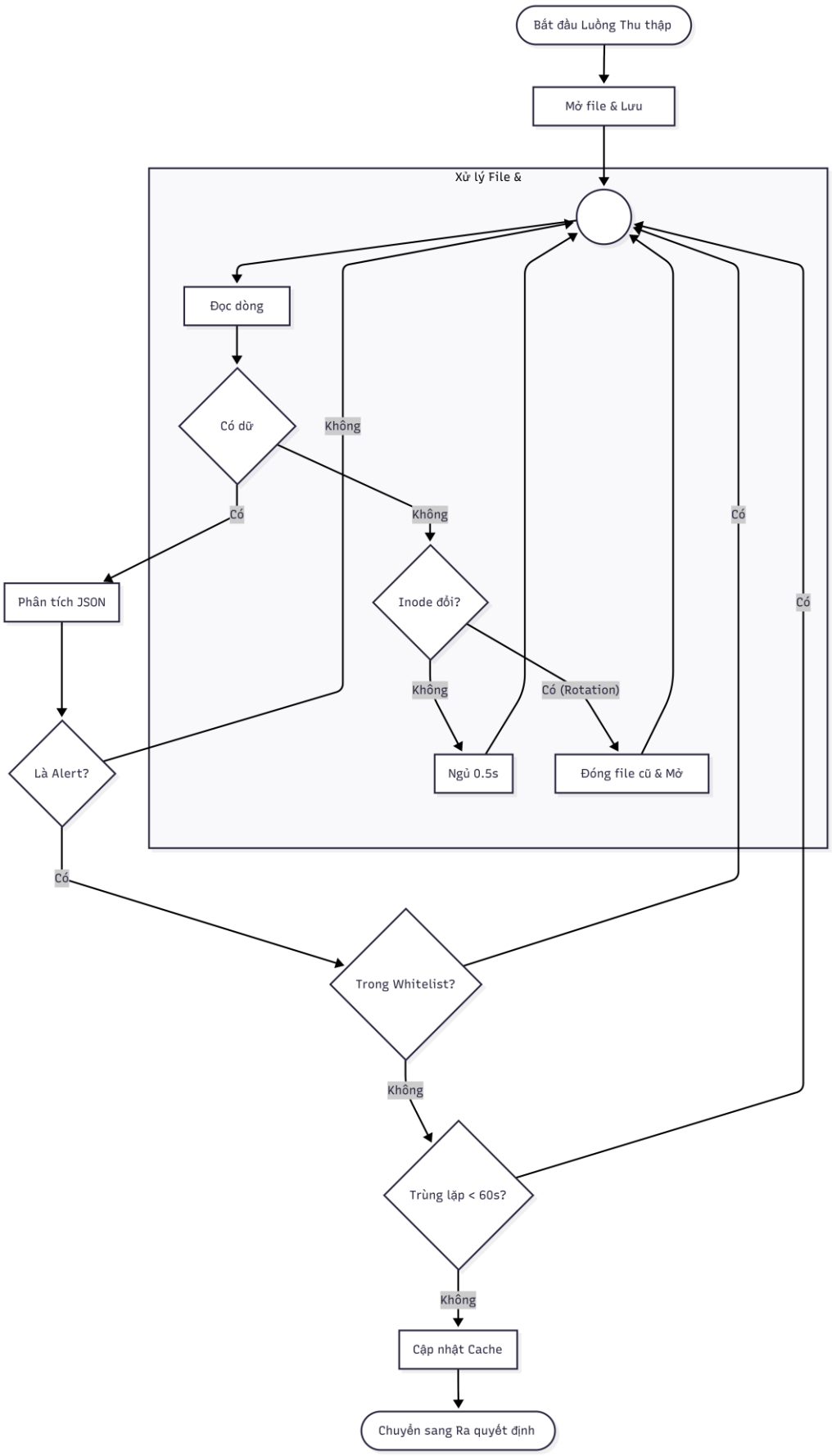
- Hệ thống quét bảng bans trong cơ sở dữ liệu để tìm các địa chỉ IP đã hết thời gian phạt (expires_at <= current_time).
- Thực hiện lệnh mở khóa (Unban) trên tường lửa và xóa bản ghi khỏi danh sách theo dõi.
- Quy trình này diễn ra bất đồng bộ, đảm bảo không làm tắc nghẽn luồng xử lý sự kiện chính.



Hình 2.7: Lưu đồ luồng tự động gỡ bỏ lệnh cấm

2.3.2. Cơ chế thu thập và xử lý sự kiện

Để đảm bảo tính thời gian thực (Real-time) trong việc phản hồi tấn công, mô-đun không thực hiện truy vấn định kỳ vào cơ sở dữ liệu mà áp dụng cơ chế xử lý theo sự kiện (Event-driven) trực tiếp từ luồng dữ liệu của Suricata. Quy trình đọc và xử lý log được khái quát hóa qua lưu đồ thuật toán tại hình 2.8 dưới đây.



Hình 2.8: Lưu đồ thu thập và lọc sự kiện

Dựa trên hình minh họa, quy trình xử lý bao gồm ba cơ chế kỹ thuật trọng tâm:

Cơ chế đọc log thời gian thực và xử lý xoay vòng (Log Tailing & Rotation) Hệ thống thực hiện giám sát liên tục tệp eve.json theo cơ chế tương tự lệnh tail -f trong Linux. Điểm đặc biệt trong thiết kế này là khả năng xử lý tự động quá trình luân chuyển nhật ký (Log Rotation) của Suricata. Mã nguồn theo dõi chỉ số inode (index node) của tệp tin; nếu phát hiện inode thay đổi (tức là file hiện tại đã bị đổi tên và file mới được tạo ra), hệ thống sẽ tự động đóng file cũ và mở lại file mới ngay lập tức. Điều này đảm bảo tính toàn vẹn dữ liệu, không bỏ sót bất kỳ cảnh báo nào trong thời điểm hệ thống thực hiện bảo trì log.

Chuẩn hóa và Phân tích cú pháp (Parsing) Dữ liệu đầu vào là các chuỗi văn bản định dạng JSON. Tại bước này, hệ thống thực hiện giải mã (Deserialization) để chuyển đổi chuỗi văn bản thành đối tượng từ điển (Dictionary) trong Python, cho phép truy xuất nhanh các trường thông tin quan trọng như địa chỉ IP nguồn (src_ip), loại sự kiện (event_type), và định danh chữ ký (alert.signature).

Bộ lọc đa tầng và Khử trùng lặp (Filtering & Deduplication) Trước khi sự kiện được chuyển đến bộ máy ra quyết định, nó phải đi qua một lớp "màng lọc" để loại bỏ nhiễu (Noise reduction), giúp tối ưu hóa tài nguyên xử lý:

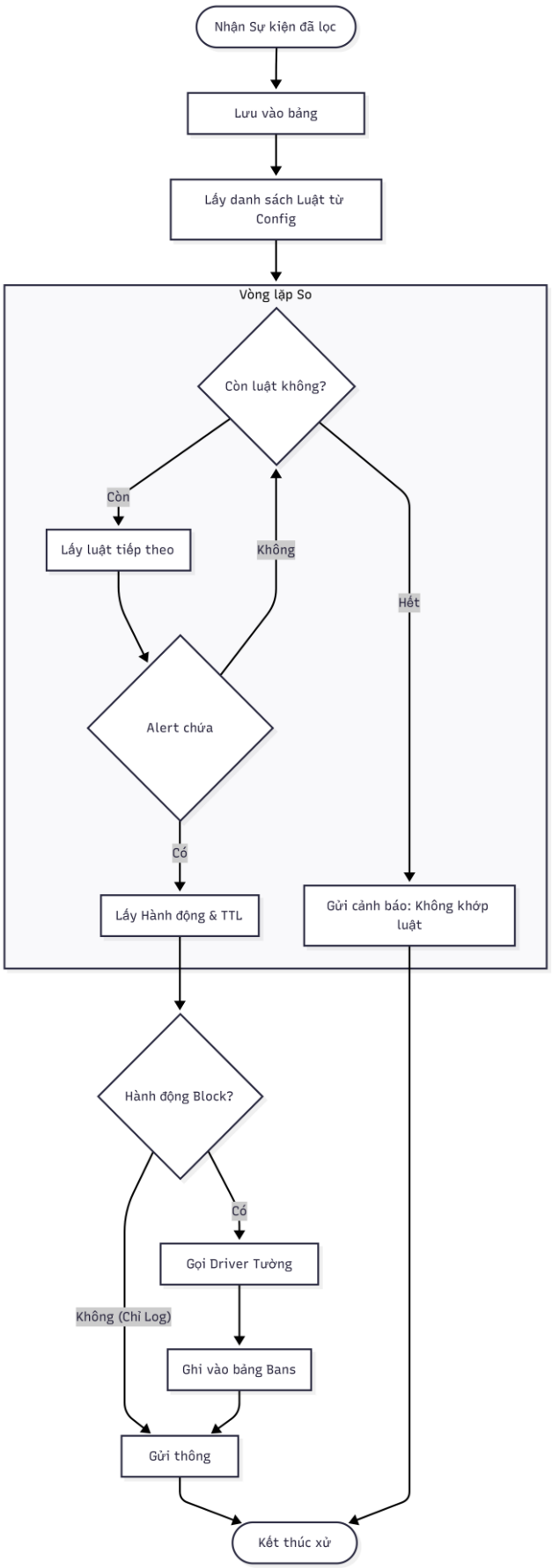
- Bộ lọc loại sự kiện: Hệ thống chỉ chấp nhận các sự kiện có trường event_type là alert, loại bỏ hoàn toàn các bản ghi thống kê giao thức (DNS, HTTP, TLS logs) không mang tính chất cảnh báo.
- Danh sách tin cậy (Whitelist Check): Địa chỉ IP nguồn được đối chiếu với danh sách Whitelist cấu hình trong config.yaml (hỗ trợ cả IP đơn lẻ và dải mạng CIDR). Mọi cảnh báo xuất phát từ IP tin cậy sẽ bị hủy bỏ để tránh chặn nhầm quản trị viên hoặc các hệ thống nội bộ.
- Khử trùng lặp (Deduplication): Đây là tính năng quan trọng để ngăn chặn tình trạng "ngập lụt cảnh báo" (Alert Fatigue). Khi một cuộc tấn công mạng sinh ra hàng ngàn gói tin giống nhau trong vài giây, hệ thống duy trì một bộ nhớ đệm tạm thời (Cache). Nếu một cảnh báo trùng lặp (cùng IP nguồn và dấu hiệu tấn

công) xuất hiện trong khoảng thời gian "nguội" (Cooldown) mặc định là 60 giây, nó sẽ bị bỏ qua.

2.3.3. Cơ chế ra quyết định và luật phản hồi

Sau khi sự kiện đã vượt qua các bước lọc sơ cấp và khử trùng lặp, nó được chuyển đến bộ máy ra quyết định (Decision Engine). Tại đây, hệ thống không áp dụng một hành động rập khuôn cho mọi cảnh báo, mà sử dụng thuật toán so khớp để phân loại mức độ nghiêm trọng và đưa ra phương án xử lý tương thích.

Quy trình logic từ lúc nhận diện mẫu tấn công đến khi kích hoạt hành động ngăn chặn được mô tả chi tiết trong hình 2.9 dưới đây.



Hình 2.9: Lưu đồ quy trình ra quyết định và ánh xạ luật phản hồi

Dựa trên thiết kế, cơ chế này hoạt động dựa trên hai nguyên tắc cốt lõi:

Nguyên tắc ánh xạ luật dựa trên từ khóa (Keyword-based Mapping) Trong thực tế, Suricata có hàng chục nghìn chữ ký (signatures) khác nhau và liên tục được cập nhật. Việc viết kịch bản xử lý riêng biệt cho từng chữ ký là bất khả thi và khó bảo trì. Do đó, mô-đun Mini-SOAR áp dụng phương pháp "Gom nhóm hành vi" thông qua từ khóa .

Hệ thống sẽ duyệt qua danh sách các luật phản hồi được định nghĩa trước trong tệp cấu hình. Mỗi luật bao gồm một tập hợp các từ khóa đặc trưng. Thuật toán tìm kiếm chuỗi con được sử dụng để kiểm tra xem thông điệp cảnh báo (alert.signature) có chứa từ khóa hay không.

- *Ví dụ:* Nếu cảnh báo chứa chuỗi "SQL Injection" hoặc "UNION SELECT", hệ thống tự động xếp loại đây là nhóm tấn công Ứng dụng Web. Nếu chứa "NMAP" hoặc "SCAN", nó được xếp vào nhóm Dò quét mạng.

Cách tiếp cận này giúp hệ thống linh hoạt, có thể bắt được cả những biến thể tấn công mới (Zero-day) miễn là chúng chứa các từ khóa cốt lõi của loại hình tấn công đó mà không cần cập nhật lại mã nguồn.

Cơ chế phản hồi tương xứng (Proportional Response) Một điểm sáng trong thiết kế của mô-đun là khả năng áp dụng thời gian ngăn chặn (Time-to-Live - TTL) khác nhau tùy theo mức độ nguy hiểm của hành vi. Thay vì chặn vĩnh viễn (dễ gây ra dương tính giả) hoặc chặn cứng một khoảng thời gian cố định, hệ thống áp dụng mức phạt tương ứng:

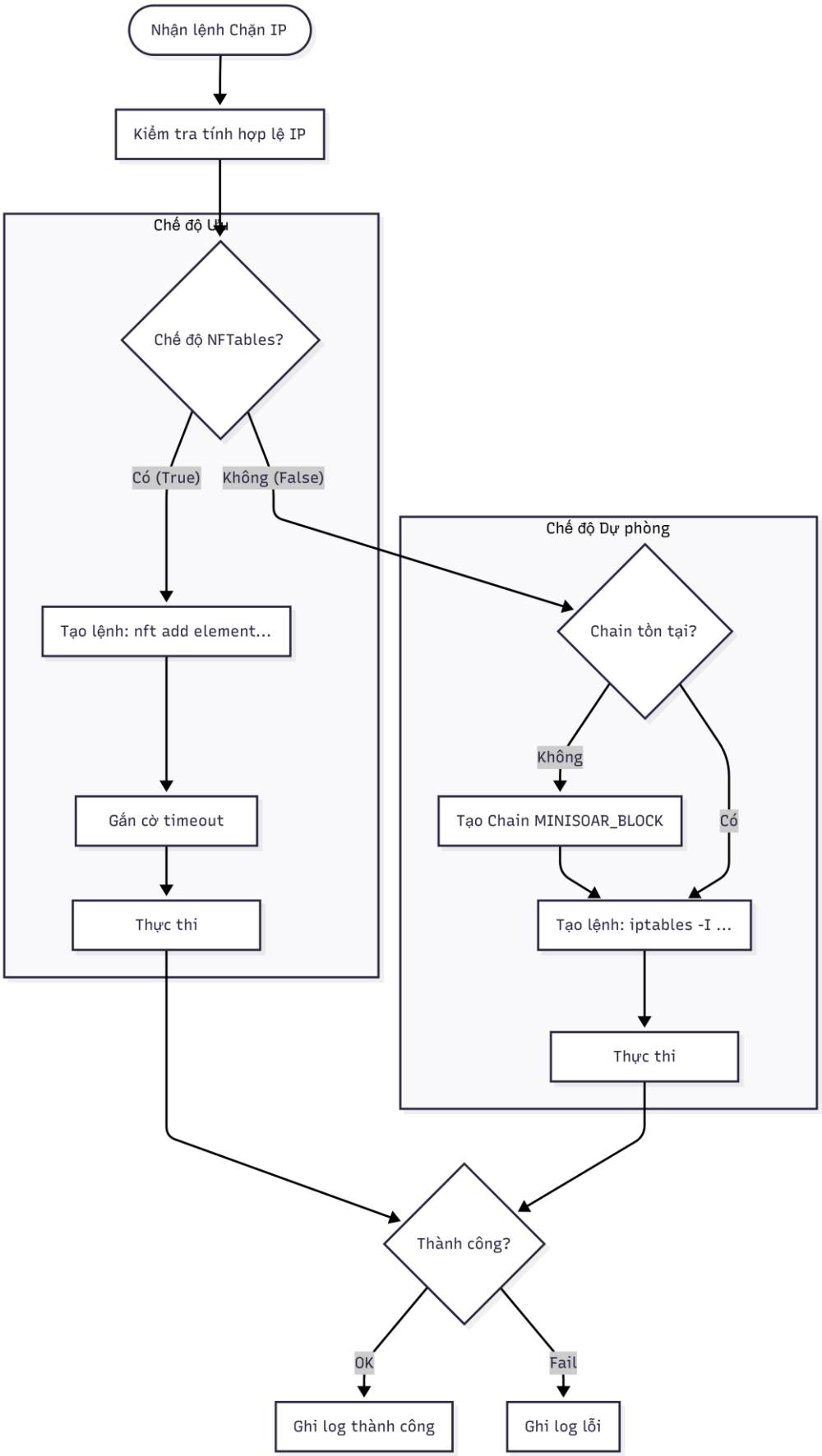
- Mức độ Thấp (Dò quét/Thám thính): Áp dụng thời gian chặn ngắn (ví dụ: 600 giây). Mục tiêu là làm gián đoạn quá trình thu thập thông tin và làm nản lòng kẻ tấn công mà không gây ảnh hưởng lâu dài nếu lỡ chặn nhầm người dùng hợp lệ.
- Mức độ Trung bình (Khai thác Web - SQLi/XSS): Áp dụng thời gian chặn trung bình (ví dụ: 3600 - 7200 giây) để bảo vệ ứng dụng ngay lập tức trước các đợt tấn công dồn dập.
- Mức độ Cao (Mã độc/C2): Đối với các dấu hiệu nhiễm mã độc hoặc kết nối đến máy chủ điều khiển (C&C), hệ thống áp dụng thời gian chặn rất dài (86400 giây

hoặc hơn) và có thể kích hoạt thêm cơ chế cách ly (Quarantine) để ngăn chặn sự lây lan trong mạng nội bộ.

2.3.4. Tương tác với tường lửa

Mô-đun phản hồi không trực tiếp xử lý gói tin mà hoạt động như một lớp điều khiển (Control Plane), gửi các chỉ thị xuống tầng mạng của hệ điều hành Linux để thực thi việc ngăn chặn. Để đảm bảo tính tương thích trên nhiều bản phân phối Linux khác nhau, hệ thống được thiết kế theo kiến trúc trừu tượng hóa (Abstraction Layer) thông qua lớp FirewallDriver.

Cơ chế lựa chọn thông minh giữa các nền tảng tường lửa được mô tả trong hình 2.10 dưới đây.



Hình 2.10: Lưu đồ logic tương tác và lựa chọn nền tảng tường lửa

Dựa trên thiết kế này, hệ thống hỗ trợ hai cơ chế hoạt động song song:

Cơ chế ưu tiên: NFTables với hiệu năng cao

Hệ thống ưu tiên sử dụng NFTables làm backend chính nhờ kiến trúc máy ảo (Virtual Machine) giúp biên dịch luật thành bytecode, mang lại hiệu năng xử lý vượt trội 1.

- Cấu trúc tập hợp định danh (Named Sets): Thay vì thêm hàng nghìn luật DROP rời rạc (gây phân mảnh bộ nhớ và làm chậm hệ thống), Mini-SOAR sử dụng cấu trúc Set để lưu trữ danh sách IP đen.
- Tối ưu hóa thuật toán: Việc sử dụng Set giúp giảm độ phức tạp thuật toán khi tra cứu từ $O(n)$ (duyệt tuần tự) xuống còn $O(1)$ (tra cứu bảng băm). Điều này đảm bảo thông lượng mạng (Throughput) không bị suy giảm ngay cả khi danh sách chặn chứa hàng chục nghìn địa chỉ IP.
- Thao tác nguyên tử (Atomic Operations): Các lệnh thêm/xóa IP được thực hiện tức thời mà không cần nạp lại toàn bộ bộ luật.

Cơ chế dự phòng: IPtables (Legacy Support)

Để đảm bảo tính khả thi trên các hệ thống cũ chưa hỗ trợ NFTables, mô-đun tích hợp cơ chế dự phòng về IPtables.

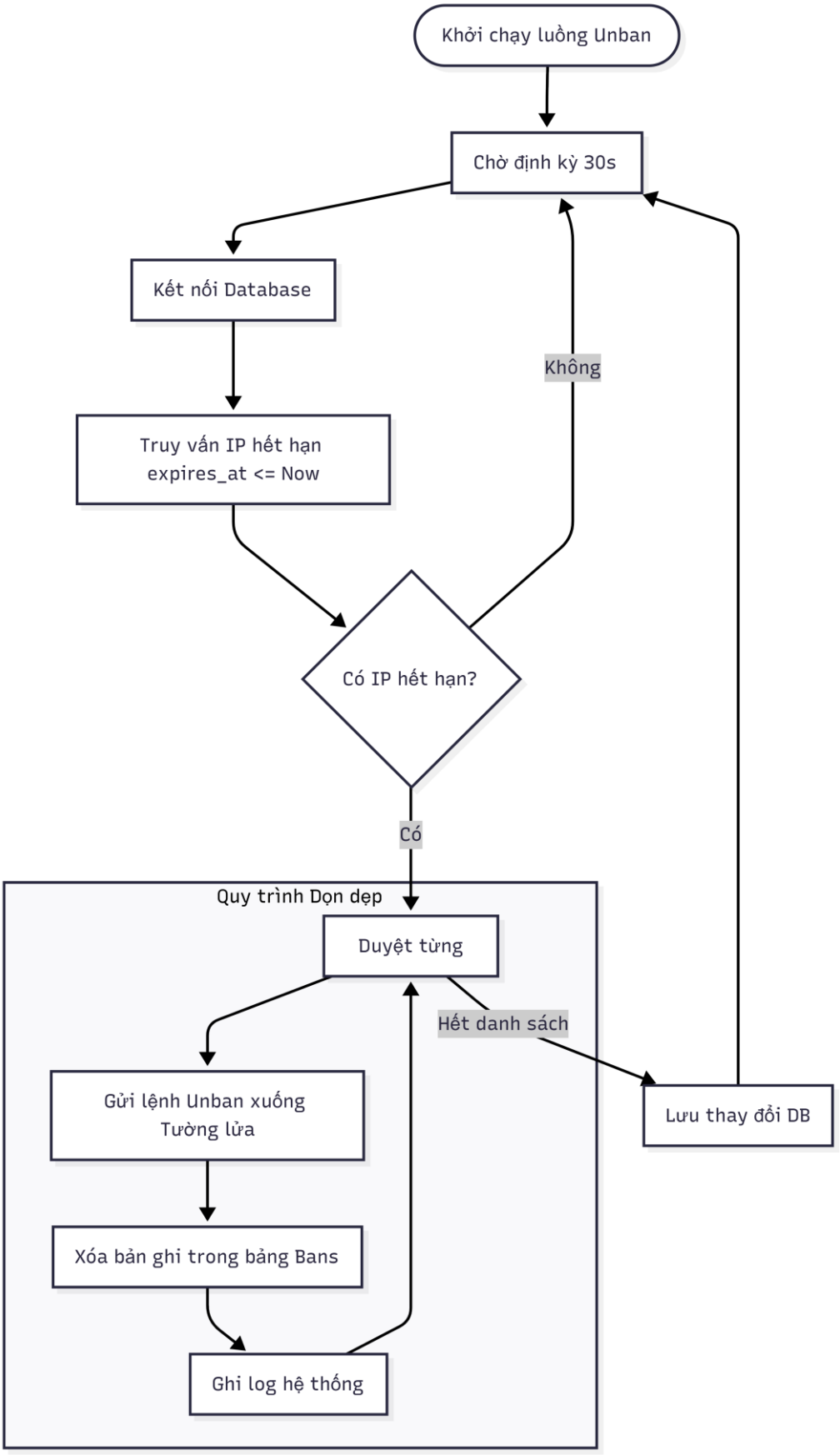
- Chuỗi quản lý riêng (Custom Chain): Hệ thống không can thiệp trực tiếp vào chuỗi INPUT mặc định mà tạo ra một chuỗi con tên là MINISOAR_BLOCK. Tất cả lưu lượng đi vào sẽ được chuyển hướng sang chuỗi này để kiểm tra.
- Quản lý biệt lập: Cách tổ chức này giúp tách biệt các luật do hệ thống tự động sinh ra khỏi các luật quản trị thủ công, đồng thời cho phép gỡ bỏ toàn bộ cơ chế chặn một cách nhanh chóng (Flush chain) khi cần thiết mà không làm gián đoạn kết nối mạng chính.

2.3.5. Quản lý trạng thái và vòng đời lệnh cấm

Một trong những thách thức lớn nhất của các hệ thống phản hồi tự động là quản lý vòng đời của các lệnh cấm. Việc chặn vĩnh viễn (Permanent Ban) một địa chỉ IP

thường không khả thi trong thực tế do tính chất động của không gian địa chỉ IPv4 (DHCP, NAT). Do đó, hệ thống được thiết kế để quản lý trạng thái theo mô hình Time-to-Live (TTL), đảm bảo tính tạm thời và khả năng tự phục hồi.

Quy trình đồng bộ trạng thái giữa cơ sở dữ liệu và tường lửa được mô tả chi tiết trong hình 2.11 dưới đây.



Hình 2.11: Lưu đồ cơ chế quản lý trạng thái và luồng gỡ bỏ tự động

Dựa trên hình minh họa, cơ chế quản lý bao gồm ba thành phần chiến lược:

Lớp lưu trữ trạng thái bền vững: Để đảm bảo trạng thái an ninh không bị mất đi khi ứng dụng khởi động lại hoặc máy chủ gặp sự cố mất điện, mô-đun sử dụng SQLite làm cơ sở dữ liệu lưu trữ bền vững. Mọi quyết định chặn IP không chỉ được gửi xuống tường lửa (vốn chỉ tồn tại trong bộ nhớ RAM của Kernel) mà còn được ghi đồng thời vào bảng bans. Cấu trúc bản ghi bao gồm khóa chính là địa chỉ IP, thời điểm bắt đầu chặn và thời điểm hết hạn dự kiến (expires_at).

Cơ chế khôi phục trạng thái: Tính năng quan trọng thể hiện sự ổn định của hệ thống là khả năng Khôi phục sau sự cố. Ngay khi mô-đun khởi động, hệ thống truy vấn toàn bộ danh sách IP trong cơ sở dữ liệu có thời gian hết hạn lớn hơn thời điểm hiện tại. Đối với mỗi IP, hệ thống tính toán thời gian còn lại và tái lập luật chặn trên tường lửa. Cơ chế này đảm bảo kẻ tấn công không thể thoát khỏi lệnh cấm bằng cách thực hiện tấn công từ chối dịch vụ (DoS) khiến server khởi động lại.

Tiến trình dọn dẹp tự động: Để giải phóng tài nguyên và tránh chặn nhầm kéo dài, hệ thống duy trì một tiến trình chạy nền (Daemon Thread) chuyên biệt. Tiến trình này hoạt động độc lập với luồng xử lý log chính, thực hiện chu kỳ thăm dò định kỳ (mặc định 30 giây):

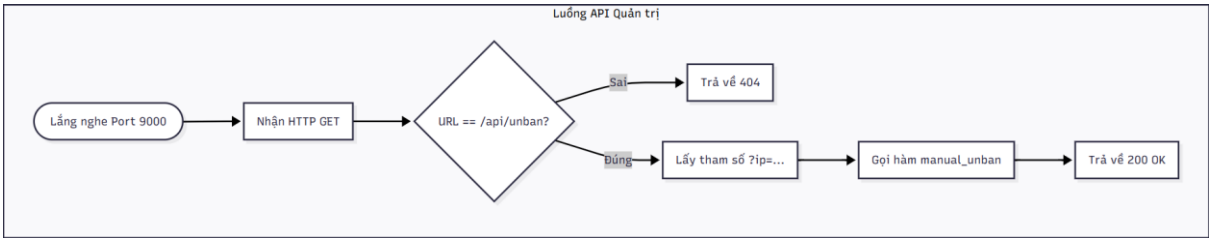
- Truy vấn tìm các IP đã hết hạn (expires_at <= now).
- Gửi lệnh mở khóa truy cập mạng cho IP đó trên tường lửa.
- Xóa bản ghi khỏi cơ sở dữ liệu để dọn dẹp.

Việc tách rời luồng dọn dẹp này giúp đảm bảo hiệu năng, tránh làm tắc nghẽn khả năng phát hiện các cuộc tấn công mới đang diễn ra.

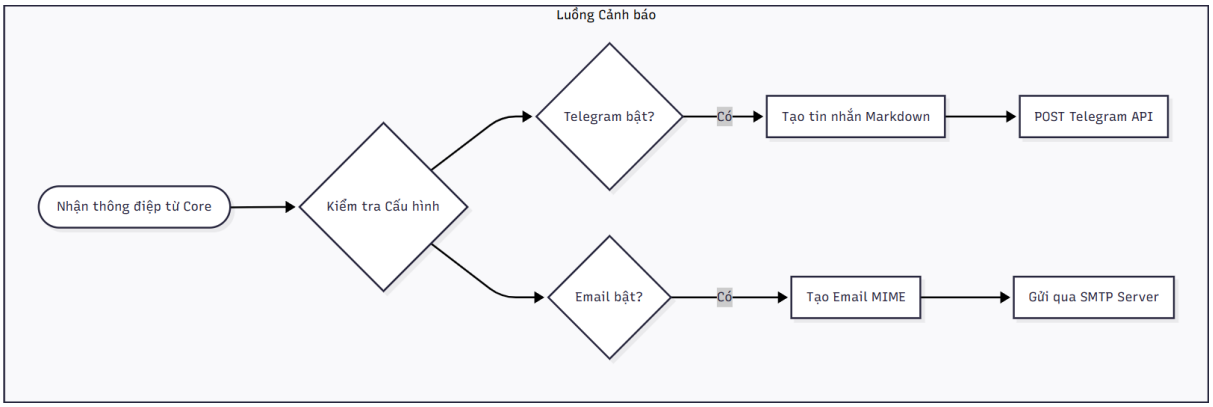
2.3.6. Hệ thống cảnh báo và API quản trị

Một hệ thống tự động hóa phản hồi (SOAR) hiệu quả không thể hoạt động như một "hộp đen". Để đảm bảo tính minh bạch và duy trì vai trò giám sát của con người (Human-in-the-loop), mô-đun được tích hợp hai phân hệ giao tiếp quan trọng: Hệ thống cảnh báo đa kênh (chiều ra) và API quản trị (chiều vào).

Luồng xử lý thông tin giữa các kênh giao tiếp này được mô tả khái quát trong hình 2.12 và hình 2.13 dưới đây.



Hình 2.12: Lưu đồ luồng cảnh báo đa kênh



Hình 2.13: Lưu đồ luồng API quản trị

Hệ thống cảnh báo đa kênh (Multi-channel Notification): Lớp Notifier chịu trách nhiệm chuyển phát thông tin về các hành động ngăn chặn tới đội ngũ vận hành (SecOps). Hệ thống hỗ trợ hai kênh thông báo với mục đích sử dụng khác nhau:

- Kênh Telegram (Cảnh báo thời gian thực): Đây là kênh ưu tiên cho các sự cố khẩn cấp. Hệ thống sử dụng phương thức HTTP POST để gửi tin nhắn định dạng Markdown tới Telegram Bot API ngay khi một lệnh chặn IP được thực thi. Điều này giúp quản trị viên nắm bắt tình hình ngay lập tức trên thiết bị di động.
- Kênh Email (Lưu trữ và Kiểm toán): Đối với mục đích lưu vết (Audit Trail) và báo cáo định kỳ, hệ thống tích hợp giao thức SMTP. Các cảnh báo được đóng gói và gửi qua máy chủ mail doanh nghiệp, phục vụ cho việc tra soát lịch sử sau này.
- Chế độ kiểm thử (Dry-run): Để tránh gây nhiễu trong quá trình thử nghiệm, hệ thống tích hợp cờ dry_run. Khi kích hoạt, các cảnh báo chỉ được ghi vào log nội bộ (Console/File) mà không gửi tin nhắn đi, giúp quá trình debug an toàn hơn.

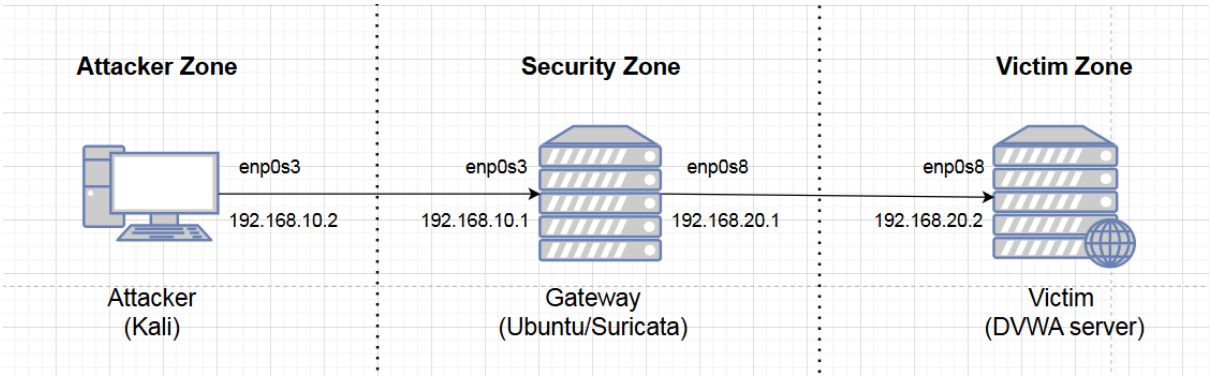
API Quản trị: Để cho phép can thiệp thủ công mà không cần truy cập trực tiếp vào dòng lệnh máy chủ (SSH), Mini-SOAR khởi chạy một máy chủ HTTP nhẹ (Lightweight HTTP Server) hoạt động trên một luồng riêng biệt .

- Cơ chế hoạt động: API lắng nghe trên cổng 9000 và tiếp nhận các yêu cầu HTTP GET.
- Chức năng xử lý: Endpoint /api/unban cho phép quản trị viên gỡ bỏ lệnh cấm đối với một IP cụ thể ngay lập tức (trong trường hợp chặn nhầm - False Positive). Lệnh này sẽ gọi trực tiếp xuống lớp FirewallDriver để xóa IP khỏi danh sách đen và đồng bộ lại trạng thái trong cơ sở dữ liệu.

CHƯƠNG 3: TRIỂN KHAI VÀ THỬ NGHIỆM

3.1. Kiến trúc tổng thể của hệ thống

3.1.1. Mô hình mạng triển khai (Network Topology)



Hình 3.1: Sơ đồ mạng

Hệ thống được triển khai trên nền tảng ảo hóa, được quy hoạch thành 3 phân vùng mạng riêng biệt kết nối với nhau thông qua một Gateway trung tâm. Cấu trúc chi tiết của từng thành phần như sau:

Vùng Tấn công (Attacker Zone)

Thiết bị: Máy ảo Kali Linux.

Cấu hình mạng:

Địa chỉ IP: 192.168.10.2/24.

Giao diện mạng: enp0s3.

Gateway trỏ về: 192.168.10.1.

Vai trò: Giả lập môi trường Internet bên ngoài, đóng vai trò là nguồn phát sinh các lưu lượng tấn công (Malicious Traffic). Tại đây thực hiện các kỹ thuật kiểm thử như: dò quét mạng (Nmap), tấn công từ chối dịch vụ (DoS), và khai thác lỗ hổng web (SQLi, XSS).

Vùng Phòng thủ (Security Zone) Đây là thành phần cốt lõi của hệ thống, đóng vai trò là "cửa ngõ" kiểm soát mọi lưu lượng đi vào và đi ra.

Thiết bị: Máy chủ Ubuntu Server.

Cấu hình mạng: Máy chủ được trang bị 2 card mạng để thực hiện chức năng định tuyến (Routing):

Giao diện WAN (enp0s3): Địa chỉ IP 192.168.10.1/24: Tiếp nhận lưu lượng từ vùng ngoài (Kali).

Giao diện LAN (enp0s8): Địa chỉ IP 192.168.20.1/24: Kết nối tới vùng mạng nội bộ (Victim).

Kiến trúc phần mềm (Software Stack): Trên Gateway được tích hợp các module bảo mật:

Nftables (Firewall): Thực thi các quy tắc lọc gói tin ở tầng mạng và chịu trách nhiệm chuyển hướng lưu lượng vào hàng đợi NFQUEUE để phân tích.

Suricata (IPS Engine): Hoạt động ở chế độ Inline, thực hiện phân tích sâu gói tin để phát hiện và ngăn chặn tấn công theo thời gian thực.

Mini-SOAR (Active Response): Module Python tự phát triển, giám sát log và tự động cập nhật luật chặn lên Firewall khi phát hiện mối đe dọa nghiêm trọng.

ELK Stack (Monitoring): Hệ thống thu thập (Filebeat), lưu trữ (Elasticsearch) và trực quan hóa (Kibana) nhật ký an ninh.

Vùng Nạn nhân (Internal Zone / Victim)

Thiết bị: Máy chủ chạy ứng dụng web DVWA (Damn Vulnerable Web App).

Cấu hình mạng:

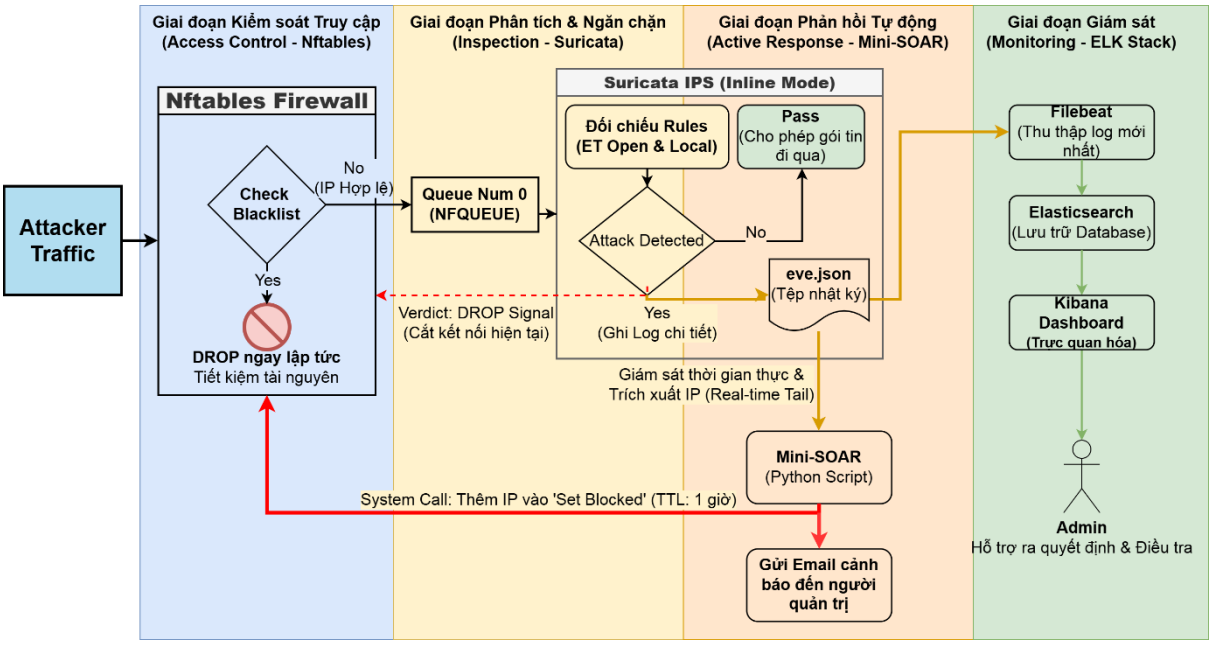
Địa chỉ IP: 192.168.20.2/24.

Giao diện mạng: enp0s8 (kết nối vào mạng LAN 192.168.20.0/24).

Gateway trỏ về: 192.168.20.1.

Vai trò: Máy chủ mục tiêu chứa các lỗ hổng bảo mật, được bảo vệ phía sau Gateway. Mọi truy cập đến máy này đều bắt buộc phải đi qua sự kiểm duyệt của Suricata.

3.1.2. Luồng dữ liệu và Nguyên lý hoạt động



Hình 3.2: Kiến trúc tổng thể của hệ thống

a. Luồng dữ liệu (Data Flow):

Quy trình xử lý một cuộc tấn công diễn ra theo 4 giai đoạn liên tiếp:

Giai đoạn Kiểm soát Truy cập (Access Control - Nftables):

Mọi gói tin đi vào đều phải đi qua bộ lọc Nftables.

Tại đây, hệ thống kiểm tra địa chỉ IP nguồn:

- Nếu IP nằm trong danh sách chặn (set blocked): Gói tin bị hủy (DROP) ngay lập tức để tiết kiệm tài nguyên.
- Nếu IP hợp lệ: Gói tin được chuyển tiếp vào hàng đợi người dùng số 0 (queue num 0) để chờ phân tích sâu.

Giai đoạn Phân tích & Ngăn chặn (Inspection - Suricata):

Suricata hoạt động ở chế độ Inline, liên tục lấy gói tin từ hàng đợi để giải mã và đối chiếu với bộ luật (ET Open & Local Rules).

Nếu phát hiện dấu hiệu tấn công (ví dụ: SQLi payload), Suricata sẽ thực hiện đồng thời hai hành động:

- Gửi tín hiệu Verdict: DROP về Nftables để cắt đứt kết nối hiện tại.
- Ghi chi tiết sự kiện vào tệp nhật ký eve.json.

Nếu không phát hiện gì Suricata sẽ cho gói tin đi qua để đến với web DVWA.

Giai đoạn Phản hồi Tự động (Active Response - Mini-SOAR):

Module Mini-SOAR (Python) chạy ngầm và giám sát thời gian thực tệp eve.json.

Khi nhận được cảnh báo tấn công, module thực hiện logic nghiệp vụ:

- Phân tích: Trích xuất địa chỉ IP nguồn (src_ip) và loại hình tấn công (signature) từ dòng log.
- Ngăn chặn (Blocking): Gửi lệnh hệ thống (System Call) xuống Nftables để thêm IP này vào danh sách đen (set blocked) với thời gian tồn tại (TTL) là 1 giờ.
- Cảnh báo (Notification): Song song với hành động chặn, module kết nối tới máy chủ SMTP (Gmail) để gửi một Email cảnh báo chi tiết đến người quản trị. Nội dung email bao gồm: Thời gian phát hiện, IP tấn công và Tên loại tấn công.

Cơ chế này đảm bảo kẻ tấn công bị cô lập hoàn toàn khỏi hệ thống, đồng thời người quản trị được thông báo tức thời về sự cố.

Giai đoạn Giám sát (Monitoring - ELK Stack):

Song song với quá trình phản hồi, Filebeat thu thập dữ liệu log mới nhất và đồng bộ về cơ sở dữ liệu Elasticsearch.

Người quản trị theo dõi tình hình an ninh mạng thông qua các biểu đồ trực quan trên Kibana Dashboard, hỗ trợ việc ra quyết định và điều tra sự cố sau này.

b. Nguyên lý hoạt động và Cơ chế kết nối (Operating Principles & Interconnection)

Hệ thống hoạt động dựa trên 3 cơ chế liên kết chính giúp các công cụ rời rạc trở thành một thể thống nhất:

Cơ chế NFQUEUE (Kết nối Nftables ↔ Suricata) Đây là cầu nối giữa tầng nhân hệ điều hành (Kernel space) và tầng ứng dụng (User space).

- Nguyên lý: Nftables chỉ có khả năng lọc gói tin dựa trên IP/Port (Layer 3/4) nhưng không hiểu nội dung bên trong (Payload). Suricata có khả

năng phân tích sâu (DPI) nhưng không nắm giữ quyền điều khiển gói tin thực tế.

- Tương tác: Nftables tạm giữ gói tin và ủy quyền quyết định cho Suricata thông qua hàng đợi NFQUEUE. Suricata sau khi phân tích sẽ trả về một phán quyết (Verdict) là NF_ACCEPT hoặc NF_DROP. Nftables buộc phải tuân theo phán quyết này.

Cơ chế Event-Driven (Kết nối Suricata ↔ Mini-SOAR ↔ Email) Đây là cơ chế phản ứng tự động dựa trên sự kiện (Event-driven Automation).

- Nguyên lý: Suricata không có chức năng tự động sửa đổi luật Firewall hay gửi Email. Do đó, Script Mini-SOAR đóng vai trò là "cánh tay nối dài".
- Tương tác:
    - Log-based Trigger: Script sử dụng kỹ thuật "tailing" (đọc nối đuôi) file eve.json. Ngay khi Suricata ghi một dòng log cảnh báo (Trigger), Script sẽ bắt được sự kiện đó.
    - System Call: Script sử dụng thư viện subprocess của Python để gọi lệnh hệ thống nft add element..., tác động trực tiếp lên cấu hình Firewall đang chạy.
    - SMTP Protocol: Script sử dụng thư viện smtplib để thiết lập phiên kết nối với Gmail Server, gửi cảnh báo đi ngay lập tức.

Cơ chế Log Shipping (Kết nối Suricata ↔ ELK Stack) Đây là cơ chế chuẩn hóa và tập trung dữ liệu.

- Nguyên lý: File log eve.json chứa dữ liệu thô và nằm cục bộ trên máy Gateway, rất khó để quản lý tổng thể. ELK Stack giúp biến dữ liệu này thành thông tin có thể tra cứu.
- Tương tác:
    - Filebeat đóng vai trò là "người vận chuyển". Nó được cấu hình module suricata để tự động hiểu cấu trúc JSON của log.
    - Elasticsearch đánh chỉ mục (Index) dữ liệu giúp việc tìm kiếm hàng triệu dòng log diễn ra trong tích tắc.

- Kibana truy vấn vào Elasticsearch để vẽ biểu đồ theo thời gian thực.

3.2.Mô tả thực nghiệm

Quá trình thực nghiệm được thiết kế nhằm kiểm chứng khả năng phát hiện (Detection) và ngăn chặn (Prevention) của hệ thống đối với các vector tấn công đa dạng, từ lớp ứng dụng đến hạ tầng mạng. Các kịch bản thử nghiệm được chia thành 4 nhóm chính dựa trên mục tiêu và phương thức tấn công:

3.2.1. Nhóm tấn công Ứng dụng Web (Web Application Attacks)

Mục tiêu là kiểm tra khả năng của Suricata trong việc phân tích nội dung gói tin HTTP (Deep Packet Inspection) để chặn các mã khai thác phổ biến nhắm vào lỗ hổng phần mềm.

SQL Injection (SQLi): Sử dụng các câu lệnh truy vấn SQL độc hại (như SELECT USER, UNION SELECT) chèn vào URL nhằm thao túng cơ sở dữ liệu.

Cross-Site Scripting (XSS): Chèn các đoạn mã JavaScript độc hại (thẻ <script>) vào ứng dụng web để tấn công người dùng cuối.

Path Traversal (LFI): Thử nghiệm truy cập trái phép vào các tập tin hệ thống nhạy cảm (ví dụ: /etc/passwd) thông qua việc thao túng đường dẫn URL.

Shellshock (RCE): Khai thác lỗ hổng thực thi mã từ xa thông qua HTTP Headers (CVE-2014-6271).

Malicious File Upload: Giả lập hành vi kẻ tấn công tải lên các Webshell (chứa mã nguồn PHP hoặc hàm system) để chiếm quyền điều khiển máy chủ.

3.2.2. Nhóm tấn công Hạ tầng Mạng (Network Infrastructure Attacks)

Mục tiêu là đánh giá khả năng bảo vệ tính sẵn sàng của hệ thống và phát hiện các hành vi do thám mạng.

Denial of Service (DoS): Thực hiện tấn công SYN Flood để làm tràn ngập tài nguyên mạng, kiểm chứng khả năng giới hạn lưu lượng (threshold) của hệ thống.

Network Scanning: Sử dụng Nmap với các tùy chọn quét sâu (OS Detection) để dò tìm thông tin hệ điều hành và dịch vụ đang chạy, kiểm tra khả năng nhận diện mẫu quét của IPS.

3.2.3. Nhóm tấn công Tự động và Dò mật khẩu (Automation & Brute Force)

Tập trung vào việc phát hiện các hành vi bất thường về tần suất truy cập.

Brute Force/Scanning: Sử dụng các công cụ tự động (như Hydra) để gửi lượng lớn yêu cầu đăng nhập hoặc dò quét thư mục trong thời gian ngắn, nhằm kiểm tra cơ chế phát hiện bất thường dựa trên ngưỡng (threshold).

3.2.4. Nhóm ngăn chặn lộ lọt dữ liệu (Data Loss Prevention - DLP)

Kiểm thử khả năng kiểm soát luồng dữ liệu chiều ra (Outbound) của hệ thống.

Information Leakage: Kiểm tra việc hệ thống chặn máy chủ gửi trả về các thông báo lỗi chi tiết của cơ sở dữ liệu (SQL Errors), giúp che giấu cấu trúc hệ thống.

Sensitive Data Exposure: Ngăn chặn việc nội dung các file nhạy cảm (như /etc/passwd) bị gửi ra ngoài internet ngay cả khi kẻ tấn công đã gửi được lệnh truy vấn thành công.

3.3.Cài đặt và triển khai hệ thống

3.3.1 Cài đặt và Cấu hình Suricata

Hệ thống Suricata được triển khai trên máy chủ Gateway đóng vai trò là động cơ phân tích và ngăn chặn xâm nhập (IPS Engine). Quá trình cấu hình tập trung vào việc định nghĩa vùng mạng bảo vệ và tích hợp với hàng đợi NFQUEUE của Linux Kernel.

a. Cài đặt và Tối ưu hóa môi trường

Suricata được cài đặt từ kho lưu trữ chính thức PPA của OISF (Open Information Security Foundation) để đảm bảo phiên bản ổn định mới nhất. Các thư viện phụ trợ (dependencies) như libnetfilter-queue được cài đặt đầy đủ để hỗ trợ chế độ Inline.

b. Cấu hình tham số vận hành (suricata.yaml)

Tệp cấu hình chính /etc/suricata/suricata.yaml được tinh chỉnh để định nghĩa luồng dữ liệu vào/ra và tích hợp với kiến trúc Gateway. Các nhóm tham số quan trọng bao gồm:

- Định nghĩa vùng mạng (Network Vars): Biến HOME_NET được thiết lập bao gồm dải mạng nội bộ chứa máy chủ DVWA (192.168.20.0/24). Điều này giúp Suricata phân biệt rõ ràng lưu lượng tấn công từ bên ngoài (EXTERNAL_NET) và lưu lượng nội bộ.
- Quản lý nguồn Luật (Rule Path): Chỉ định đường dẫn tới thư mục chứa luật. Hệ thống được cấu hình để nạp đồng thời bộ luật chuẩn ET Open (suricata.rules) và bộ luật tùy chỉnh cho DoS/Brute Force (local.rules).
- Cấu hình Nhật ký (Logging): Kích hoạt đầu ra eve-log định dạng JSON. Đặc biệt, tham số payload: yes được bật để ghi lại nội dung gói tin (ví dụ: câu lệnh SQL độc hại), phục vụ cho việc điều tra số và phân tích của Mini-SOAR.

Nội dung cấu hình tệp /etc/suricata/suricata.yaml:

```
Định nghĩa biến mạng
vars:
  address-groups:
    HOME_NET: "[192.168.20.0/24]"
    EXTERNAL_NET: "!$HOME_NET"
Cấu hình nguồn luật
default-rule-path: /var/lib/suricata/rules
rule-files:
  - suricata.rules      # Luật ET Open
  - local.rules         # Luật Local (DoS/Threshold)
Cấu hình đầu ra Log (cho ELK & Script)
outputs:
```

```
  - eve-log:
      enabled: yes
      filetype: regular
      filename: eve.json
      types:
        - alert:
            payload: yes                # Ghi payload để soi mã độc
            payload-buffer-size: 4kb
            payload-printable: yes
        - http:
            extended: yes
```

c. Quản lý Luật và Chính sách ngăn chặn

Theo cấu hình mặc định, các luật của Suricata chỉ hoạt động ở chế độ Cảnh báo (Alert), tức là chỉ ghi log mà không can thiệp vào lưu lượng. Để hệ thống hoạt động như một IPS thực thụ với khả năng chặn đứng tấn công, chính sách luật được cấu hình lại thông qua công cụ quản lý suricata-update.

Cấu hình chuyển đổi hành động (drop.conf) Tệp /etc/suricata/drop.conf được thiết lập để tự động chuyển hành động của các luật thuộc nhóm nguy hiểm từ Alert sang Drop. Chính sách này áp dụng cho cả các nhóm luật (Categories) và các bộ luật cụ thể của ET Open thông qua biểu thức chính quy.

Nội dung cấu hình tệp /etc/suricata/drop.conf:

```
# Chặn theo Nhóm luật (Categories)
group: sql-injection
group: exploit
group: malware
group: trojan
```

group: dos

group: attempted-admin

group: attempted-user

group: unsuccessful-user

group: web-application-attack

group: attack_response

Chặn theo Biểu thức chính quy (Regular Expression)

re: ET WEB_SERVER

re: ET WEB_SPECIFIC_APPS

re: ET SCAN

re: ET EXPLOIT

re: ET ATTACK_RESPONSE

re: ET DOS

Cấu hình Luật cục bộ (local.rules) Bên cạnh bộ luật chuẩn, tệp local.rules được bổ sung để định nghĩa các quy tắc phát hiện dựa trên ngưỡng (Thresholding). Điều này giúp lấp đầy khoảng trống của các luật dựa trên chữ ký, đặc biệt hiệu quả trong việc ngăn chặn các cuộc tấn công dựa trên hành vi như DoS SYN Flood hay Brute Force.

Áp dụng chính sách Sau khi định nghĩa các cấu hình trên, lệnh cập nhật được thực thi để hợp nhất các thay đổi vào tệp luật tổng thể suricata.rules: sudo suricata-update

d. Khởi chạy dịch vụ

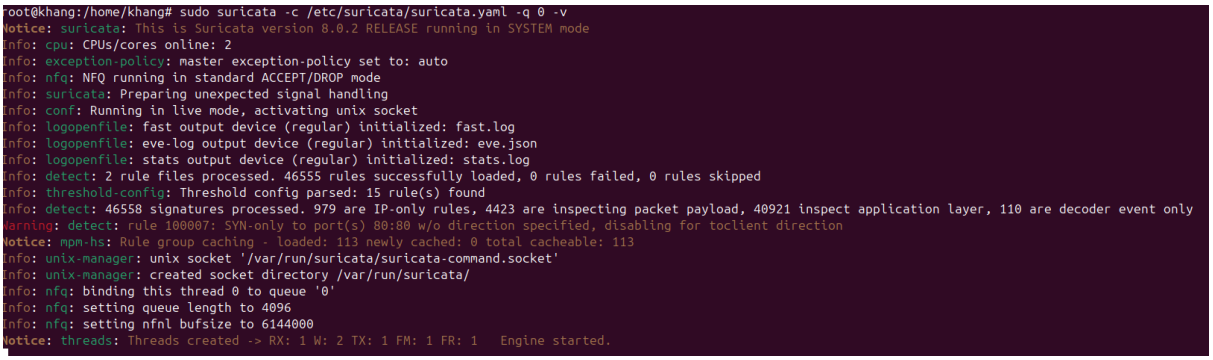
Để tích hợp hệ thống IPS với tường lửa Nftables, Suricata được khởi chạy với tham số dòng lệnh ghi đè chế độ lắng nghe mặc định.

Lệnh khởi chạy thực nghiệm:

sudo suricata -c /etc/suricata/suricata.yaml -q 0 –v

Giải thích tham số:

- -c ...: Chỉ định đường dẫn tệp cấu hình.
- -q 0: Tham số quan trọng nhất, kích hoạt chế độ NFQUEUE. Nó yêu cầu Suricata lấy gói tin từ hàng đợi số 0 của nhân hệ điều hành (Kernel) để xử lý thay vì lắng nghe thụ động trên card mạng. Điều này đảm bảo tính đồng bộ với luật chuyển hướng của Nftables.
- -v: Hiển thị thông tin chi tiết (Verbose) để giám sát quá trình nạp luật.



Hình 3.3: Khởi chạy Suricata

3.3.2 Triển khai ELK Stack (Log Management)

Hệ thống ELK (Elasticsearch, Logstash, Kibana) đóng vai trò là trung tâm giám sát an ninh, chịu trách nhiệm lưu trữ tập trung và trực quan hóa các dữ liệu cảnh báo từ Suricata. Trong mô hình này, thành phần Logstash được lược bỏ để tối ưu hóa tài nguyên, dữ liệu sẽ được chuyển trực tiếp từ Filebeat vào Elasticsearch.

a. Chuẩn bị môi trường và Kho lưu trữ

Để đảm bảo tính ổn định và khả năng tương thích với các module hiện đại, hệ thống sử dụng kho lưu trữ (Repository) chính thức phiên bản 8.x của Elastic. Khóa GPG (GnuPG) được thêm vào hệ thống để xác thực gói cài đặt.

b. Cài đặt và Cấu hình Elasticsearch

Elasticsearch đóng vai trò là cơ sở dữ liệu NoSQL, thực hiện việc đánh chỉ mục (Indexing) cho dữ liệu log để phục vụ tìm kiếm nhanh.

Cấu hình tham số (elasticsearch.yml): Tệp cấu hình được tinh chỉnh để hoạt động tối ưu trong môi trường Lab (Single-node). Các tính năng bảo mật phức tạp (như SSL/TLS nội bộ) được vô hiệu hóa để đơn giản hóa quá trình tích hợp với Filebeat.

Nội dung cấu hình tệp /etc/elasticsearch/elasticsearch.yml:

Cấu hình Mạng

network.host: localhost

http.port: 9200

Khởi chạy dịch vụ: Dịch vụ Elasticsearch được kích hoạt khởi động cùng hệ thống để đảm bảo tính sẵn sàng.

```
root@khang:/home/khang# sudo systemctl status elasticsearch
● elasticsearch.service - Elasticsearch
     Loaded: loaded (/usr/lib/systemd/system/elasticsearch.service; enabled; preset: enabled)
     Active: active (running) since Thu 2025-12-04 14:12:03 +07; 16min ago
       Docs: https://www.elastic.co
   Main PID: 3293 (java)
      Tasks: 93 (limit: 4548)
     Memory: 1.1G (peak: 1.3G swap: 522.4M swap peak: 526.2M)
        CPU: 1min 55.871s
     CGroup: /system.slice/elasticsearch.service
             ├─3293 /usr/share/elasticsearch/jdk/bin/java -Xms4m -Xmx64m -XX:+UseSerialGC -Dcli
             ├─3417 /usr/share/elasticsearch/jdk/bin/java -Des.networkaddress.cache.ttl=60 -Des
             └─3458 /usr/share/elasticsearch/modules/x-pack-ml/platform/linux-x86_64/bin/contro

Dec 04 14:11:08 khang systemd[1]: Starting elasticsearch.service - Elasticsearch...
Dec 04 14:12:03 khang systemd[1]: Started elasticsearch.service - Elasticsearch.
lines 1-15/15 (END)
```

Hình 3.4: Khởi chạy Elasticsearch thành công

c. Cài đặt và Cấu hình Kibana

Kibana cung cấp giao diện web để người quản trị tương tác với dữ liệu.

Cấu hình tham số (kibana.yml): Khác với Elasticsearch (chỉ nghe localhost), Kibana được cấu hình để lắng nghe trên tất cả các giao diện mạng (0.0.0.0). Điều này cho phép người quản trị truy cập Dashboard từ máy trạm bên ngoài.

Nội dung cấu hình tệp /etc/kibana/kibana.yml:

Cấu hình truy cập từ xa

server.port: 5601

server.host: "0.0.0.0"

Kết nối tới Database

elasticsearch.hosts: ["http://localhost:9200"]

Khởi chạy dịch vụ: Sau khi cấu hình, dịch vụ Kibana được khởi động và mở cổng 5601.

```
root@khang:/home/khang# sudo systemctl status kibana
● kibana.service - Kibana
     Loaded: loaded (/usr/lib/systemd/system/kibana.service; enabled; preset: enabled)
     Active: active (running) since Thu 2025-12-04 14:11:08 +07; 20min ago
       Docs: https://www.elastic.co
   Main PID: 3296 (node)
      Tasks: 11 (limit: 4548)
     Memory: 607.9M (peak: 900.8M swap: 214.8M swap peak: 223.5M)
        CPU: 1min 8.619s
     CGroup: /system.slice/kibana.service
```

Hình 3.5:Khởi chạy Kibana thành công

3.3.3 Cài đặt Filebeat (Log Shipper)

Filebeat đóng vai trò là tác nhân (Agent) thu thập log nhẹ, được cài đặt ngay trên máy chủ Suricata để vận chuyển nhật ký sự kiện về hệ thống trung tâm ELK theo thời gian thực.

a. Cài đặt và Kích hoạt Module chuyên dụng

Filebeat được cài đặt từ kho lưu trữ Elastic 8.x. Điểm ưu việt của Filebeat là khả năng tích hợp sẵn các Module phân tích log. Trong hệ thống này, module suricata được kích hoạt để tự động hóa việc phân tích cú pháp (Parsing) tệp JSON và ánh xạ các trường dữ liệu (Field mapping) chuẩn ECS (Elastic Common Schema).

Cấu hình Module Suricata (/etc/filebeat/modules.d/suricata.yml): Đường dẫn tới tệp log eve.json được khai báo chính xác để Filebeat theo dõi liên tục.

```
- module: suricata
  eve:
      enabled: true
      # Đường dẫn tới file log đầu ra của Suricata
      var.paths: ["/var/log/suricata/eve.json"]
```

b. Cấu hình Kết nối và Đầu ra (Output)

Tệp cấu hình chính /etc/filebeat/filebeat.yml được thiết lập để định nghĩa đích đến của dữ liệu và nạp các tài nguyên trực quan hóa.

Kết nối tới Kibana: Thiết lập này cho phép Filebeat tự động tải lên các Dashboard mẫu và Index Pattern.

Kết nối tới Elasticsearch: Đây là nơi lưu trữ dữ liệu log thực tế. Do Filebeat và Elasticsearch nằm trên cùng một máy chủ Gateway, giao thức kết nối được thiết lập qua localhost để tối ưu tốc độ.

Nội dung cấu hình tệp /etc/filebeat/filebeat.yml:

```
# Cấu hình nạp Dashboard (Setup)
setup.kibana:
    host: "localhost:5601"
# Cấu hình gửi Log (Output)
output.elasticsearch:
    hosts: ["localhost:9200"]
    protocol: "http"
```

c. Khởi tạo Tài nguyên và Vận hành

Trước khi khởi chạy dịch vụ, lệnh setup được thực thi một lần duy nhất. Quá trình này sẽ khởi tạo các bảng điều khiển (Dashboard) trực quan chuyên biệt cho Suricata trên giao diện Kibana.

Lệnh khởi tạo: sudo filebeat setup

Khởi chạy dịch vụ: Filebeat được kích hoạt chạy nền để đảm bảo việc vận chuyển log diễn ra liên tục 24/7.

3.3.4 Triển khai Mini-SOAR (Active Response Script)

Mini-SOAR là module tự động hóa phản hồi sự cố được phát triển bằng ngôn ngữ Python. Thành phần này đóng vai trò "bộ não" xử lý sự kiện, kết nối giữa dữ liệu cảnh báo từ Suricata và hành động ngăn chặn trên Tường lửa Nftables.

a. Chuẩn bị môi trường vận hành (Environment Setup)

Module yêu cầu môi trường Python 3.8 trở lên cùng các thư viện phụ thuộc để xử lý file YAML và giao thức SMTP. Cấu trúc thư mục được quy hoạch tại /opt/mini_soar/ để đảm bảo tính tách biệt hệ thống.

Thư viện phụ thuộc: pyyaml (đọc cấu hình), requests (gửi API nếu cần), smtplib (gửi Email cảnh báo).

Cơ sở dữ liệu: Sử dụng SQLite cục bộ để lưu trạng thái các phiên chặn (Session Tracking), phục vụ cho cơ chế tự động mở khóa (Unban) sau khi hết thời gian phạt.

b. Cấu hình và Mã nguồn (Source Code Deployment)

Tệp cấu hình (config.yaml): Tệp này định nghĩa các tham số vận hành quan trọng như danh sách trắng (Whitelist) để tránh chặn nhầm quản trị viên, thông số Email gửi cảnh báo và thời gian cấm IP (Ban Duration).

Nội dung cấu hình tệp /opt/mini_soar/config.yaml:

```
# Cấu hình chung
eve_log: "/var/log/suricata/eve.json"
db_path: "/var/lib/mini_soar/mini_soar.db"
ban_ttl: 3600              # Thời gian chặn: 1 giờ
# Danh sách trắng (Không bao giờ chặn)
whitelist:
  - "127.0.0.1"
  - "192.168.20.2"       # Web Server
  - "192.168.10.1"       # Gateway
# Cấu hình Email Cảnh báo
smtp_server: "smtp.gmail.com"
smtp_port: 587
smtp_user: "admin_email@gmail.com"
mail_to: security_team@gmail.com
```

Mã nguồn điều khiển (mini_soar.py): Đây là lõi xử lý chính của module. Script thực hiện giám sát thời gian thực tệp log (Log Tailing) và tương tác trực tiếp với Kernel thông qua lệnh hệ thống (System Call).

```
def block_ip(self, ip_addr):
    """Thực thi lệnh chặn IP ở tầng mạng"""
    if ip_addr in self.whitelist:
        return
    # Thêm IP vào Set 'blocked' của Nftables
    cmd = f"nft add element inet filter blocked {{ {ip_addr} }}"
    subprocess.run(cmd, shell=True)
    # Gửi cảnh báo Email
    self.send_alert_email(ip_addr)
    logger.warning(f"Active Response: Blocked IP {ip_addr}")
```

c. Thiết lập Tự động hóa (Systemd Service)

Để đảm bảo module hoạt động liên tục như một dịch vụ nền (Daemon) và tự động khởi động cùng hệ điều hành, một Unit File Systemd được thiết lập.

Nội dung tệp dịch vụ /etc/systemd/system/mini-soar.service:

```
[Unit]
Description=Mini-SOAR Active Response Engine
After=network.target suricata.service
[Service]
Type=simple
User=root
WorkingDirectory=/opt/mini_soar
ExecStart=/usr/bin/python3 /opt/mini_soar/mini_soar.py --config config.yaml
```

Restart=always

RestartSec=5

[Install]

WantedBy=multi-user.target

d. Kiểm tra

Sau khi kích hoạt dịch vụ, trạng thái hoạt động được kiểm tra để đảm bảo module đã kết nối thành công với Nftables và luồng log.

Trạng thái dịch vụ: Sử dụng lệnh systemctl status mini-soar để xác nhận dịch vụ đang chạy (active running).

Kiểm tra lớp bảo vệ Firewall: Sử dụng lệnh nft list ruleset để xác minh danh sách chặn (set blocked) đã được khởi tạo và sẵn sàng tiếp nhận IP tấn công.

3.4.Triển khai các kịch bản thử nghiệm

3.4.1. Kịch bản 1: Ngăn chặn tấn công SQL Injection (SQLi)

Mục tiêu: Kiểm chứng khả năng phân tích sâu gói tin (DPI) dựa trên chữ ký (Signature-based) để phát hiện và ngăn chặn các câu lệnh truy vấn cơ sở dữ liệu trái phép được chèn vào đường dẫn URL (GET Request).

Công cụ thực hiện: Trình duyệt Firefox / Lệnh curl trên Kali Linux.

Payload tấn công: Sử dụng kỹ thuật UNION-BASED SQL Injection nhằm trích xuất tên người dùng và mật khẩu từ cơ sở dữ liệu:

1' UNION SELECT user, password FROM users#

Phân tích quá trình Phát hiện và Ngăn chặn Quy trình xử lý cuộc tấn công diễn ra qua 3 bước liên tiếp:

Bước 1: Cơ chế Phát hiện (Detection) Khi gói tin chứa payload đi qua Gateway, Suricata giải mã giao thức HTTP và phân tích trường URI. Hệ thống so khớp nội dung gói tin với bộ luật ET Open và phát hiện sự trùng khớp với luật có SID 2010963.

- Dấu hiệu nhận biết: Chuỗi ký tự SELECT xuất hiện cùng với USER trong đường dẫn, vi phạm quy tắc bảo mật ứng dụng Web.
- Ghi nhận: Hệ thống ghi lại sự kiện vào log với mức độ nghiêm trọng (Severity) cao.

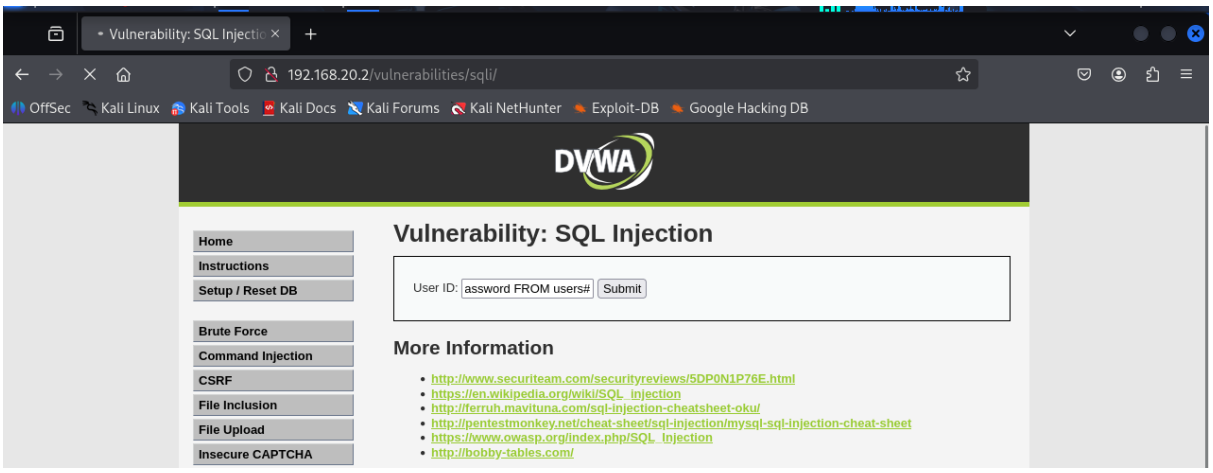
Bước 2: Cơ chế Ngăn chặn tức thời (Immediate Prevention) Do luật này đã được cấu hình hành động là DROP trong file drop.conf, Suricata ngay lập tức gửi tín hiệu về Nftables để hủy gói tin này. Kết nối TCP bị ngắt ngay lập tức trước khi yêu cầu đến được Web Server.

Bước 3: Cơ chế Phản hồi tự động (Active Response) Ngay sau khi log cảnh báo được ghi nhận, module Mini-SOAR thực hiện:

- Ra lệnh cho Firewall chặn cứng IP nguồn 192.168.10.2 trong 1 giờ.
- Gửi Email cảnh báo chi tiết tới người quản trị.

Kết quả thực nghiệm:

Tại phía tấn công: Trình duyệt web treo ở trạng thái chờ (Loading) và sau đó báo lỗi kết nối. Kẻ tấn công không nhận được bất kỳ dữ liệu nào.



Hình 3.6: Trang web không phản hồi sau khi kẻ tấn công submit lệnh tấn công

Tại hệ thống phòng thủ:

- Suricata Log: Ghi nhận hành động Drop đối với gói tin chứa mã độc SQL.

```
12/04/2025-21:09:35.298790  [Drop] [**] [1:2010963:7] ET WEB_SERVER SELECT USER
SQL Injection Attempt in URI [**] [Classification: Web Application Attack] [Prio
rity: 1] {TCP} 192.168.10.2:52568 -> 192.168.20.2:80
```

Hình 3.7: Log Suricata báo drop gói tin với rule SQL Injection

- Active Response Log: Script ghi nhận việc thực thi lệnh Ban IP và gửi mail thành công.

```
[2025-12-04 21:12:16,472] [INFO] ALERT: Blocked 192.168.10.2 for 7200s (Rule: SQ
L Injection Attack)
[2025-12-04 21:12:21,676] [INFO] EMAIL SENT to khangvu2517@gmail.com
```

Hình 3.8: Log ban IP và gửi thông tin về email của script theo Rule SQL Injection

- Email Notification: Quản trị viên nhận được cảnh báo tức thời trên điện thoại/máy tính.

Hình 3.9: Thông báo blocked IP do Rule SQL Injection được gửi về Email

3.4.2. Kịch bản 2: Ngăn chặn tấn công Cross-Site Scripting (XSS)

Mục tiêu: Đánh giá khả năng kiểm soát nội dung gói tin HTTP (Content Inspection) để phát hiện và ngăn chặn các đoạn mã JavaScript độc hại được chèn vào tham số ứng dụng web (Reflected XSS), ngăn ngừa nguy cơ đánh cắp phiên làm việc (Session Hijacking) của người dùng.

Công cụ thực hiện: Trình duyệt web hoặc công cụ gửi request thủ công.

Payload tấn công: Chèn thẻ kịch bản cơ bản vào thanh địa chỉ để kiểm tra phản ứng của hệ thống: <script>alert('XSS')</script>

Phân tích quá trình Phát hiện và Ngăn chặn Quy trình xử lý mã độc XSS diễn ra qua 3 bước:

Bước 1: Cơ chế Phát hiện (Detection) Suricata thực hiện giải mã và phân tích trường URI của gói tin HTTP GET gửi lên máy chủ. Hệ thống đối chiếu chuỗi ký tự trong URL với bộ luật bảo mật Web và tìm thấy sự trùng khớp với luật SID 2009714.

- Dấu hiệu nhận biết: Sự xuất hiện của thẻ mở HTML <script> nằm ngay trên thanh địa chỉ. Đây là dấu hiệu đặc trưng của tấn công XSS dạng phản xạ.
- Ghi nhận: Hệ thống định danh sự kiện là "ET WEB_SERVER Script tag in URI" và ghi log cảnh báo.

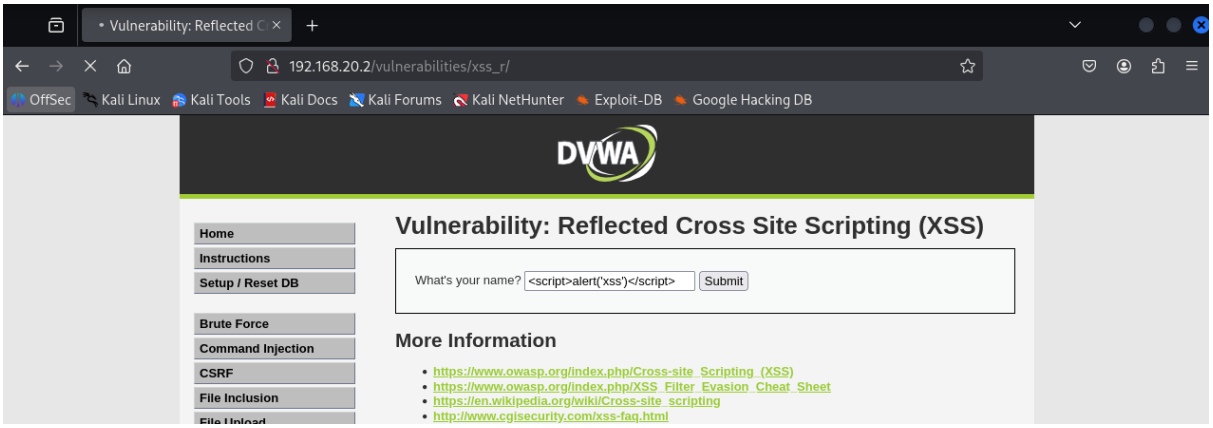
Bước 2: Cơ chế Ngăn chặn tức thời (Immediate Prevention) Dựa trên chính sách drop.conf (nhóm web-application-attack), Suricata kích hoạt hành động DROP. Gói tin chứa mã độc bị hủy bỏ ngay lập tức tại Gateway, không cho phép đi vào Web Server để thực thi trên trình duyệt nạn nhân.

Bước 3: Cơ chế Phản hồi tự động (Active Response) Script Mini-SOAR phát hiện log cảnh báo XSS và kích hoạt quy trình phản ứng:

- Gọi lệnh hệ thống để thêm IP tấn công vào danh sách đen của Nftables.
- Gửi email thông báo sự cố kèm theo nội dung payload bị chặn.

Kết quả thực nghiệm:

Tại phía tấn công: Trình duyệt không hiển thị hộp thoại cảnh báo (Pop-up Alert) như mong đợi của kẻ tấn công. Thay vào đó, kết nối bị ngắt đột ngột (Connection Reset) hoặc báo lỗi không thể truy cập.



Hình 3.10: Trang web không phản hồi sau khi kẻ tấn công submit lệnh tấn công

Tại hệ thống phòng thủ:

- Suricata Log: Ghi nhận log chặn gói tin chứa thẻ <script> trong URI.

```
12/04/2025-21:13:40.139739  [Drop] [**] [1:2009714:9] ET WEB_SERVER Script tag i
n URI Possible Cross Site Scripting Attempt [**] [Classification: Web Applicatio
n Attack] [Priority: 1] {TCP} 192.168.10.2:51058 -> 192.168.20.2:80
```

Hình 3.11: Log Suricata báo drop gói tin với rule XSS

- Active Response Log: Script ghi nhận hành động cấm IP (Ban) thành công.

```
[2025-12-04 21:13:40,224] [INFO] Incident: 192.168.10.2 | ET WEB_SERVER Script t
ag in URI Possible Cross Site Scripting Attempt
[2025-12-04 21:13:40,260] [INFO] ALERT: Blocked 192.168.10.2 for 3600s (Rule: XS
S / Scripting)
[2025-12-04 21:13:44,258] [INFO] EMAIL SENT to khangvu2517@gmail.com
```

Hình 3.12: Log ban IP và gửi thông tin về email của script theo Rule XSS

- Email Notification: Quản trị viên nhận được cảnh báo về cuộc tấn công XSS kèm theo IP nguồn.

Hình 3.13: Thông báo blocked IP do Rule XSS được gửi về Email

3.4.3. Kịch bản 3: Ngăn chặn tấn công Path Traversal (LFI)

Mục tiêu: Kiểm chứng khả năng bảo vệ các tập tin cấu hình hệ thống nhạy cảm (như /etc/passwd, /etc/shadow). Thử nghiệm được thực hiện để chứng minh tính độc lập nền tảng của hệ thống IPS: Suricata có thể ngăn chặn tấn công truy cập file trái phép trên cả ứng dụng có sẵn (DVWA) lẫn các trang web tùy biến (test_lfi.php) mà không cần vá lỗ hổng trên mã nguồn.

Công cụ thực hiện: Sử dụng trình lệnh curl để gửi yêu cầu HTTP nguyên bản, giúp quan sát rõ mã lỗi trả về ở tầng mạng.

Payload tấn công: Sử dụng kỹ thuật leo thang thư mục (Directory Traversal) với chuỗi ../ để truy cập file mật khẩu của hệ điều hành Linux:

curl -v http://192.168.20.2/dvwa/vulnerabilities/fi/?page=../../../../etc/passwd

Phân tích quá trình Phát hiện và Ngăn chặn Quy trình xử lý cuộc tấn công truy cập file trái phép diễn ra như sau:

Bước 1: Cơ chế Phát hiện (Detection) Suricata thực hiện phân tích chuỗi ký tự (Pattern Matching) trên toàn bộ đường dẫn URI của yêu cầu. Hệ thống đối chiếu với bộ luật bảo mật máy chủ Web và phát hiện sự trùng khớp với luật SID 2049400.

- Dấu hiệu nhận biết: Sự xuất hiện của chuỗi đường dẫn tuyệt đối /etc/passwd. Đây là dấu hiệu rõ ràng của nỗ lực đọc trộm file hệ thống Linux.
- Ghi nhận: Hệ thống định danh sự kiện là "ET WEB_SERVER /etc/passwd Detected in URI" và ghi log.

Bước 2: Cơ chế Ngăn chặn tức thời (Immediate Prevention) Do tính chất nghiêm trọng của việc lộ lọt cấu hình hệ thống, luật này đã được cấu hình hành động DROP trong drop.conf. Suricata gửi phán quyết về Nftables để hủy gói tin ngay tại Gateway.

Bước 3: Cơ chế Phản hồi tự động (Active Response) Quy trình phản ứng của Mini-SOAR được kích hoạt ngay khi log xuất hiện:

- Thực thi lệnh hệ thống để chặn đứng IP nguồn của kẻ tấn công tại tường lửa.
- Gửi cảnh báo qua Email để quản trị viên kiểm tra lại quyền hạn file trên server.

Kết quả thực nghiệm:

Tại phía tấn công: Lệnh curl không nhận được mã HTTP 200 OK hay nội dung file /etc/passwd. Thay vào đó, kết nối bị đóng đột ngột bởi máy chủ trung gian.

```
┌──(kali㉿kali)-[~]
└─$ curl -v "http://192.168.20.2/test_lfi.php?file=../../../../etc/pas
swd"
*   Trying 192.168.20.2:80 ...
* Connected to 192.168.20.2 (192.168.20.2) port 80
* using HTTP/1.x
> GET /test_lfi.php?file=../../../../etc/passwd HTTP/1.1
> Host: 192.168.20.2
> User-Agent: curl/8.13.0
> Accept: */*
>
* Request completely sent off
```

Hình 3.14: Phía tấn công không nhận được phản hồi

Tại hệ thống phòng thủ:

- Suricata Log: Nhật ký ghi nhận chính xác hành động chặn truy cập vào file /etc/passwd.

```
12/04/2025-21:15:23.969165  [Drop] [**] [1:2049400:1] ET WEB_SERVER /etc/passwd
Detected in URI [**] [Classification: Attempted Information Leak] [Priority: 2]
{TCP} 192.168.10.2:37548 -> 192.168.20.2:80
```

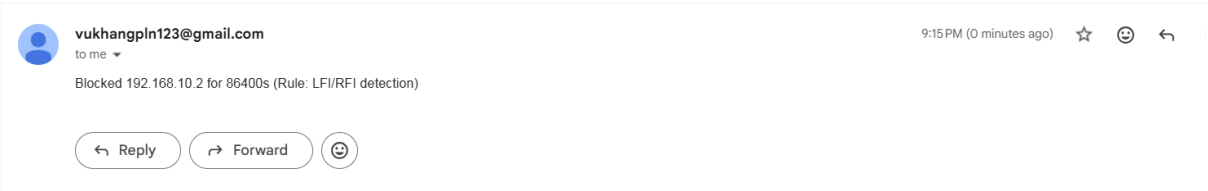
Hình 3.15: Log Suricata báo drop gói tin với rule LFI

- Active Response Log: Script ghi nhận việc thực thi lệnh cấm IP thành công.

```
[2025-12-04 21:15:24,108] [INFO] Incident: 192.168.10.2 | ET WEB_SERVER /etc/pas
swd Detected in URI
[2025-12-04 21:15:24,191] [INFO] ALERT: Blocked 192.168.10.2 for 86400s (Rule: L
FI/RFI detection)
[2025-12-04 21:15:27,903] [INFO] EMAIL SENT to khangvu2517@gmail.com
```

Hình 3.16: Log ban IP và gửi thông tin về email của script theo Rule LFI

- Email Notification: Hòm thư quản trị viên nhận được cảnh báo về nỗ lực truy cập file trái phép.



Hình 3.17: Thông báo blocked IP do Rule LFI được gửi về Email

3.4.4. Kịch bản 4: Ngăn chặn tải lên mã độc (Malicious File Upload)

Mục tiêu: Kiểm chứng tính năng phân tích sâu gói tin (Deep Packet Inspection - DPI) đối với phần thân của gói tin HTTP (HTTP Body). Kịch bản nhằm chứng minh hệ thống có khả năng phát hiện nội dung mã độc (Webshell) ẩn bên trong các tệp tin được tải lên máy chủ, ngăn chặn nguy cơ thực thi mã từ xa (RCE).

Công cụ thực hiện: Chức năng Upload của DVWA.

Payload tấn công: Kẻ tấn công cố gắng tải lên một tệp tin có tên shell.php chứa mã nguồn Webshell đơn giản (One-liner Web Shell) để chiếm quyền điều khiển server:

<?php system($_GET['cmd']); ?>

Phân tích quá trình Phát hiện và Ngăn chặn Quy trình xử lý hành vi tải lên mã độc diễn ra qua 3 bước:

Bước 1: Cơ chế Phát hiện (Detection) Khi người dùng thực hiện hành động POST để gửi file, Suricata tiến hành giải mã và phân tích vùng dữ liệu http_client_body. Hệ thống đối chiếu nội dung file với bộ luật ET Open và tìm thấy sự trùng khớp với luật SID 2020102.

- Dấu hiệu nhận biết: Hệ thống phát hiện sự tồn tại đồng thời của thẻ mở PHP (<?php) và hàm thực thi lệnh hệ thống nguy hiểm (system) nằm trong nội dung file tải lên. Đây là chữ ký đặc trưng của các loại mã độc Webshell.
- Ghi nhận: Hệ thống định danh sự kiện là "ET WEB_SERVER PHP System Command in HTTP POST".

Bước 2: Cơ chế Ngăn chặn tức thời (Immediate Prevention) Do thuộc nhóm luật web-application-attack đã được cấu hình trong chính sách drop.conf, Suricata lập tức gửi phán quyết DROP về Nftables. Kết nối truyền tải file bị cắt đứt ngay khi các byte chứa mã độc đi qua Gateway.

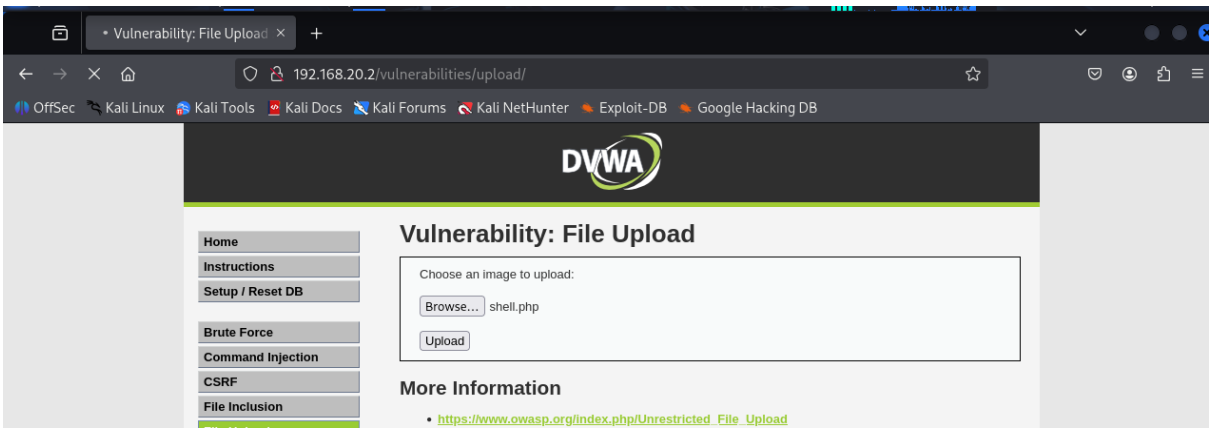
Bước 3: Cơ chế Phản hồi tự động (Active Response) Script Mini-SOAR nhận diện hành vi tải mã độc là cực kỳ nguy hiểm:

- Thực thi lệnh chặn cứng IP nguồn của kẻ tấn công tại tường lửa.

- Gửi email cảnh báo khẩn cấp tới quản trị viên kèm theo thông tin chi tiết về loại mã độc phát hiện.

Kết quả thực nghiệm:

Tại phía tấn công: Quá trình tải file bị gián đoạn giữa chừng. Trình duyệt không nhận được phản hồi thành công từ server (HTTP 200) mà rơi vào trạng thái mất kết nối (Connection Reset). File mã độc không thể xuất hiện trên thư mục của Web Server.



Hình 3.18: Trang web không phản hồi sau khi kẻ tấn công submit lệnh tấn công

Tại hệ thống phòng thủ:

- Suricata Log: Nhật ký ghi nhận việc chặn gói tin HTTP POST có chứa hàm system của PHP.

```
12/04/2025-21:17:07.951084  [Drop] [**] [1:2020102:5] ET WEB_SERVER PHP System C
ommand in HTTP POST [**] [Classification: Web Application Attack] [Priority: 1]
{TCP} 192.168.10.2:50200 -> 192.168.20.2:80
```

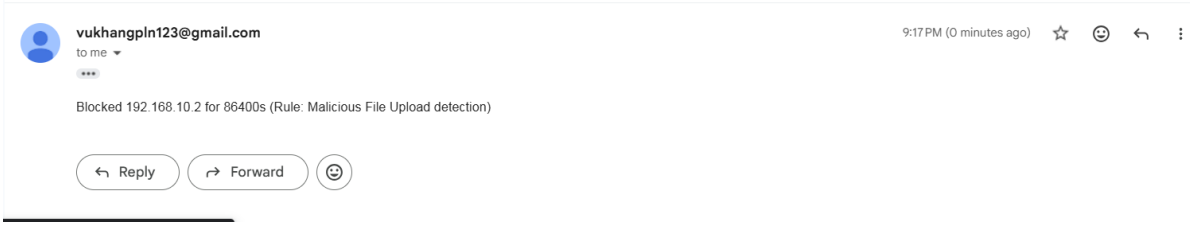
Hình 3.19: Log Suricata báo drop gói tin với rule nội dung chứa mã độc

- Active Response Log: Script ghi nhận hành động cấm IP (Ban) và gửi mail cảnh báo.

```
[2025-12-04 21:17:12,261] [INFO] Incident: 192.168.10.2 | ET WEB_SERVER PHP Syst
em Command in HTTP POST
[2025-12-04 21:17:12,329] [INFO] ALERT: Blocked 192.168.10.2 for 86400s (Rule: M
alicious File Upload detection)
[2025-12-04 21:17:16,238] [INFO] EMAIL SENT to khangvu2517@gmail.com
```

Hình 3.20: Log ban IP và gửi thông tin về email của script theo Rule nội dung chứa mã độc

- Email Notification: Quản trị viên nhận được thông báo về nỗ lực tải lên Webshell bị ngăn chặn.



Hình 3.21: Thông báo blocked IP do Rule nội dung chứa mã độc được gửi về Email

3.4.5. Kịch bản 5: Ngăn chặn tấn công từ chối dịch vụ (DoS - SYN Flood)

Mục tiêu: Đánh giá khả năng chịu tải của hệ thống và kiểm chứng cơ chế phát hiện tấn công dựa trên ngưỡng (Thresholding) được định nghĩa trong Luật cục bộ (local.rules). Kịch bản này nhằm chứng minh hiệu quả của module Mini-SOAR trong việc giảm tải cho hệ thống IPS bằng cách chuyển tác vụ chặn xuống tầng tường lửa (Network Layer) khi đối mặt với lưu lượng tấn công cường độ cao.

Công cụ thực hiện: hping3.

Lệnh tấn công: Thực hiện tấn công ngập lụt cờ SYN (SYN Flood) hướng tới cổng Web (80) của máy nạn nhân:

sudo hping3 -S --flood -V -p 80 192.168.20.2

Phân tích quá trình Phát hiện và Ngăn chặn Khác với các kịch bản tấn công Web, quy trình xử lý DoS dựa trên việc đếm tần suất:

Bước 1: Cơ chế Phát hiện (Anomaly Detection) Suricata theo dõi luồng kết nối TCP. Bộ đếm ngưỡng (Threshold) trong luật SID 100008 (file local.rules) được kích hoạt.

- Logic phát hiện: Nếu một địa chỉ IP nguồn gửi quá 20 gói tin SYN trong vòng 1 giây, hệ thống xác định đây là hành vi bất thường, không phải truy cập của người dùng thực.
- Ghi nhận: Hệ thống định danh sự kiện là "IPS - DoS Attack: SYN Flood Detected".

Bước 2: Cơ chế Ngăn chặn tức thời (Immediate Prevention) Suricata gửi phán quyết DROP về Nftables. Các gói tin SYN tiếp theo bị hủy bỏ, ngăn chặn việc máy chủ Web phải cấp phát tài nguyên cho các kết nối giả mạo (tránh tràn bảng kết nối).

Bước 3: Cơ chế Phản hồi tự động (Active Response) Đây là bước quan trọng nhất trong kịch bản DoS. Script Mini-SOAR phát hiện cảnh báo và thực hiện chiến lược "Giảm tải":

- Chặn tại tầng mạng: Thêm IP 192.168.10.2 vào bảng filter của Nftables.
- Hiệu quả: Sau khi bị chặn bởi Nftables, các gói tin tấn công sẽ bị loại bỏ ngay tại cửa ngõ Kernel mà không cần đi vào Suricata để phân tích nữa. Điều này giúp CPU của Gateway không bị quá tải, đảm bảo hệ thống vẫn sống sót dù lưu lượng tấn công rất lớn.

Kết quả thực nghiệm:

Tại phía tấn công: Công cụ hping3 ghi nhận tỷ lệ mất gói tin (Packet Loss) là 100%. Không có bất kỳ gói tin nào nhận được phản hồi (ACK) từ máy chủ đích. Cuộc tấn công bị vô hiệu hóa hoàn toàn.

```
┌──(kali㉿kali)-[~]
└─$ sudo hping3 -S --flood -V -p 80 192.168.20.2
[sudo] password for kali:
using eth0, addr: 192.168.10.2, MTU: 1500
HPING 192.168.20.2 (eth0 192.168.20.2): S set, 40 headers + 0 data byt
es
hping in flood mode, no replies will be shown
^C
--- 192.168.20.2 hping statistic ---
385603 packets transmitted, 0 packets received, 100% packet loss
round-trip min/avg/max = 0.0/0.0/0.0 ms
```

Hình 3.22: Phía tấn công thất bại khi các gói tin đã bị chặn

Tại hệ thống phòng thủ:

- Suricata Log: Nhật ký hiển thị hàng loạt cảnh báo về hành vi SYN Flood vượt ngưỡng cho phép.

```
12/04/2025-21:18:29.241169  [wDrop] [**] [1:100008:1] IPS - DoS Attack: SYN Floo
d Detected [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.10.2:41093
-> 192.168.20.2:80
12/04/2025-21:18:30.242237  [wDrop] [**] [1:100008:1] IPS - DoS Attack: SYN Floo
d Detected [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.10.2:60716
-> 192.168.20.2:80
12/04/2025-21:18:31.244091  [wDrop] [**] [1:100008:1] IPS - DoS Attack: SYN Floo
d Detected [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.10.2:23505
-> 192.168.20.2:80
12/04/2025-21:18:32.242680  [wDrop] [**] [1:100008:1] IPS - DoS Attack: SYN Floo
d Detected [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.10.2:54349
-> 192.168.20.2:80
```

Hình 3.23: Log Suricata báo drop gói tin với rule Dos

- Active Response Log: Script ghi nhận việc ban hành lệnh chặn IP cấp tốc để bảo vệ tài nguyên.

```
[2025-12-04 21:18:24,219] [INFO] Incident: 192.168.10.2 | IPS - DoS Attack: SYN
Flood Detected
[2025-12-04 21:18:24,421] [INFO] ALERT: Blocked 192.168.10.2 for 86400s (Rule: D
oS)
[2025-12-04 21:18:28,493] [INFO] EMAIL SENT to khangvu2517@gmail.com
```

Hình 3.24:Log ban IP và gửi thông tin về email của script theo Rule Dos

- Email Notification: Quản trị viên nhận được cảnh báo về cuộc tấn công từ chối dịch vụ đang diễn ra.

Hình 3.25: Thông báo blocked IP do Rule Dos được gửi về Email

3.4.6. Kịch bản 6: Ngăn chặn dò quét mạng (Network Scanning)

Mục tiêu: Phát hiện và ngăn chặn sớm các hành vi thu thập thông tin hạ tầng (Information Gathering) trong giai đoạn trinh sát. Kịch bản nhằm kiểm chứng khả năng nhận diện các dấu hiệu đặc trưng (Fingerprint) của các công cụ quét tự động phổ biến như Nmap, ngăn kẻ tấn công xác định hệ điều hành, phiên bản dịch vụ và các cổng đang mở.

Công cụ thực hiện: nmap

Lệnh tấn công: Sử dụng tùy chọn quét tích cực (Aggressive Scan -A) kết hợp quét cổng Web:

nmap -A -p 80 192.168.20.2

Phân tích quá trình Phát hiện và Ngăn chặn Quy trình xử lý hành vi dò quét diễn ra qua 3 bước:

Bước 1: Cơ chế Phát hiện (Signature Detection) Khi Nmap thực hiện tính năng nhận diện hệ điều hành (OS Detection), nó gửi đi các gói tin UDP chứa các mẫu ký tự đặc biệt (ví dụ: chuỗi chữ 'C' lặp lại). Suricata phân tích gói tin và đối chiếu với bộ luật ET SCAN.

- Dấu hiệu nhận biết: Hệ thống phát hiện mẫu gói tin trùng khớp với luật SID 2018489 ("ET SCAN NMAP OS Detection Probe"). Ngoài ra, các hành vi quét Script cũng bị phát hiện thông qua chuỗi User-Agent đặc trưng của Nmap.
- Ghi nhận: Hệ thống định danh sự kiện là hành vi dò quét mạng nguy hiểm.

Bước 2: Cơ chế Ngăn chặn tức thời (Immediate Prevention) Dựa trên chính sách bảo mật, các hành vi dò quét (ET SCAN) được cấu hình hành động DROP. Suricata cắt đứt kết nối ngay lập tức, khiến Nmap không nhận được phản hồi từ mục tiêu.

Bước 3: Cơ chế Phản hồi tự động (Active Response) Script Mini-SOAR nhận diện hành vi dò quét là tiền đề của các cuộc tấn công lớn hơn:

- Ra lệnh cho Firewall chặn cứng IP nguồn 192.168.10.2.
- Gửi email cảnh báo tới quản trị viên để thông báo về việc hạ tầng mạng đang bị nhòm ngó.

Kết quả thực nghiệm:

Tại phía tấn công: Nmap không thể hoàn thành quá trình quét. Công cụ báo lỗi kết nối hoặc trả về kết quả sai lệch "Host seems down" (Máy chủ dường như đã tắt). Kẻ tấn công không thu thập được bất kỳ thông tin nào về hệ điều hành hay phiên bản phần mềm của Web Server.

```
┌──(kali㉿kali)-[~]
└─$ nmap -A -p 80 192.168.20.2
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-04 09:19 EST
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is
 disabled. Try using --system-dns or specify valid servers with --dns-
servers
```

Hình 3.26: Phía tấn công không nhận được phản hồi

Tại hệ thống phòng thủ:

- Suricata Log: Nhật ký ghi nhận chính xác hành động chặn các gói tin thăm dò của Nmap.

```
12/04/2025-21:20:04.173040  [wDrop] [**] [1:2018489:4] ET SCAN NMAP OS Detection
 Probe [**] [Classification: Attempted Information Leak] [Priority: 2] {UDP} 192
.168.10.2:47756 -> 192.168.20.2:39980
```

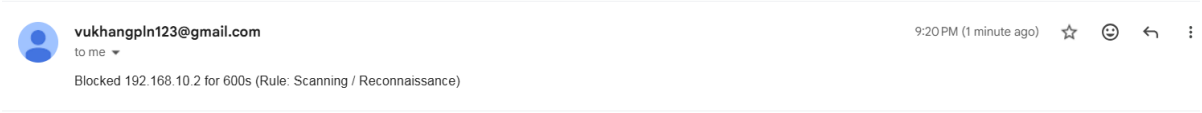
Hình 3.27: Log Suricata báo drop gói tin với rule Port Scanning

- Active Response Log: Script ghi nhận việc thực thi lệnh cấm IP thành công.

```
[2025-12-04 21:20:11,037] [INFO] Incident: 192.168.10.2 | ET SCAN NMAP OS Detect
ion Probe
[2025-12-04 21:20:11,068] [INFO] ALERT: Blocked 192.168.10.2 for 600s (Rule: Sca
nning / Reconnaissance)
[2025-12-04 21:20:14,772] [INFO] EMAIL SENT to khangvu2517@gmail.com
```

Hình 3.28: Log ban IP và gửi thông tin về email của script theo Rule Port Scanning

- Email Notification: Quản trị viên nhận được cảnh báo sớm về hành vi dò quét mạng.



Hình 3.29: Thông báo blocked IP do Rule Port Scanning được gửi về Email

3.4.7. Kịch bản 7: Ngăn chặn tấn công dò quét và Brute Force Web

Mục tiêu: Đánh giá khả năng phát hiện các hành vi truy cập bất thường dựa trên tần suất (Rate-limiting/Thresholding). Kịch bản này mô phỏng việc kẻ tấn công sử dụng các công cụ tự động để dò đoán mật khẩu (Brute Force) hoặc rà quét cấu trúc thư mục (Directory Fuzzing) với tốc độ cao, gây áp lực lên máy chủ Web.

Công cụ thực hiện: Hydra công cụ bẻ khóa mật khẩu trực tuyến song song.

Lệnh tấn công: Sử dụng Hydra để tấn công từ điển vào trang đăng nhập của DVWA:

hydra -l admin -P rockyou.txt 192.168.20.2 http-post-form "/dvwa/login.php:username=^USER^&password=^PASS^&Login=Login:Login failed" -t 4 –V

Phân tích quá trình Phát hiện và Ngăn chặn Quy trình xử lý dựa trên việc giám sát hành vi kết nối TCP tới cổng dịch vụ:

Bước 1: Cơ chế Phát hiện (Behavioral Detection) Suricata không kiểm tra nội dung mật khẩu đúng hay sai, mà giám sát tần suất khởi tạo kết nối từ một địa chỉ IP nguồn tới cổng 80. Rule cục bộ SID 100007 (trong file local.rules) được kích hoạt.

- Logic phát hiện: Quy tắc được thiết lập với ngưỡng: 10 kết nối trong vòng 10 giây. Nếu một IP vượt quá giới hạn này, Suricata xác định đây là hành vi dò quét tự động (Scanner/Bot) thay vì người dùng thông thường.
- Ghi nhận: Hệ thống định danh sự kiện là "IPS - Possible Web Brute Force or Scan".

Bước 2: Cơ chế Ngăn chặn (Conditional Prevention)

- Giai đoạn đầu: Các gói tin đầu tiên (dưới ngưỡng 10) vẫn được phép đi qua, do đó Hydra có thể thử sai được vài mật khẩu đầu.
- Giai đoạn chặn: Ngay khi bộ đếm vượt ngưỡng, Suricata gửi phán quyết DROP về Nftables. Kể từ thời điểm này, mọi kết nối tiếp theo từ IP đó đều bị hủy bỏ.

Bước 3: Cơ chế Phản hồi tự động (Active Response) Script Mini-SOAR nhận diện hành vi Brute Force là mối đe dọa dai dẳng:

- Thực thi lệnh chặn cứng IP 192.168.10.2 tại tường lửa Nftables.
- Gửi email cảnh báo tới quản trị viên để thông báo về nỗ lực xâm nhập tài khoản trái phép.

Kết quả thực nghiệm:

Tại phía tấn công: Hydra thực hiện thành công khoảng 5-6 lần thử đầu tiên. Tuy nhiên, ngay sau đó, công cụ liên tục báo lỗi kết nối: [ERROR] Connection refused hoặc Timeout. Tốc độ tấn công giảm về 0, kẻ tấn công không thể tiếp tục thử các mật khẩu còn lại trong từ điển.

```
└─$ sudo hydra -l admin -P /usr/share/wordlists/rockyou.txt 192.168.20
.2 http-post-form "/dvwa/login.php:username=^USER^password=^PASS^&Logi
n=Login:Login failed" -t 4 -V
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not
 use in military or secret service organizations, or for illegal purpo
ses (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-12
-04 09:21:44
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I
to skip waiting)) from a previous session found, to prevent overwritin
g, ./hydra.restore
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries
 (l:1/p:14344399), ~3586100 tries per task
[DATA] attacking http-post-form://192.168.20.2:80/dvwa/login.php:usern
ame=^USER^password=^PASS^&Login=Login:Login failed
[ATTEMPT] target 192.168.20.2 - login "admin" - pass "123456" - 1 of 1
4344399 [child 0] (0/0)
[ATTEMPT] target 192.168.20.2 - login "admin" - pass "12345" - 2 of 14
344399 [child 1] (0/0)
[ATTEMPT] target 192.168.20.2 - login "admin" - pass "123456789" - 3 o
f 14344399 [child 2] (0/0)
[ATTEMPT] target 192.168.20.2 - login "admin" - pass "password" - 4 of
 14344399 [child 3] (0/0)
[ATTEMPT] target 192.168.20.2 - login "admin" - pass "iloveyou" - 5 of
 14344399 [child 2] (0/0)
[ATTEMPT] target 192.168.20.2 - login "admin" - pass "princess" - 6 of
 14344399 [child 1] (0/0)
[ATTEMPT] target 192.168.20.2 - login "admin" - pass "1234567" - 7 of
14344399 [child 3] (0/0)
[ATTEMPT] target 192.168.20.2 - login "admin" - pass "rockyou" - 8 of
14344399 [child 0] (0/0)
```

Hình 3.30: Phía tấn công không dò quét được do bị chặn

Tại hệ thống phòng thủ:

- Suricata Log: Nhật ký ghi nhận hàng loạt cảnh báo khi tần suất kết nối tăng đột biến.

```
12/04/2025-21:22:08.354898  [wDrop] [**] [1:100007:2] IPS - Possible Web Brute F
orce or Scan [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.10.2:5461
8 -> 192.168.20.2:80
12/04/2025-21:22:08.488097  [Drop] [**] [1:100007:2] IPS - Possible Web Brute Fo
rce or Scan [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.10.2:54644
 -> 192.168.20.2:80
```

Hình 3.31: Log Suricata báo drop gói tin với rule Brute Force

- Active Response Log: Script ghi nhận việc phát hiện hành vi Brute Force và ra lệnh cấm IP.

```
[2025-12-04 21:22:08,586] [INFO] Incident: 192.168.10.2 | IPS - Possible Web Bru
te Force or Scan
[2025-12-04 21:22:08,617] [INFO] ALERT: Blocked 192.168.10.2 for 86400s (Rule: B
rute force)
[2025-12-04 21:22:12,090] [INFO] EMAIL SENT to khangvu2517@gmail.com
```

Hình 3.32: Log ban IP và gửi thông tin về email của script theo Rule Brute Force

- Email Notification: Quản trị viên nhận được cảnh báo về hành vi dò mật khẩu.

Hình 3.33: Thông báo blocked IP do Rule Brute Force được gửi về Email

3.4.8. Kịch bản 8: Ngăn chặn tấn công Shellshock (Remote Code Execution)

Mục tiêu: Kiểm tra khả năng phát hiện các mã khai thác lỗ hổng phần mềm nghiêm trọng (CVE) được giấu kín bên trong các trường thông tin tiêu đề HTTP (HTTP Headers), cụ thể là trường User-Agent. Kịch bản này mô phỏng cuộc tấn công khai thác lỗ hổng Bash Shellshock (CVE-2014-6271) nhằm thực thi mã lệnh từ xa lên máy chủ web.

Công cụ thực hiện: Lệnh curl.

Payload tấn công: Gửi một yêu cầu HTTP với User-Agent chứa chuỗi ký tự đặc biệt có khả năng đánh lừa trình thông dịch Bash thực thi lệnh hệ thống:

curl -H "User-Agent: () { :; }; /bin/eject" http://192.168.20.2/dvwa/login.php -v

Phân tích quá trình Phát hiện và Ngăn chặn Quy trình xử lý tấn công dựa trên việc phân tích các trường Header của giao thức HTTP:

Bước 1: Cơ chế Phát hiện (Header Inspection) Suricata giải mã toàn bộ phần HTTP Header của gói tin yêu cầu. Hệ thống đối chiếu nội dung trường User-Agent với cơ sở dữ liệu luật ET EXPLOIT.

- Dấu hiệu nhận biết: Hệ thống phát hiện chuỗi ký tự đặc trưng () { :; };. Đây là chữ ký (Signature) nổi tiếng của lỗ hổng Shellshock, cho phép kẻ tấn công định nghĩa một hàm rỗng để thực thi lệnh phía sau nó.
- Ghi nhận: Hệ thống khớp với luật SID 2022028 ("ET EXPLOIT Possible CVE-2014-6271 Bash Vulnerability") và ghi log cảnh báo.

Bước 2: Cơ chế Ngăn chặn tức thời (Immediate Prevention) Do thuộc nhóm luật exploit nguy hiểm cao đã cấu hình trong drop.conf, Suricata kích hoạt hành động DROP. Gói tin bị hủy ngay lập tức, ngăn chặn máy chủ Web (Apache/Nginx) chuyển tiếp nội dung Header độc hại này xuống hệ điều hành (nơi Bash Shell đang hoạt động).

Bước 3: Cơ chế Phản hồi tự động (Active Response) Script Mini-SOAR xử lý sự kiện Shellshock như một cuộc tấn công vào hạ tầng nghiêm trọng:

- Ra lệnh chặn cứng IP 192.168.10.2 tại tường lửa Nftables.
- Gửi email cảnh báo khẩn cấp (Critical Alert) tới đội ngũ quản trị.

Kết quả thực nghiệm:

Tại phía tấn công: Yêu cầu HTTP không nhận được phản hồi từ máy chủ. Lệnh thực thi từ xa /bin/eject không được thực hiện.

```
┌──(kali㉿kali)-[~]
└─$ curl -H "User-Agent: () { :; }; /bin/eject" http://192.168.20.2/dvwa/login.php -v
*   Trying 192.168.20.2:80 ...
* Connected to 192.168.20.2 (192.168.20.2) port 80
* using HTTP/1.x
> GET /dvwa/login.php HTTP/1.1
> Host: 192.168.20.2
> Accept: */*
> User-Agent: () { :; }; /bin/eject
>
* Request completely sent off
```

Hình 3.34: Phía tấn công không nhận được phản hồi

Tại hệ thống phòng thủ:

- Suricata Log: Nhật ký ghi nhận chính xác việc phát hiện mã khai thác CVE-2014-6271 trong User-Agent.

```
12/04/2025-21:24:02.569204  [Drop] [**] [1:2022028:2] ET WEB_SERVER Possible CVE
-2014-6271 Attempt [**] [Classification: Attempted Administrator Privilege Gain]
 [Priority: 1] {TCP} 192.168.10.2:53408 -> 192.168.20.2:80
```

Hình 3.35: Log Suricata báo drop gói tin với rule liên quan tới lỗ hổng Bash Shellshock (CVE-2014-6271)

- Active Response Log: Script ghi nhận hành động cấm IP thành công.

```
[2025-12-04 21:24:02,698] [INFO] Incident: 192.168.10.2 | ET WEB_SERVER Possible
 CVE-2014-6271 Attempt
[2025-12-04 21:24:02,737] [INFO] ALERT: Blocked 192.168.10.2 for 86400s (Rule: R
CE / Command Injection)
[2025-12-04 21:24:06,563] [INFO] EMAIL SENT to khangvu2517@gmail.com
```

Hình 3.36: Log ban IP và gửi thông tin về email của script theo Rule liên quan tới lỗ hổng Bash Shellshock (CVE-2014-6271)

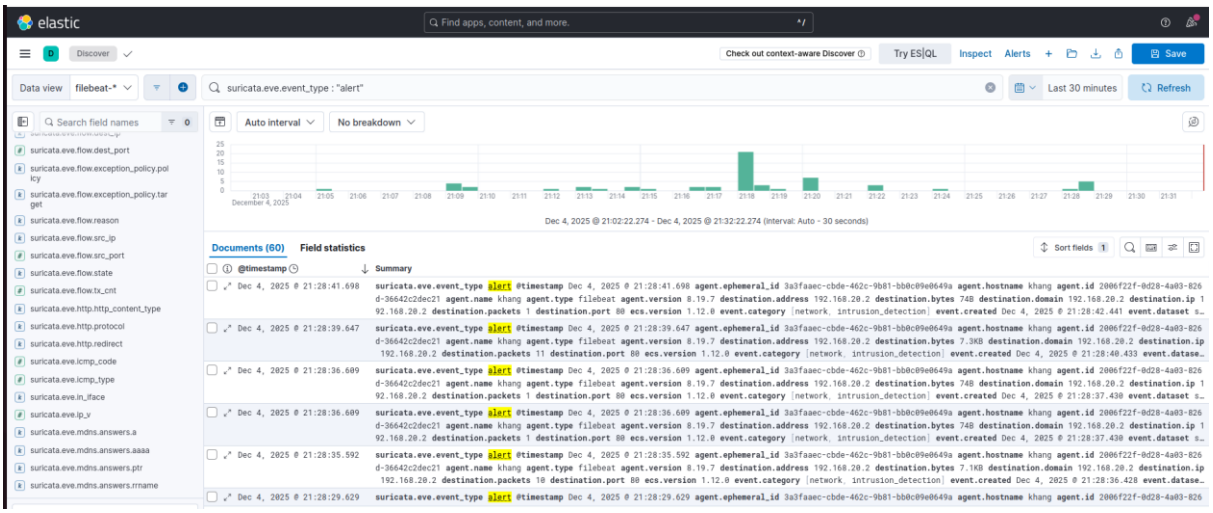
- Email Notification: Quản trị viên nhận được thông báo chi tiết về nỗ lực khai thác lỗ hổng.

Hình 3.37: Thông báo blocked IP do Rule liên quan tới lỗ hổng Bash Shellshock (CVE-2014-6271) được gửi về Email

3.5. Kết quả giám sát và trực quan hóa trên ELK Stack

3.5.1. Tra cứu log chi tiết (Discover)

Giao diện Discover trên Kibana đóng vai trò là công cụ điều tra chuyên sâu, cho phép người quản trị truy xuất dữ liệu thô (Raw Data) theo thời gian thực. Tại đây, từng sự kiện an ninh được phân tách thành các trường thông tin có cấu trúc.



Hình 3.38: Trang Discover được filter theo alert

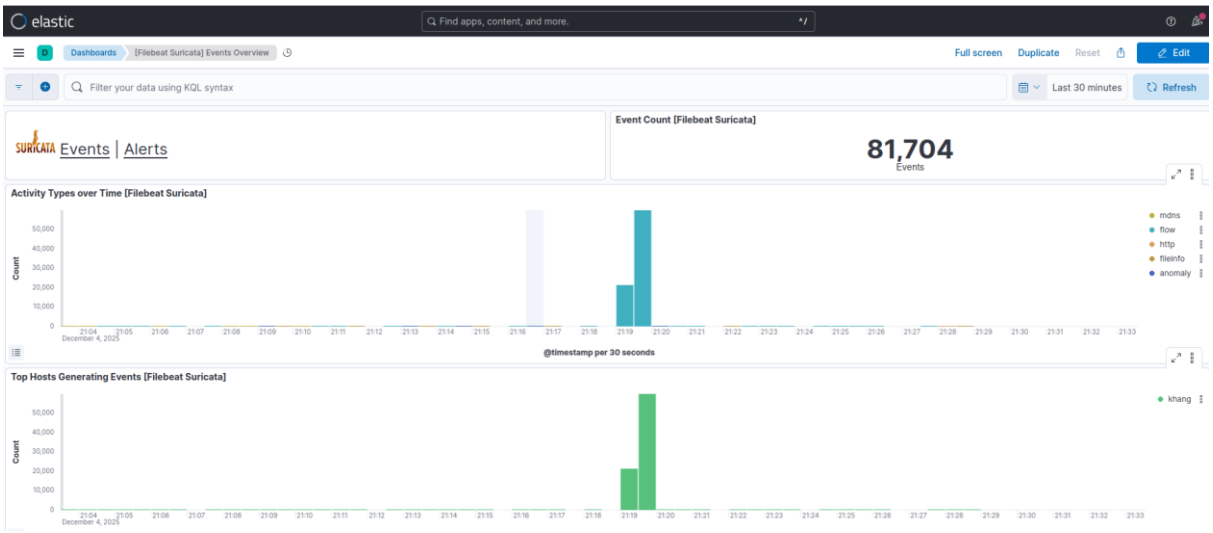
Phân tích các trường thông tin quan trọng: Dựa trên dữ liệu thu thập được, hệ thống cung cấp các thông tin chiến lược để xác định tính chất cuộc tấn công:

- Thời gian (@timestamp): Ghi nhận chính xác thời điểm xảy ra sự cố, khớp với thời gian thực nghiệm tấn công.
- Đối tượng (src_ip & dest_ip): Định danh rõ ràng kẻ tấn công (192.168.10.2) và mục tiêu (192.168.20.2).
- Hành động (alert.action): Đây là thông số quan trọng nhất. Trạng thái hiển thị là blocked (hoặc dropped), chứng minh hệ thống IPS đã can thiệp và ngăn chặn thành công, thay vì chỉ cảnh báo thụ động.

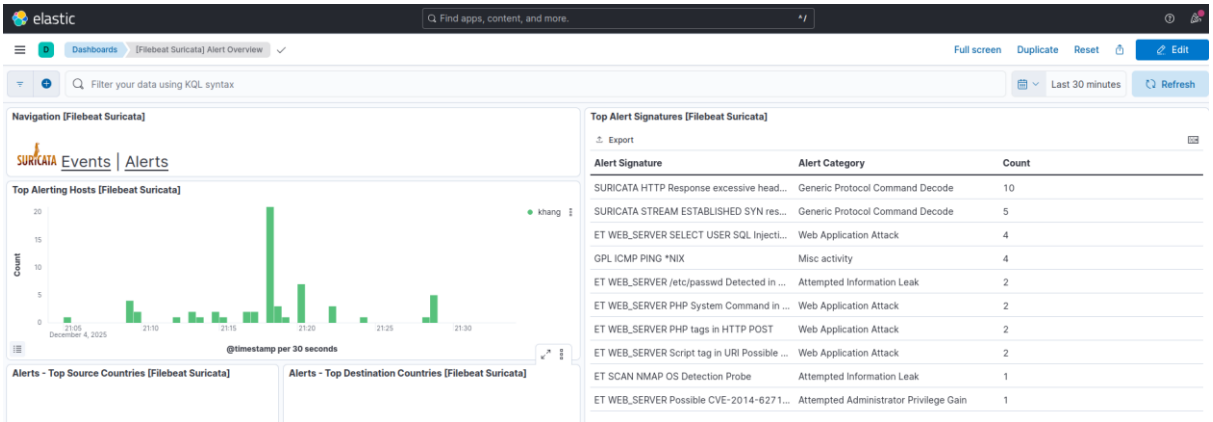
Khả năng truy vết chuỗi tấn công (Kill Chain):Thông qua tính năng lọc dữ liệu (Filter), người quản trị có thể tái hiện toàn bộ hành trình tấn công của hacker theo trình tự thời gian: Từ giai đoạn Dò quét (Nmap) $\rightarrow$ Thử nghiệm lỗ hổng (SQLi, XSS) $\rightarrow$ đến Tấn công phá hoại (DoS, Upload Shell). Điều này hỗ trợ đắc lực cho việc lập báo cáo sự cố và tinh chỉnh bộ luật bảo vệ.

3.5.2. Dashboard tổng quan (Visualization)

Bên cạnh việc tra cứu chi tiết, Dashboard cung cấp cái nhìn toàn cảnh về tình hình an ninh mạng (Situational Awareness) thông qua các biểu đồ trực quan hóa dữ liệu.



Hình 3.39: Dashboard theo Event Overview



Hình 3.40: Dashboard theo Alert Overview

Biểu đồ tần suất theo thời gian (Alerts over time):

- Biểu đồ cột hiển thị các đỉnh (Spike) về số lượng cảnh báo.
- Nhận xét: Các đỉnh của biểu đồ trùng khớp hoàn toàn với các mốc thời gian thực hiện lệnh tấn công nmap, hydra, và hping3 trong kịch bản thực nghiệm. Điều này giúp người quản trị nhanh chóng phát hiện thời điểm hệ thống bắt đầu chịu tải bất thường.

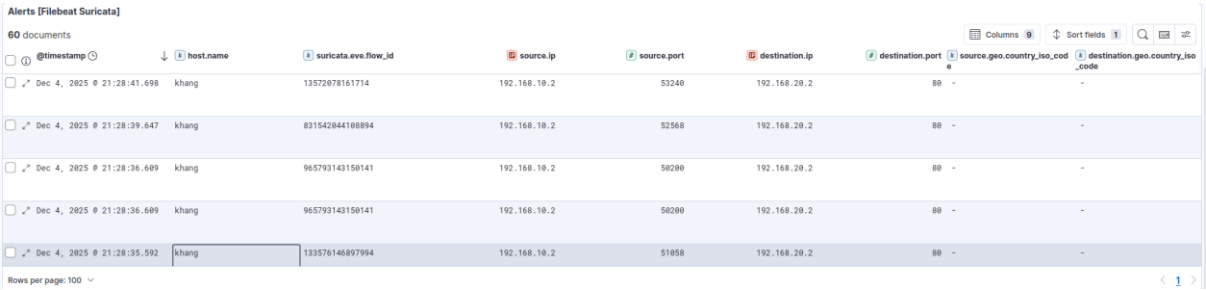
Thống kê loại hình tấn công (Top Alert Signatures):

- Bảng xếp hạng hiển thị các quy tắc (Rule) bị vi phạm nhiều nhất.
- Kết quả: Danh sách hiển thị đầy đủ các vector tấn công đã thử nghiệm như: ET SCAN Nmap, IPS - DoS Attack, SQL Injection.

- Ý nghĩa: Giúp xác định xu hướng tấn công chủ đạo để ưu tiên nguồn lực đối phó.

Thống kê nguồn và đích (Top Talkers):

- Top Source IPs: Xác định địa chỉ 192.168.10.2 chiếm 100% số lượng cảnh báo, khẳng định chính xác nguồn gốc cuộc tấn công.
- Top Destination IPs: Xác định máy chủ Web mục tiêu đang chịu ảnh hưởng.



Alerts [Filebeat Suricata]

60 documents

Columns 9 | Sort fields 1

@timestamp	host.name	suricata.eve.flow_id	source.ip	source.port	destination.ip	destination.port	source.geo.country_iso_code	destination.geo.country_iso_code
Dec 4, 2025 @ 21:28:41.698	khang	13572078161714	192.168.10.2	53240	192.168.20.2	80	-	-
Dec 4, 2025 @ 21:28:39.647	khang	831542044108894	192.168.10.2	52568	192.168.20.2	80	-	-
Dec 4, 2025 @ 21:28:36.609	khang	965793143150141	192.168.10.2	50200	192.168.20.2	80	-	-
Dec 4, 2025 @ 21:28:36.609	khang	965793143150141	192.168.10.2	50200	192.168.20.2	80	-	-
Dec 4, 2025 @ 21:28:35.592	khang	133576146897994	192.168.10.2	51058	192.168.20.2	80	-	-

Rows per page: 100

1

Hình 3.41: Thông tin của alert

Đánh giá hiệu quả giám sát: Việc tích hợp Dashboard mang lại hai giá trị thực tiễn lớn cho quy trình vận hành (SecOps):

- Phát hiện sớm: Giúp quản trị viên nhận diện bất thường chỉ trong vài giây quan sát biểu đồ mà không cần đọc hàng nghìn dòng log thô.
- Hỗ trợ ra quyết định: Dựa vào thống kê "Top Source IPs", người quản trị có thể nhanh chóng đưa ra quyết định chặn thủ công các dải IP nguy hiểm trong trường hợp hệ thống tự động gặp sự cố.

KẾT LUẬN

Đề tài "Hệ thống phát hiện và phản hồi xâm nhập sử dụng mã nguồn mở" đã hoàn thành các mục tiêu nghiên cứu đề ra, xây dựng thành công một giải pháp an ninh mạng khép kín, đáp ứng nhu cầu giám sát sâu và tự vệ chủ động với chi phí tối ưu. Hệ thống được thiết kế dựa trên sự tích hợp chặt chẽ giữa ba thành phần công nghệ cốt lõi, bao gồm Suricata đóng vai trò là bộ máy phát hiện với khả năng phân tích sâu gói tin đa luồng; ELK Stack đảm nhiệm chức năng trung tâm giám sát, chuẩn hóa và trực quan hóa dữ liệu; và đặc biệt là module Mini-SOAR do nhóm tự phát triển giúp tự động hóa hoàn toàn quy trình ngăn chặn tấn công thông qua việc tương tác trực tiếp với tường lửa Nftables.

Thông qua quá trình triển khai và kiểm thử thực nghiệm với các kịch bản tấn công đa dạng, hệ thống đã chứng minh được tính ổn định và hiệu quả bảo vệ vượt trội. Kết quả thực nghiệm cho thấy khả năng phát hiện và ngăn chặn thành công toàn bộ các mẫu tấn công thử nghiệm, từ các kỹ thuật khai thác lớp ứng dụng web như SQL Injection, XSS, Shellshock, File Upload cho đến các tấn công hạ tầng mạng như DoS SYN Flood và dò quét cổng. Điểm nổi bật của hệ thống nằm ở cơ chế "Phản hồi tương xứng" được vận hành bởi module Mini-SOAR, cho phép áp dụng thời gian ngăn chặn linh hoạt tùy theo mức độ nghiêm trọng của hành vi, kết hợp với cấu trúc Named Sets của Nftables để duy trì hiệu năng xử lý cao ngay cả khi danh sách chặn mở rộng lên tới hàng nghìn địa chỉ IP. Bên cạnh đó, tính năng cảnh báo đa kênh qua Telegram và Email cũng hoạt động chính xác, đảm bảo quản trị viên luôn nắm bắt được tình hình an ninh hệ thống theo thời gian thực.

Mặc dù đã đạt được những kết quả tích cực, đề tài vẫn tồn tại một số hạn chế nhất định cần được khắc phục trong giai đoạn phát triển tiếp theo. Hiện tại, hệ thống mới chỉ được kiểm chứng trong môi trường giả lập (Lab) với lưu lượng mạng hạn chế, chưa trải qua các bài kiểm tra chịu tải (Stress Test) trong môi trường doanh nghiệp thực tế với băng thông lớn, đồng thời khả năng phân tích lưu lượng mã hóa (HTTPS/TLS) còn phụ thuộc vào các giải pháp giải mã bổ trợ. Hướng phát triển sắp tới của đề tài sẽ tập trung vào việc tối ưu hóa mã nguồn module phản hồi để tiết kiệm tài nguyên hệ thống, xây dựng giao diện quản trị Web (Web GUI) trực quan hơn để thuận tiện cho

việc cấu hình luật, và nghiên cứu tích hợp các thuật toán học máy (Machine Learning) vào quy trình phân tích log nhằm nâng cao khả năng phát hiện các dấu hiệu bất thường chưa được định nghĩa trước. Tổng kết lại, đồ án đã cung cấp một mô hình tham chiếu khả thi và hiệu quả cho các tổ chức mong muốn xây dựng hệ thống phòng thủ an ninh mạng chủ động dựa trên nền tảng mã nguồn mở.

TÀI LIỆU THAM KHẢO

[1] **Bộ Khoa học và Công nghệ**, *Báo cáo an toàn thông tin mạng Việt Nam tháng 9/2024*, Cổng thông tin điện tử Bộ Khoa học và Công nghệ, 2024.

[2] **Carney, M.**, *A Taxonomy of Intrusion Response Systems*, Graduate Theses and Dissertations, Iowa State University, 2019.

[3] **Elastic**, *Suricata Integration*, Elastic Documentation, 2025.

[4] **GreyNoise Labs**, *Suricata evasion, starring URL decoding*, GreyNoise Research, 2025.

[5] **Hoover, C.**, *Comparative Study of Snort 3 and Suricata Intrusion Detection Systems*, Theses and Dissertations, University of Arkansas, 2020.

[6] **Imperva**, What is Slowloris? Examples & Mitigation Techniques, Imperva Learning Center.

[7] **Khraisat, A., Gondal, I., Vamplew, P., Kamruzzaman, J.**, *IoT Intrusion Detection Taxonomy, Reference Architecture, and Analyses*, Sensors, Vol. 21, Issue 19, MDPI, 2021.

[8] **Open Information Security Foundation (OISF)**, *Suricata User Guide*, Version 9.0.0-dev, 2025.

[9] **Shameli-Sendi, A., Ezzati-Jivan, N., Jabbarifar, M., Dagenais, M.**, *Intrusion Response Systems: Survey and Taxonomy*, International Journal of Computer Science and Network Security, Vol. 12, No. 1, 2012, pp. 1-14.

[10] **Sở Thông tin và Truyền thông Lâm Đồng**, *Tổng quan về tình hình an toàn thông tin mạng Việt Nam tháng 10/2024*, Cổng thông tin chuyển đổi số tỉnh Lâm Đồng, 2024.

[11] **Stamus Networks**, *Suricata vs Snort*, Stamus Networks Blog.

[12] **Stamus Networks**, *Threat Hunting with Suricata and Newly-Registered Domain Threat Intel*, Stamus Networks Blog.

[13] **Viettel Cyber Security**, *Báo cáo tình hình An ninh mạng tại Việt Nam năm 2024*, Tập đoàn Công nghiệp – Viễn thông Quân đội (Viettel), 2024.